

ACME Waters

Plan Integral de Ciberseguridad

Documento de anexos técnicos

Tipo de documento	Anexos
Autores	Miguel Campins Fernández
Fecha	Junio de 2026

Índice de anexos

Plan Integral de Ciberseguridad de ACME Waters

Ref.	Apartado	Contenido principal	Pág.
Anexo I	<u>Estrategia de ciberseguridad</u>	Objeto, diagnóstico, marco ENS/NIST, visión, objetivos, pilares, regulación, horizonte y conclusión.	2
I.1	<u>Marco y principios estratégicos</u>	Objeto, alcance, diagnóstico, marco rector, visión, principios y objetivos.	2-3
I.2	<u>Pilares, regulación y medición</u>	Pilares, líneas de acción, marco legal, horizonte, medición y conclusión.	3-6
Anexo II	<u>Organización del área de ciberseguridad</u>	Modelo DC/DIS, departamentos, comités, RACI, servicios gestionados, presupuesto, indicadores y aseguramiento.	7
II.1	<u>Modelo, roles y decisión</u>	Objeto, modelo DC/DIS, departamentos, responsabilidades, comités y gestión de crisis.	7-10
II.2	<u>RACI, servicios y presupuesto</u>	Procesos/RACI, servicios gestionados, presupuesto, indicadores, transición y aseguramiento.	11-14
Anexo III	<u>Análisis de riesgos</u>	Auditoría, amenazas, metodología, inventario, vulnerabilidades, red, cloud, teletrabajo, BIA, continuidad y riesgos R1-R11.	15
III.1	<u>Auditoría, amenazas y evidencias</u>	Plan de auditoría, detección de amenazas, calidad de logs, evidencias y custodia.	15-19
III.2	<u>Riesgo, activos y vulnerabilidades</u>	Metodología, trazabilidad, inventario, vulnerabilidades y dimensiones de riesgo.	19-25
III.3	<u>Red, cloud, teletrabajo y BIA</u>	Diseño lógico, flujos, cloud, teletrabajo, BIA, continuidad y riesgos R1-R11.	26-42
Anexo IV	<u>Gestión de la ciberseguridad y arquitectura tecnológica</u>	Plan Director, servicios, marcos, arquitectura, SIEM/SOAR, cifrado, vulnerabilidades, recuperación, roadmap y presupuesto.	43
IV.1	<u>Plan Director y servicios</u>	Objeto, trazabilidad, cartera P1-P12, servicios y marcos de referencia.	43-46
IV.2	<u>Arquitectura y capacidades</u>	Arquitectura, SIEM/SOAR, cifrado, vulnerabilidades, recuperación, roadmap y presupuesto.	46-49
Anexo V	<u>Respuesta a ciberataques</u>	Principios, ciclo de vida, roles, servicios, severidad, evidencias, SOAR, runbooks, continuidad, métricas y plantillas.	54
V.1	<u>Proceso, evidencias y automatización</u>	Objeto, principios, ciclo de vida, roles, severidad, proceso, evidencias y SOAR.	54-75
V.2	<u>Runbooks RB-01 a RB-12</u>	Catálogo y criterios forenses; runbooks RB-01 a RB-12.	75-108
V.3	<u>Continuidad, métricas y plantillas</u>	Coordinación con recuperación, métricas, ejercicios y plantillas operativas.	108-118
Refs.	<u>Referencias bibliográficas</u>	Fuentes públicas normativas y metodológicas utilizadas como marco.	119

Anexo I. Estrategia de ciberseguridad

1. Objeto y alcance

El presente anexo define la estrategia de ciberseguridad de ACME Waters como marco directivo para orientar el diseño, construcción, implantación y mejora continua del modelo de ciberseguridad corporativo. Se complementa con los anexos de análisis de riesgos, arquitectura técnica y respuesta a incidentes, y fija los principios, prioridades, objetivos y líneas de acción que deben dar coherencia al conjunto del Plan Integral de Ciberseguridad.

ACME Waters opera el ciclo integral del agua, con actividad nacional e internacional, 1.200.000 abonados y presencia en España, Europa, América del Sur y Asia. La ciberseguridad debe tratarse como una capacidad corporativa ligada a la continuidad de un servicio esencial, a la protección de datos personales, a la confianza de clientes y administraciones, y a la resiliencia de los procesos de negocio. El alcance estratégico será corporativo, aunque el desarrollo técnico del proyecto se focalice en la infraestructura crítica del Centro de Proceso de Datos gestionado desde TI dentro de la Dirección General de Operaciones.

La estrategia cubre personas, procesos, información, proveedores, aplicaciones, datos, identidades, servicios cloud, teletrabajo, infraestructuras TI y relaciones con tecnologías de operación. Debe distinguirse entre seguridad de la información y ciberseguridad: la primera protege la información en cualquier formato (digital, físico o verbal); la segunda protege sistemas, redes, identidades, dispositivos, aplicaciones y datos digitales frente a amenazas del ciberespacio. En ACME ambas disciplinas deberán integrarse bajo un Sistema de Gestión de Seguridad de la Información, evitando que la ciberseguridad sea una función puramente técnica desconectada del gobierno de la información. Al tratarse de una empresa del ciclo integral del agua, la estrategia deberá incorporar desde el inicio la dimensión ciberfísica: una indisponibilidad, manipulación o degradación de sistemas digitales puede afectar a la continuidad del servicio, a la calidad del agua, a la seguridad operacional, al medioambiente y a la confianza pública.

2. Diagnóstico estratégico de partida

ACME parte de una situación favorable para construir un modelo de madurez alto: la dirección ha asumido la necesidad de reforzar la ciberseguridad, existe presupuesto suficiente, se ha previsto separar el gobierno de la seguridad de su operación técnica y la compañía dispone de aplicaciones y servicios de alta criticidad con impacto directo sobre clientes, procesos internos y continuidad de servicio. Sin embargo, la organización de ciberseguridad está todavía por construir y la empresa ha sufrido incidentes previos que obligan a pasar de un enfoque reactivo a un modelo preventivo, gobernado por riesgo, preparado para detectar y capaz de recuperar.

El entorno tecnológico incluye aplicaciones críticas como MAIN, CRM, ERP, Oficina Virtual, Tienda Online y AQUAPP; servicios en nube; VPN para teletrabajo; directorio activo; servidores de ficheros; equipos portátiles; teléfonos Android; y proveedores externos como CALLMATIC. La existencia de aplicaciones expuestas a Internet, datos de abonados, sistemas de administración, servicios cloud, proveedores críticos y procesos vinculados a operación eleva la necesidad de un modelo documentado, auditable y orientado a resiliencia. Los anexos técnicos precisan las dependencias entre el CPD, las sedes, los servicios corporativos y los entornos de operación, evitando asumir que las tecnologías de operación funcionan de forma aislada o que pueden protegerse con controles puramente IT.

El CPD será el núcleo de criticidad del proyecto, pero no debe tratarse como una isla tecnológica. Su exposición e impacto dependen de identidades, redes, sedes, usuarios, dispositivos, proveedores, aplicaciones y procesos de negocio. Desde la óptica industrial, también deberá evaluarse si el CPD participa en la supervisión, historización, intercambio de datos, gestión remota, coordinación operativa o soporte de servicios que afecten a plantas, estaciones, instalaciones remotas o procesos del ciclo del agua. La estrategia deberá evitar dos errores: diseñar controles de cumplimiento sin capacidad operativa real y desplegar controles técnicos sin gobierno, trazabilidad ni evidencias.

3. Marco rector: ENS y NIST CSF 2.0

La estrategia se articulará sobre un doble eje rector: cumplimiento nacional reforzado y alineamiento internacional. El Esquema Nacional de Seguridad actuará como columna de cumplimiento para la actividad española de ACME, por su vinculación con el sector público y por su condición de entidad que presta servicios esenciales y opera infraestructuras críticas. De forma complementaria, NIST Cybersecurity Framework 2.0 se adoptará como marco internacional de gobierno, madurez y lenguaje común, especialmente relevante por la dimensión multinacional de la compañía y por la distribución aproximada de su base de clientes entre España y el exterior.

Este enfoque evita una estrategia demasiado local, insuficiente para una empresa internacional, y también evita un marco puramente global que trate el cumplimiento nacional como un anexo. El ENS y la normativa española proporcionan obligaciones concretas, categorías, medidas, evidencias y exigencias de auditoría. NIST CSF 2.0 estructura la conversación ejecutiva y permite ordenar capacidades en las funciones Govern, Identify, Protect, Detect, Respond y Recover. Ambas referencias deben convivir desde el diseño del Plan Director de Seguridad.

La función Govern de NIST CSF 2.0 resulta especialmente importante para ACME porque permite formalizar estrategia, roles, políticas, supervisión, gestión de riesgos, cadena de suministro y reporting al Consejo de Dirección. El ENS, por su parte, exige trasladar la seguridad a un modelo verificable, con responsables, medidas, procedimientos, auditorías y mejora continua. La combinación de ambos marcos permitirá que el cumplimiento no sea meramente documental y que la madurez internacional no ignore obligaciones españolas.

Como soporte metodológico se utilizarán ISO/IEC 27001 para el Sistema de Gestión de Seguridad de la Información, ISO/IEC 27005 para gestión de riesgos, NIST SP 800-207 para arquitectura Zero Trust, NIST SP 800-61r3 para respuesta a incidentes, NIST SP 800-82r3 e ISA/IEC 62443 para el tratamiento de entornos industriales u OT, e información de ENISA, CCN-CERT e INCIBE. En el ámbito industrial, NIST SP 800-82r3 permitirá adaptar controles a requisitos específicos de rendimiento, fiabilidad, disponibilidad y seguridad operacional, mientras que ISA/IEC 62443 aportará un lenguaje orientado a sistemas de automatización y control industrial, ciclo de vida, roles, requisitos comunes, defensa en profundidad, zonas y conductos. El objetivo no es acumular marcos, sino usarlos para justificar decisiones, medir madurez, generar evidencias y evitar improvisación.

4. Visión, misión y principios

La visión de ACME Waters debe ser convertirse en una organización resiliente, confiable y verificable, capaz de proteger sus servicios digitales y operacionales, mantener la continuidad del ciclo del agua y preservar la confianza de abonados, administraciones, empleados, proveedores y socios internacionales.

La misión de la estrategia es proteger la información, los sistemas, las identidades, las aplicaciones, los proveedores y los procesos críticos mediante un modelo gobernado por riesgo, cumplimiento normativo, defensa en profundidad, detección continua, respuesta eficaz, recuperación probada y cultura organizativa.

Los principios rectores serán: gobierno desde la dirección; cumplimiento verificable; gestión basada en riesgo; defensa en profundidad; seguridad por capas; mínimo privilegio; reducción de superficie de ataque; seguridad y privacidad desde el diseño; identidad como perímetro operativo; segmentación lógica y funcional; resiliencia TI/OT; responsabilidad compartida de todas las Direcciones Generales; y mejora continua basada en incidentes, auditorías, cambios regulatorios, evolución de amenazas, pruebas de recuperación y resultados de métricas. En los dominios OT, estos principios deberán aplicarse con una prioridad específica: preservar la disponibilidad, la integridad del proceso, la seguridad de las personas, la continuidad operativa, la calidad del servicio y la capacidad de recuperación.

Estos principios obligan a que cada decisión posterior pueda explicarse por su relación con activos críticos, obligaciones normativas, impacto sobre el negocio, reducción de riesgo y capacidad de generar evidencia. No bastará con desplegar herramientas: cada control deberá tener propietario, finalidad, procedimiento asociado, métrica de eficacia y revisión periódica.

Desde la perspectiva preventiva, ACME deberá evitar depender de una única barrera perimetral. La estrategia deberá combinar controles físicos, organizativos y técnicos que limiten la probabilidad de compromiso y contengan su impacto: inventario actualizado, configuraciones seguras, desactivación de servicios innecesarios, parcheo priorizado por riesgo, gestión de vulnerabilidades, control de exposición externa, segmentación, autenticación robusta, cifrado, revisión de privilegios, protección de endpoint y supervisión continua. En entornos OT, estos controles deberán evaluarse antes de implantarse para evitar efectos colaterales sobre la planta: latencia, indisponibilidad, incompatibilidades con fabricantes, pérdida de operación manual, bloqueos de usuarios críticos, interrupciones por parcheo o escaneos activos no autorizados. La seguridad debe reforzar la operación, no ponerla en riesgo.

5. Objetivos estratégicos

La estrategia tendrá una visión a cinco años y una hoja de ruta inicial a tres años, que será desarrollada en el Plan Director de Seguridad. Sus objetivos principales son consolidar el modelo de gobierno, alcanzar un nivel elevado de cumplimiento ENS y normativo, adoptar NIST CSF 2.0 como marco corporativo de madurez, proteger los activos críticos del CPD y extender progresivamente el modelo a sedes, cloud, proveedores y entornos OT/IoT. Esta extensión deberá realizarse mediante un enfoque diferenciado para TI y OT: convergente en gobierno, riesgo y evidencias, pero prudente en la implantación técnica para respetar los requisitos de operación industrial.

El primer objetivo es establecer un gobierno claro de ciberseguridad: autoridad, responsabilidades, comités, escalado, reporting, segregación de funciones, relación entre CISO/CIO/continuidad/legal y participación del Consejo de Dirección. La separación entre gobierno y operación deberá evitar conflictos de intereses: quien define políticas, riesgos y controles no debe ser el único que evalúe su propio cumplimiento operativo.

El segundo objetivo es implantar un Sistema de Gestión de Seguridad de la Información coherente con ISO/IEC 27001 y compatible con ENS. Este sistema deberá incluir política general, políticas específicas, gestión documental, inventario, clasificación de información, propietarios de activos, revisión de accesos, gestión de cambios, auditorías, tratamiento de no conformidades y mejora continua.

El tercer objetivo es formalizar la gestión de riesgos. ACME deberá definir criterios de impacto y probabilidad, propietarios de riesgo, apetito y tolerancia, metodología de evaluación, tratamiento, aceptación de riesgo residual, revisión periódica y comunicación a dirección. El apartado de análisis de riesgos se apoya en estos criterios estratégicos.

El cuarto objetivo es proteger el CPD crítico y los servicios que soporta: MAIN, ERP, CRM, Oficina Virtual, Tienda Online, AQUAPP, directorio activo, bases de datos, servidores de ficheros, conectividad, teletrabajo y administración de sistemas. La estrategia deberá reducir superficie de ataque mediante hardening, segmentación, control de accesos, MFA, PAM, gestión de vulnerabilidades, parcheo, protección de endpoints, seguridad cloud, control de cambios y revisión de terceros. Deberá prestarse especial atención a accesos remotos, cuentas privilegiadas, interconexiones con proveedores, integraciones con sedes o entornos de operación, rutas de administración y dependencia del directorio activo, porque estos elementos pueden convertirse en vectores de propagación entre TI, CPD y dominios operacionales.

El quinto objetivo es construir capacidades de detección, respuesta y recuperación: registro centralizado, monitorización continua, SIEM, casos de uso, inteligencia de amenazas, playbooks, coordinación legal, comunicación de crisis, preservación de evidencias, copias de seguridad protegidas, BIA, RTO, RPO y pruebas periódicas. En el ámbito industrial, estas capacidades deberán contemplar continuidad operacional, recuperación segura de servicios que soporten la operación y coordinación con responsables de planta, operaciones, mantenimiento, ingeniería, calidad y proveedores. El sexto objetivo es integrar cultura de seguridad mediante formación general, formación de administradores, simulaciones de phishing, ejercicios de crisis, canales de notificación y concienciación adaptada a personal corporativo, técnico y operacional.

6. Pilares y líneas de acción

La estrategia se despliega en siete pilares complementarios. El primer pilar es gobierno y cumplimiento: una estructura de dirección de ciberseguridad capaz de definir políticas, supervisar riesgos, coordinar incidentes, exigir evidencias y elevar decisiones al Consejo. El segundo pilar es conocimiento de activos y riesgos: inventarios de activos, servicios, aplicaciones, datos, proveedores, identidades privilegiadas, dependencias cloud, integraciones y flujos críticos.

El tercer pilar es arquitectura segura y preventiva: defensa en profundidad, Zero Trust progresivo, MFA, PAM, hardening, parchado, EDR, cifrado, WAF, protección cloud, segmentación de red, gestión de configuraciones, control de cambios, protección de API y gobierno de exposición externa. Este pilar no debe entenderse como una lista de productos, sino como un patrón de diseño verificable que combine controles preventivos, detectivos y de contención para reducir la probabilidad de intrusión y limitar propagación. En OT, su aplicación deberá adaptarse a ventanas de mantenimiento, criticidad del proceso, dependencia de fabricantes, vida útil de equipos, protocolos industriales, operación manual, seguridad física y requisitos de disponibilidad.

La arquitectura preventiva deberá expresarse por capas: seguridad física y ambiental del CPD; perímetro y conectividad externa; red interna y segmentación; identidad y privilegios; endpoint, servidor y dispositivos móviles; aplicaciones y API; dato y cifrado; cloud y SaaS; proveedores; y dominios de operación cuando exista interconexión TI/OT. Para cada capa deberán definirse objetivos de protección, controles mínimos, responsables, evidencias esperadas y criterios de revisión, manteniendo el nivel de detalle técnico para la fase de arquitectura tecnológica.

El cuarto pilar es protección de datos y confianza digital: privacidad desde el diseño, minimización, clasificación, control de accesos, trazabilidad, cifrado, gestión de brechas, retención proporcional y revisión de encargados de tratamiento en Oficina Virtual, Tienda Online, AQUAPP, CRM, ERP y procesos de facturación o atención al cliente.

En aplicaciones y servicios expuestos, la estrategia deberá incorporar seguridad desde el diseño y durante el ciclo de vida: requisitos de seguridad, revisión de arquitectura, pruebas de seguridad, control de cambios, gestión de secretos, protección frente a abuso de API, registro de eventos relevantes y criterios de aceptación antes de pasar a producción. En cloud, deberá priorizarse la gestión de identidad, la configuración segura, el cifrado, la supervisión de postura, la separación de entornos, el registro de actividad y la responsabilidad compartida con el proveedor. En operación industrial, los accesos remotos de mantenimiento, soporte de fabricantes e interfaces de terceros deberán quedar inventariados, justificados, aprobados, monitorizados, limitados temporalmente y sujetos a trazabilidad.

El quinto pilar es detección y respuesta: monitorización, casos de uso, gestión de alertas, registro centralizado, preservación de evidencias, procedimientos de escalado, coordinación con dirección, legal, comunicación, TI, negocio y proveedores, y lecciones aprendidas. La respuesta a incidentes deberá estar preparada antes de que ocurra el incidente, no improvisarse durante la crisis.

El sexto pilar es continuidad y recuperación: cobertura frente a ransomware, caída de CPD, compromiso de identidad, fallo de proveedor, fuga de datos, indisponibilidad de aplicaciones críticas, degradación de comunicaciones y pérdida de integridad de datos. Para ACME, la continuidad no debe limitarse a recuperar servidores: debe preservar la capacidad de prestar el servicio esencial del agua, mantener procesos seguros, evitar degradaciones que afecten a calidad, vertido, depuración o suministro y priorizar escenarios con impacto físico, ambiental o social. Las copias de seguridad deberán estar protegidas frente a borrado o cifrado malicioso, y las restauraciones deberán probarse de forma periódica. El séptimo pilar es cultura y cambio organizativo, con participación de todas las Direcciones Generales, formación diferenciada por rol y ejercicios que incluyan escenarios corporativos, crisis de CPD y dependencias TI/OT.



Figura 1. Representación visual de los pilares y líneas de acción de la estrategia de ciberseguridad.

7. Marco legal y regulatorio aplicable

ACME deberá contemplar como mínimo el Esquema Nacional de Seguridad regulado por el Real Decreto 311/2022; la Ley 8/2011 de protección de infraestructuras críticas y su desarrollo reglamentario; el Real Decreto-ley 12/2018 y el Real Decreto 43/2021 sobre seguridad de las redes y sistemas de información; la Directiva NIS2 y su transposición al ordenamiento español cuando resulte plenamente aprobada o sustituya el régimen NIS anterior; el Reglamento General de Protección de Datos; la Ley Orgánica 3/2018 de

Protección de Datos Personales y garantía de los derechos digitales; y las obligaciones aplicables a teletrabajo, contratación, auditoría, continuidad, conservación de evidencias, derechos digitales y gestión de proveedores.

La condición de ACME como entidad vinculada al sector público, operadora de servicios esenciales y responsable de infraestructuras críticas exige evitar una interpretación mínima del cumplimiento. El enfoque correcto es de cumplimiento reforzado: identificar obligaciones, asignar responsables, definir controles, producir evidencias, auditar y revisar. Las obligaciones legales deberán integrarse en el SGSI y en el Plan Director de Seguridad, no mantenerse como anexos jurídicos desconectados de la operación.

En protección de datos, la estrategia deberá cubrir bases de legitimación, análisis de riesgos para derechos y libertades, protección desde el diseño, control de encargados, gestión de brechas, registro de actividades, atención de derechos, minimización, conservación limitada y medidas técnicas y organizativas apropiadas. Las aplicaciones de cliente —Oficina Virtual, Tienda Online y AQUAPP— y los sistemas CRM/ERP deberán tratarse como entornos de alta sensibilidad por su relación con abonados, facturación, atención y trazabilidad contractual.

En servicios esenciales e infraestructuras críticas, la estrategia deberá prever coordinación con autoridades competentes, planes exigibles, notificación de incidentes, cooperación con CSIRT/CERT de referencia, continuidad, protección de proveedores críticos y ejercicios de crisis. En entornos internacionales, ACME deberá mantener vigilancia sobre la normativa de los países donde opera, especialmente en sectores de agua, saneamiento, infraestructuras críticas, protección de datos y ciberseguridad de servicios esenciales. El marco normativo deberá mantenerse vivo: cuando evolucionen las obligaciones en España, la Unión Europea o los países de operación, deberán revisarse políticas, contratos, controles, evidencias y planes de continuidad.

Como referencia metodológica, esta estrategia adopta la lógica de estructuración de la Estrategia Nacional de Ciberseguridad y de la Estratègia de Ciberseguretat de la Generalitat de Catalunya 2019-2022, adaptándola a la escala empresarial de ACME mediante principios, pilares y líneas de acción medibles. En la fase de desarrollo legal, el mapa normativo deberá verificarse caso por caso y completarse, cuando proceda, con la Ley 34/2002 de servicios de la sociedad de la información y comercio electrónico para Oficina Virtual, Tienda Online, AQUAPP y comunicaciones electrónicas; el Reglamento eIDAS y la Ley 6/2020 si se emplean servicios de confianza, firma, certificados o contratación electrónica; la Directiva CER y su transposición si ACME queda comprendida como entidad crítica; el Real Decreto 704/2011 en materia de protección de infraestructuras críticas cuando resulte aplicable; y la actualización del régimen NIS/NIS2 conforme avance su transposición española, evitando afirmar obligaciones como aplicables sin confirmar la designación, el ámbito material, la prestación a administraciones públicas o la jurisdicción afectada.

8. Horizonte y medición

El primer año debe centrarse en gobierno, mapa normativo, inventario, análisis de riesgos, políticas, controles urgentes, priorización del CPD crítico y capacidad mínima de detección y respuesta. En paralelo, deberá iniciarse el levantamiento de dependencias TI/OT mediante documentación, entrevistas, inventario y descubrimiento prudente, priorizando técnicas pasivas o no intrusivas cuando afecten a redes o activos operacionales. El segundo año debe consolidar arquitectura, servicios gestionados, seguridad cloud, gestión de vulnerabilidades, continuidad, pruebas y métricas. El tercer año debe elevar madurez, automatización, integración TI/OT, auditorías, ejercicios avanzados y mejora de proveedores. Los años cuarto y quinto se orientarán a optimización, certificación o auditoría avanzada, mejora continua, expansión internacional homogénea y resiliencia corporativa.

El seguimiento estratégico deberá medirse mediante perfiles NIST CSF 2.0 actual y objetivo, nivel de cumplimiento ENS, porcentaje de activos críticos inventariados, riesgos críticos tratados, riesgos residuales aceptados formalmente, cobertura de MFA/PAM, cuentas privilegiadas revisadas, sistemas bastionados conforme a línea base, vulnerabilidades críticas corregidas en plazo, exposición externa no justificada eliminada, segmentación implantada en activos críticos, cobertura EDR, cobertura de monitorización, resultados de restauración, ejercicios de crisis, cumplimiento de proveedores y auditorías superadas. En la dimensión industrial, deberán añadirse indicadores como porcentaje de dependencias TI/OT documentadas, accesos remotos industriales inventariados y revisados, proveedores OT críticos evaluados, activos operacionales críticos identificados, ejercicios de continuidad con participación de Operaciones y excepciones de seguridad formalmente justificadas por impacto en safety o continuidad.

Las métricas deberán diferenciar entre actividad y eficacia. No bastará con contar controles desplegados, usuarios formados o alertas generadas; será necesario medir si los controles reducen riesgo, si las alertas son investigables, si las restauraciones cumplen RTO/RPO, si los proveedores responden en plazo, si los riesgos residuales están aceptados por quien corresponde y si la dirección dispone de información suficiente para decidir.

La estrategia deberá revisarse al menos anualmente y siempre que se produzca un incidente grave, un cambio normativo relevante, una adquisición, una expansión internacional, un cambio de proveedor crítico, una modificación sustancial del CPD o una transformación significativa en TI/OT.

Roadmap tecnológico a 3 años

Secuencia priorizada para implantar capacidades, consolidarlas y optimizarlas sin duplicar el plan global a cinco años.



Figura 2. Horizonte temporal y medición estratégica del Plan Integral de Ciberseguridad.

9. Conclusión

La estrategia de ciberseguridad de ACME Waters debe responder a una realidad dual: operador nacional crítico y empresa internacional. Por ello, se adopta un modelo de doble eje: ENS y normativa española como base obligatoria reforzada, y NIST CSF 2.0 como marco internacional de gobierno, madurez y comunicación. Esta combinación permite blindar el cumplimiento nacional sin perder coherencia global. Además, la condición de operador del ciclo integral del agua exige que la estrategia no se limite a proteger sistemas corporativos: debe preservar la continuidad operacional, la seguridad de los procesos, la calidad del servicio, la protección del medioambiente y la capacidad de recuperación ante incidentes con impacto ciberfísico.

El enfoque propuesto integra seguridad de la información, ciberseguridad, gestión de riesgos, cumplimiento, continuidad, protección de datos, cultura organizativa, arquitectura preventiva y sensibilidad industrial. Los apartados técnicos posteriores del documento convierten esta estrategia en organización, análisis de riesgos, arquitectura tecnológica, servicios, herramientas, procedimientos, presupuestos y respuesta a ciberataques. La ciberseguridad de ACME deberá dejar de ser una reacción ante incidentes y convertirse en una capacidad corporativa de gobierno, protección y resiliencia, capaz de operar de forma coherente en TI, cloud, proveedores y tecnologías de operación.

Anexo II. Organización del área de ciberseguridad

1. Objeto y criterio de diseño

El presente anexo define el modelo organizativo del área de ciberseguridad de ACME Waters, dando continuidad a la estrategia aprobada en la FASE 1. Su finalidad es fijar estructura de gobierno, operación, coordinación, comités, responsabilidades, servicios gestionados y evidencias mínimas para ejecutar la estrategia sin repetirla ni anticipar el diseño técnico de apartados técnicos posteriores del documento.

El diseño se apoya en tres criterios rectores. Primero, separar gobierno y operación para preservar independencia, trazabilidad y capacidad de auditoría. Segundo, construir una organización suficiente, eficiente y realista: ACME dispone de presupuesto suficiente, pero no debe crear una estructura hipertrófica. Tercero, mantener alcance corporativo global con prioridad España y CPD crítico, sin asumir jurisdicciones internacionales concretas porque no se conoce la dispersión territorial del 50 % de clientes fuera de España.

2. Modelo organizativo DC/DIS

Se adopta un modelo dual formado por el Departamento de Ciberseguridad (DC) y el Departamento de Infraestructura de Seguridad (DIS). El DC actúa como función de gobierno, riesgo, cumplimiento, SGSI, supervisión, coordinación de incidentes, gobierno de la detección, autoridad interna de respuesta, gobierno de identidades y accesos, y gobierno de Seguridad OT. El DIS ejecuta la operación técnica de controles, plataformas, telemetría, MFA, IAM/PAM y servicios de seguridad bajo la Dirección de TI/Operaciones. La separación evita que quien opera los controles sea el único responsable de validarlos, aceptar riesgos, priorizar alertas, aprobar privilegios críticos, dirigir la comunicación de crisis o reportar su eficacia al Consejo, especialmente cuando las medidas puedan afectar a disponibilidad, safety o continuidad operacional.

El CISO/RSI dependerá funcionalmente de la Secretaría del Consejo y tendrá acceso periódico al Consejo de Dirección. El CIO mantendrá la responsabilidad operativa sobre infraestructuras TI y coordinación técnica con OT, pero no concentrará el gobierno de ciberseguridad. Las decisiones que afecten a planta, mantenimiento industrial, accesos remotos de fabricantes, ventanas de intervención o continuidad del proceso deberán coordinarse con Operaciones y responsables de planta antes de su ejecución. En sedes internacionales se designarán enlaces ligeros de seguridad cuando el volumen, criticidad o regulación local lo justifiquen, con dependencia funcional del DC y coordinación operativa local.

Jerarquía territorial. La Sede Central de Ceuta actúa como nodo jerárquico de gobierno y decisión para el modelo DC/DIS. Desde ella se coordinan las oficinas corporativas, el CPD crítico y los centros de producción distribuidos en Europa, América del Sur y Asia, con enlaces locales cuando la criticidad, la regulación o el volumen operativo lo requieran.

Ámbito / sede	Dependencia funcional	Función de ciberseguridad	Coordinación operativa
Sede Central de Ceuta	Secretaría del Consejo / CISO-RSI	Gobierno corporativo, apetito de riesgo, SGSI, reporting, aceptación de riesgos y coordinación de crisis.	Consejo, DGs, CIO, DPD, Jurídico, Operaciones y Auditoría.
CPD crítico y servicios centrales TI	DIS bajo CIO; supervisión DC	Operación de plataformas, telemetría, IAM/PAM, hardening, SIEM/SOAR y soporte a SOC/MDR.	DC, SOC/MDR, CSIRT interno y propietarios de sistemas.
Oficinas corporativas en Europa	Enlace local con dependencia funcional del DC	Aplicación de políticas, coordinación de accesos, evidencias, proveedores y escalado de incidentes.	Responsables locales, RRHH, Jurídico/Compras y DIS.
Centros de producción en Europa	Operaciones/planta; gobierno OT desde DC	Inventario OT mínimo, accesos remotos, excepciones, ventanas de mantenimiento y continuidad/safety.	Responsables de planta, mantenimiento, DIS, proveedores industriales y CSIRT si procede.
Oficinas y centros en América del Sur	Enlace regional funcional DC; operación local	Extensión del modelo corporativo, gestión de riesgos locales, protección de datos y coordinación de incidentes.	Dirección regional, Operaciones, Jurídico local, DIS y SOC/MDR.
Oficinas y centros en Asia	Enlace regional funcional DC; operación local	Ejecución homogénea de políticas, evidencias, accesos, proveedores críticos y seguridad OT/TI según criticidad.	Dirección regional, Operaciones, Jurídico local, DIS y SOC/MDR.

Rol / unidad	Dependencia	Misión principal
CSIRT interno	DC / CISO	Coordinar incidentes escalados, severidad, evidencias, comunicación interna, activación de crisis y cierre con lecciones aprendidas.
CISO/RSI	Secretaría del Consejo	Dirigir gobierno, SGSI, riesgo, cumplimiento, reporting ejecutivo, estrategia y coordinación de incidentes relevantes.
DC	CISO/RSI	Gobierno ENS/NIST/ISO, políticas, riesgos, evidencias, cultura, coordinación CSIRT, supervisión de detección, gobierno IAM/PAM y Seguridad OT.
DIS	CIO / DG Operaciones	Operar controles y plataformas TI/OT autorizadas: endpoint, red, hardening, vulnerabilidades, cloud, SIEM/SOAR, MFA, IAM/PAM y soporte al SOC/MDR.
DPD	Independiente; coordinación con Jurídico y CISO	Supervisar protección de datos, privacidad por diseño, brechas de datos personales y criterios de adecuación aplicables.
Jurídico y Compras	DG Jurídico y Cumplimiento / Financiera	Gestionar contratos y proveedores, incorporando cláusulas de seguridad, protección de datos y accesos de terceros validadas por DC/DPD cuando proceda.
Seguridad OT	DC; ejecución coordinada con DIS y Operaciones	Gobernar criterios OT, inventario mínimo, excepciones, mantenimiento remoto, proveedores industriales, continuidad operacional y relación con planta.
Auditoría interna	Consejo / función corporativa independiente	Verificar periódicamente eficacia, evidencias y cumplimiento sin asumir operación ni gobierno diario de ciberseguridad.
SOC/MDR externo	Contrato gestionado; supervisión DC y soporte DIS	Monitorización 24x7, triaje inicial, enriquecimiento de alertas, ticketing, recomendación técnica y escalado al CSIRT interno.
RRHH y responsables de negocio	DG RRHH / áreas propietarias	Activar altas, bajas y cambios de rol; aprobar accesos por necesidad de saber y revisar periódicamente permisos de sus equipos.
Operaciones y responsables de planta	DG Operaciones / direcciones técnicas	Validar impacto operativo de cambios OT, ventanas de mantenimiento, operación manual, continuidad, safety y coordinación con proveedores industriales.

Figura 3. Organigrama funcional del modelo DC/DIS y sus relaciones de coordinación.

3. Departamentos, puestos y responsabilidades

La organización se define por departamentos y puestos, no por una taxonomía extensa de capacidades. Cada función debe tener propietario, misión, evidencias y relación con los comités. La dotación inicial será interna y funcional, reforzada con servicios gestionados selectivos para obtener cobertura, especialización y flexibilidad internacional sin perder control sobre decisiones críticas.

El DC incluirá dirección CISO/RSI, GRC/SGSI, gestión de riesgos y evidencias, coordinación CSIRT, cultura y concienciación, gobierno de Seguridad OT, supervisión de detección y gobierno de identidades y accesos. La función de Seguridad OT no sustituirá a Ingeniería, Operaciones ni mantenimiento de planta; definirá criterios, validará riesgos, coordinará excepciones y asegurará que las medidas de ciberseguridad no degraden safety, disponibilidad, integridad del proceso ni capacidad de recuperación. El gobierno de identidades definirá modelo de roles, mínimo privilegio, segregación de funciones, revisiones periódicas, acceso de terceros y evidencias. El CSIRT interno será una capacidad de coordinación, no un SOC paralelo: recibirá escalados del SOC/MDR, clasificará severidad, coordinará la respuesta con DIS y áreas afectadas, preservará evidencias iniciales, activará crisis cuando proceda y cerrará lecciones aprendidas. El DIS incluirá responsable técnico de infraestructura de seguridad, operación de plataformas, vulnerabilidades y hardening, seguridad cloud, IAM/PAM operativo, telemetría/SIEM/SOAR técnico, relación operativa con SOC/MDR y ejecución técnica OT solo cuando haya validación de Operaciones. Al inicio varias funciones podrán agruparse en perfiles polivalentes siempre que no se mezclen aprobación de riesgo, operación técnica y verificación independiente.

Para hacer trazable la priorización exigida por el enunciado, las capacidades se ordenan por impacto sobre gobierno, reducción de riesgo material, continuidad del servicio y control de accesos críticos.

Orden	Capacidad	Motivo principal
1	Gobierno, riesgo y cumplimiento	Define autoridad, políticas, evidencias, aceptación de riesgo y reporting.
2	Identidad, MFA y PAM	Reduce el riesgo de abuso de credenciales y accesos privilegiados.
3	SOC/MDR y detección	Aporta visibilidad 24x7, triaje y escalado temprano.
4	Gestión de vulnerabilidades y hardening	Disminuye exposición técnica en TI, cloud y activos críticos.
5	CSIRT y gestión de incidentes	Coordina severidad, comunicación, evidencias, contención y lecciones aprendidas.
6	Seguridad OT y continuidad operacional	Protege plantas, procesos ciberfísicos, safety y servicio esencial.
7	Cloud, proveedores y cadena de suministro	Controla dependencias externas, accesos de terceros y servicios expuestos.
8	Cultura, formación y simulacros	Reduce riesgo humano y mejora respuesta de negocio.
9	Auditoría y mejora continua	Verifica eficacia, cumplimiento y madurez del modelo.

Las subcapacidades principales se implantan con propietarios claros para evitar solapamientos entre gobierno, operación técnica, negocio y proveedores.

Capacidad	Subcapacidades principales	Propietario principal
Gobierno/GRC	SGSI, políticas, mapa de riesgos, evidencias, auditorías, cumplimiento ENS/ISO/NIS2 y reporting.	DC / CISO
Identidad y accesos	RBAC, ciclo alta-baja-cambio, MFA, PAM, cuentas de servicio, accesos de terceros y recertificación.	DC gobierno; DIS operación; RRHH/Negocio aprobación
Detección y SOC/MDR	Casos de uso, cobertura de logs, SLA, triaje, ticketing, escalado, MTTD/MTTA y calidad de alertas.	DC supervisión; DIS integración; SOC/MDR ejecución
Vulnerabilidades y hardening	Inventario técnico, escaneo, priorización, parcheo, configuración segura, excepciones y verificación.	DIS; validación de riesgo DC
CSIRT y crisis	Severidad, coordinación, TLP, evidencias iniciales, comunicación, activación de crisis y lecciones aprendidas.	CSIRT interno / CISO
Seguridad OT	Inventario mínimo, zonas, accesos remotos, proveedores industriales, ventanas, excepciones, safety y continuidad.	DC Seguridad OT + Operaciones
Cloud y proveedores	Evaluación contractual, responsabilidades, logs, accesos, cláusulas, revisiones y continuidad de servicios externos.	DC + Jurídico/Compras + DIS
Cultura y auditoría	Formación por perfiles, phishing simulation, simulacros, auditorías internas, indicadores y mejora continua.	DC/GRC con RRHH y Auditoría

Área	Puesto / función	Responsabilidades resumidas
DC	GRC/SGSI y evidencias	Políticas, controles, auditorías, ENS/NIST/ISO, repositorio de evidencias, indicadores y mejora continua.
DC	Riesgo y cumplimiento	Riesgos corporativos de ciberseguridad, criterios de aceptación, seguimiento de planes y coordinación con Jurídico/DPD.
DC	CSIRT interno	Autoridad operativa de incidente, clasificación de severidad, escalado, coordinación DIS/SOC/MDR, comunicación controlada, preservación de evidencias y lecciones aprendidas.
DC	Seguridad OT	Gobierno OT, coordinación con Operaciones/planta, proveedores industriales, mantenimiento remoto, ventanas, excepciones y continuidad/safety.
DC	Cultura y concienciación	Programa por perfiles: Consejo, directivos, empleados, IT, OT, desarrollo, atención al cliente y proveedores relevantes.
DIS	SecOps técnico	Operación de controles técnicos, endpoint, red, cloud, SIEM/SOAR, hardening y soporte al SOC/MDR; ejecución OT solo con validación operativa.
DIS	IAM/MFA/PAM operativo	Altas/bajas técnicas, grupos AD, MFA, bóveda/PAM, cuentas de servicio, caducidad de accesos y trazabilidad.
DC	Supervisión de detección	Requisitos de monitorización, cobertura mínima, prioridad de casos de uso, SLA SOC/MDR, calidad de alertas y evidencias.
DIS	Telemetría y SIEM/SOAR	Integración de fuentes, agentes, colectores, sincronización horaria, normalización, salud de plataformas y ticketing técnico.
DC	Comunicación y crisis	Preparar mensajes internos, coordinar con Jurídico/DPD/Comunicación, aplicar TLP y evitar difusión no autorizada o especulativa.
DC	Gobierno IAM/PAM	Modelo de roles, mínimo privilegio, segregación de funciones, recertificación de accesos, accesos privilegiados y evidencias.
RRHH/Negocio	Ciclo de vida de accesos	Solicitud y aprobación de accesos, cambios de rol, baja de usuarios y revisión de necesidad de saber.
Operaciones/Planta	Coordinación industrial	Validación de impacto en proceso, ventanas de intervención, operación manual, pruebas en planta y relación con mantenimiento/proveedores OT.

4. Comités y modelo de decisión

El modelo combina tres niveles de decisión. El Comité Estratégico fija apetito de riesgo, prioridades, presupuesto y reporting al Consejo. El Comité Operativo controla ejecución, indicadores, accesos críticos, servicios gestionados, vulnerabilidades, evidencias y acciones correctivas, incluyendo riesgos OT relevantes. El Comité de Crisis Ciber se activa ante incidentes severos o situaciones con impacto potencial en continuidad, datos personales, reputación, servicio esencial, operación industrial, safety, medioambiente, proveedores críticos o comunicación pública. Los runbooks detallados se recogen en el bloque de respuesta a ciberataques, pero en esta fase debe quedar clara la autoridad para declarar crisis, coordinar decisiones y controlar la información.

El escalado seguirá una regla conservadora: toda alerta crítica o alta con posible afectación al CPD, datos personales, credenciales privilegiadas, continuidad del servicio, OT, proveedor crítico o exposición pública se elevará al CSIRT interno. En OT se escalarán también anomalías que puedan afectar a disponibilidad de planta, integridad del proceso, mantenimiento remoto, comunicaciones industriales, operación manual, seguridad física, safety o medioambiente. La activación del Comité de Crisis Ciber corresponderá al CISO/RSI o a la Secretaría del Consejo cuando exista impacto real o probable sobre servicio esencial, obligaciones regulatorias, comunicación externa, continuidad operativa o recuperación coordinada.

Órgano	Ritmo	Participantes	Función
Comité Estratégico	Trimestral o extraordinario	Secretaría del Consejo, CISO, CIO, DGs, Jurídico, DPD y Operaciones	Aprobar prioridades, presupuesto, riesgos relevantes, cumplimiento y reporting al Consejo.
Comité Operativo	Mensual	CISO/DC, DIS, CIO, DPD, Jurídico/Compras, Operaciones, responsables técnicos y Seguridad OT	Seguir planes, vulnerabilidades, accesos críticos, servicios gestionados, evidencias, auditorías, acciones correctivas, cobertura de telemetría, escalados CSIRT, SLA SOC/MDR y riesgos OT.
Comité de Crisis Ciber	Ad hoc	Presidencia/Secretaría, CISO, CIO, Jurídico, DPD, Comunicación, RRHH, Operaciones y responsables de planta si aplica	Decidir ante incidentes severos: continuidad, notificaciones, comunicación, contención, recuperación, prioridad de servicios, operación industrial y relación con autoridades/proveedores.

5. Procesos principales y RACI resumida

Los procesos se documentarán de forma ejecutiva-operativa: entrada, responsable, salida, SLA, evidencia y criterio de escalado. El detalle paso a paso se reservará para análisis de riesgos, arquitectura tecnológica y respuesta a ciberataques. La RACI evita ambigüedad entre gobierno, operación, protección de datos, compras, proveedores, detección 24x7, ticketing de seguridad, ciclo de vida de accesos, preservación de evidencias, comunicación controlada y dirección.

Proceso	R	A	C	I
Estrategia, políticas y SGSI	CISO/DC	Secretaría del Consejo	Jurídico, DPD, CIO, Operaciones	Consejo y DGs
Gestión de riesgos y evidencias	DC	CISO	DIS, DPD, Jurídico, áreas de negocio	Comité Operativo
Operación técnica de controles	DIS	CIO	DC, SOC/MDR, proveedores	CISO y Comité Operativo
Vulnerabilidades y hardening	DIS	CIO / CISO según riesgo	DC, Operaciones, planta y proveedores	Comité Operativo
IAM, MFA, PAM y ciclo de vida de accesos	DIS + RRHH/Negocio	CISO/CIO según ámbito	DC, DPD, Jurídico, responsables de sistemas	Auditoría y Comité Operativo
Incidentes y crisis	CSIRT interno	CISO	SOC/MDR, DIS, CIO, DPD, Jurídico, Comunicación, RRHH, Operaciones, planta	Comité de Crisis
Proveedores y contratos	Compras/Jurídico	DG correspondiente	DC, DPD, CIO, Operaciones	Comité Operativo si riesgo alto
Seguridad OT, planta y mantenimiento remoto	DC Seguridad OT	CISO	DIS, CIO, Operaciones, planta, mantenimiento y proveedores industriales	Comité Estratégico/Crisis si afecta continuidad o safety
Supervisión y detección	DC	CISO	DIS, SOC/MDR, CIO, propietarios de sistemas	Comité Operativo
Telemetría, logs y SIEM/SOAR	DIS	CIO	DC, SOC/MDR, propietarios de sistemas	CISO
Alertas y ticketing de seguridad	SOC/MDR + CSIRT interno	CISO	DIS, CIO, DPD/Jurídico si aplica	Comité Operativo / Crisis
Comunicación de incidente	DC/CSIRT	CISO	Jurídico, DPD, Comunicación, RRHH, Operaciones	Comité de Crisis
Preservación de evidencias	CSIRT + DIS	CISO	SOC/MDR, DPD/Jurídico si aplica, DFIR	Auditoría / Comité Operativo
Privilegios, cuentas de servicio y proveedores	DIS	CISO/CIO según riesgo	DC, RRHH, Jurídico/Compras, DPD, negocio, Operaciones y proveedores OT	SOC/MDR, CSIRT y Auditoría
Cambios y excepciones OT	Operaciones + DC Seguridad OT	CISO/CIO según impacto	DIS, planta, proveedores industriales, CSIRT si incidente	Comité Operativo / Crisis si riesgo alto

Tabla 1. Resumen ejecutivo de responsabilidades RACI por capacidad.

6. Servicios gestionados y hoja de implantación

El modelo combina equipo interno funcional con outsourcing selectivo. La externalización no sustituye la responsabilidad de ACME: el DC conserva gobierno, criterios, aceptación de riesgo, priorización de alertas, declaración de incidente, modelo de acceso, reporting y evidencias; el DIS conserva integración técnica, disponibilidad de fuentes de log, salud de plataformas, operación IAM/MFA/PAM y soporte operativo; el SOC/MDR aporta monitorización 24x7, triaje inicial, enriquecimiento, ticketing y escalado; el retainer DFIR aporta apoyo especializado bajo mando del CSIRT interno. Los servicios gestionados se priorizan por reducción de riesgo y capacidad inmediata, no por acumulación de herramientas.

Horizonte	Prioridad	Servicios	Justificación
0-3 meses	Alta	SOC/MDR 24x7; gestión de vulnerabilidades; IAM/MFA/PAM administrado; seguridad OT especializada	Cobertura continua, reducción de exposición, control de privilegios y accesos remotos, criterio OT, inventario mínimo y flujo de escalado desde el arranque.
3-6 meses	Media-alta	SIEM/SOAR gestionado; retainer DFIR; concienciación y phishing simulation	Normalizar telemetría, activar ticketing/orquestación, reforzar revisiones de acceso, contratar apoyo DFIR y desplegar cultura por perfiles, incluido personal OT.
12 meses	Planificada	Threat Intelligence; auditoría ENS/ISO/NIS2	Madurar inteligencia, preparar auditorías formales y consolidar evidencias.

7. Presupuesto orientativo a tres años

El presupuesto se expresa como rango estimado y porcentaje relativo para evitar falsa precisión antes del inventario completo, el análisis de riesgos y la contratación real. La directriz será no escatimar cuando la inversión reduzca riesgo material o mejore resiliencia, pero evitando gasto redundante, licencias solapadas y estructura interna sobredimensionada. Aunque el presupuesto se considera no restrictivo, se prioriza la eficiencia, la madurez alcanzable y la ausencia de solapamientos entre servicios, licencias, funciones internas y proveedores.

Año	Rango anual	Distribución relativa	Objetivo
Año 1	2,0-3,0 M€	Personal/gobierno 30-35 %; servicios gestionados 30-35 %; tecnología 18-22 %; auditoría 5-8 %; formación 3-5 %; contingencia 4-6 %	Construcción DC/DIS, SOC/MDR, vulnerabilidades, IAM/PAM, Seguridad OT y bases GRC.
Año 2	2,4-3,6 M€	Personal 30-34 %; servicios 28-34 %; tecnología 20-25 %; auditoría 5-8 %; formación 4-6 %; contingencia 5-7 %	Consolidación SIEM/SOAR, DFIR, formación por perfiles y madurez operativa.
Año 3	2,8-4,2 M€	Personal 28-32 %; servicios 26-32 %; tecnología 22-28 %; auditoría 6-9 %; formación 4-6 %; contingencia 5-7 %	Optimización, auditorías, inteligencia, mejora continua y extensión internacional selectiva.

Desglose orientativo de servicios para planificación. Los importes deben entenderse como referencia de contratación dentro de los rangos anuales anteriores, sin modificar el presupuesto trienal agregado.

Servicio	Año 1	Año 2	Año 3	Prioridad
SOC/MDR 24x7	450-650 k€	500-750 k€	550-850 k€	Muy alta
SIEM/SOAR gestionado	250-400 k€	350-550 k€	400-650 k€	Alta
Gestión de vulnerabilidades y hardening	220-350 k€	260-420 k€	300-500 k€	Muy alta
IAM/MFA/PAM administrado	300-500 k€	350-600 k€	400-700 k€	Muy alta
Seguridad OT especializada	250-450 k€	350-650 k€	450-800 k€	Muy alta

Servicio	Año 1	Año 2	Año 3	Prioridad
Retainer DFIR	120-220 k€	150-280 k€	180-350 k€	Alta
Threat Intelligence	60-120 k€	100-180 k€	150-250 k€	Media
Auditoría ENS/ISO/NIS2 y GRC	120-240 k€	160-300 k€	220-400 k€	Alta
Formación, simulacros y phishing	80-150 k€	120-220 k€	150-280 k€	Media-alta

8. Indicadores, cultura y evidencias

La medición de la FASE 2 debe comprobar si la organización funciona, si la detección produce decisiones útiles, si la reacción escala correctamente, si los accesos críticos están controlados y si la dimensión OT se gobierna sin afectar a la operación. Los indicadores mínimos serán: funciones cubiertas, asistencia y decisiones de comités, riesgos tratados en plazo, SLA de servicios gestionados, MTTD, MTTA, calidad de alertas, cobertura de telemetría, vulnerabilidades críticas remediadas, cuentas privilegiadas revisadas, bajas ejecutadas, accesos remotos de proveedores, incidentes escalados correctamente, inventario OT mínimo, excepciones OT aprobadas, ventanas de mantenimiento coordinadas, evidencias disponibles y acciones correctivas cerradas. Las métricas deberán alimentar el Comité Operativo y un resumen ejecutivo para el Comité Estratégico.

La cultura de seguridad se organizará por perfiles sin extenderse de forma excesiva: Consejo y directivos, empleados, IT, OT, desarrollo, atención al cliente y proveedores relevantes. La formación general se complementará con cápsulas específicas de riesgo, simulaciones de phishing, sesiones de crisis para dirección, contenidos prácticos para equipos técnicos y módulos OT sobre mantenimiento remoto, cambios, accesos físicos/lógicos, continuidad y actuación ante anomalías. La función GRC/evidencias del DC mantendrá repositorio, responsables, periodicidad de revisión y trazabilidad de decisiones.

Modelo de gobierno, detección, respuesta y coordinación OT

Tres niveles de decisión conectados con SOC/MDR, CSIRT, DIS y Operaciones

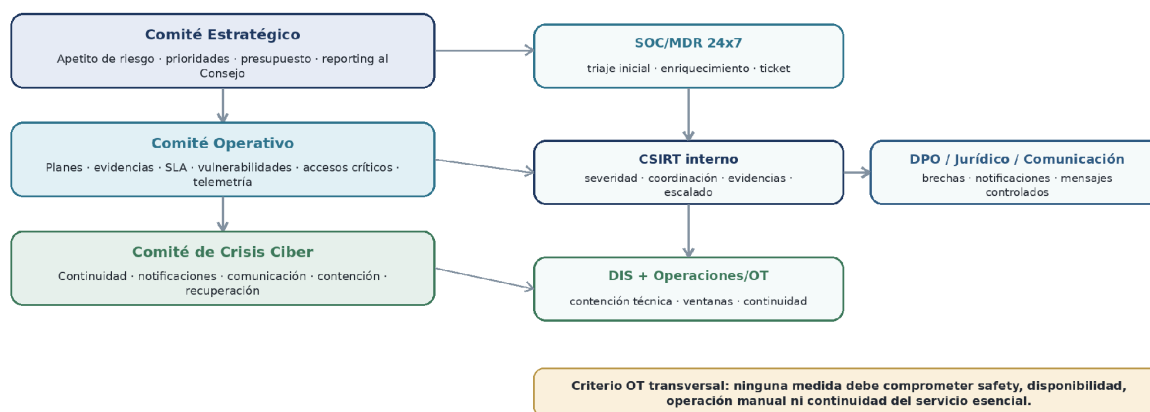


Figura 4. Modelo de gobierno, detección, respuesta y coordinación OT.

9. Entregables y transición a apartados técnicos posteriores del documento

El Anexo II deja definidos los elementos organizativos que sirven de base al resto del documento: organigrama aprobado, catálogo de roles, calendario de comités, RACI, modelo SOC/MDR-CSIRT, modelo IAM/PAM, coordinación OT, plan de servicios gestionados, presupuesto trienal y repositorio inicial de evidencias. El detalle técnico de arquitectura, respuesta, análisis de riesgos, playbooks, diseño industrial por zonas/conductos y mantenimiento seguro se recoge en los anexos correspondientes, sin que esta ordenación documental implique una secuencia de despliegue.

Como control de eficiencia, el Comité Estratégico revisará anualmente si la estructura mantiene proporción con el riesgo real, la dispersión internacional, la criticidad del CPD y la dependencia operativa de plantas e instalaciones. Si el 50 % internacional se concentrara en jurisdicciones concretas, se activará un modelo híbrido con enlaces locales reforzados; hasta disponer de esa información, la estructura federada se mantendrá ligera.

Entregable	Propietario	Uso
Organigrama DC/DIS	CISO/RSI	Aprobación de estructura, dependencias y líneas de coordinación.
RACI y catálogo de roles	DC	Base para auditoría, responsabilidades y control de evidencias.

Entregable	Propietario	Uso
Modelo SOC/MDR y CSIRT	DC + DIS	Base para el bloque de respuesta a ciberataques: escalado, SLA, métricas, evidencias, severidad y relación con Comité de Crisis.
Plan de servicios gestionados	CISO/CIO	Priorización contractual y técnica sin sobredimensionar equipo interno.
Presupuesto trienal	Comité Estratégico	Planificación de inversión y control de eficiencia.
Ficha CSIRT y criterios de escalado	CISO/CSIRT	Base para el bloque de respuesta a ciberataques: autoridad, canales, severidad, TLP y activación de crisis.
Registro de lecciones aprendidas	CSIRT/GRC	Entrada para mejora continua, acciones correctivas, evidencias y reporting ejecutivo.
Modelo IAM/PAM y accesos críticos	DC + DIS + RRHH	Base para el Plan de Acción: reglas técnicas de acceso, recertificación, cuentas privilegiadas, proveedores y evidencias.
Modelo de coordinación OT	DC Seguridad OT + Operaciones	Base para el Plan de Acción: inventario OT, proveedores industriales, mantenimiento remoto, ventanas, excepciones y criterios safety/continuidad.

10. Criterios de aseguramiento organizativo

Para evitar que el modelo quede en una declaración formal, se establecen criterios mínimos de aseguramiento. Cada control organizativo debe producir una evidencia reutilizable en auditorías, revisión de riesgos y reporting ejecutivo. La función GRC/evidencias custodiará el repositorio, pero la generación de evidencias seguirá siendo responsabilidad de cada propietario operativo.

Control organizativo	Propietario	Evidencia mínima	Revisión
Independencia CISO/CIO	Secretaría del Consejo	Actas, reporting y decisiones de riesgo	Trimestral
SGSI y cumplimiento	DC/GRC	Políticas, aplicabilidad y plan de mejora	Semestral
Servicios gestionados	DC + DIS	SLA, tickets, informes, escalados y acciones correctivas	Mensual
Proveedores críticos	Compras/Jurídico	Cláusulas, evaluación de riesgo y evidencias	Por contrato/anual
Protección de datos	DPD	Brechas, DPIA si procede y decisiones coordinadas	Según riesgo
Detección y SOC/MDR	DC + DIS	MTTD/MTTA, logs, escalados y falsos positivos	Mensual
CSIRT, crisis y comunicación	CISO/CSIRT	Tickets, severidad, decisiones, TLP, mensajes y lecciones	Mensual/tras incidente
Identidades y accesos críticos	DC + DIS + RRHH	Matriz, recertificaciones, bajas, privilegios, cuentas de servicio y proveedores	Mensual/trimestral
Seguridad OT y continuidad operacional	DC Seguridad OT + Operaciones	Inventario mínimo, excepciones, accesos remotos, ventanas, proveedores OT y decisiones por safety/continuidad	Mensual/trimestral

Anexo III. Análisis de riesgos

1. Objeto, alcance y entregables

El objetivo de este anexo es identificar vulnerabilidades actuales o inferidas por ausencia de evidencias, priorizarlas, revisar amenazas capaces de explotarlas y traducir el resultado en un plan de auditoría y análisis de riesgos útil para los apartados técnicos posteriores del documento. El foco sigue siendo el CPD crítico de ACME Waters y sus dependencias: identidad, aplicaciones públicas, servicios cloud/correo, proveedores, teletrabajo, endpoints, backups, red corporativa, frontera IT/OT y servicios operacionales vinculados al ciclo integral del agua. La lectura metodológica debe conservar una cadena de trazabilidad: activo y proceso afectado, vulnerabilidad o hipótesis, amenaza aplicable, riesgo, impacto, salvaguardas, evidencia esperada y dependencia de continuidad.

Entregable exigido	Cobertura	Evidencia documental
Ámbito de auditoría	Servicios críticos IT, cloud, teletrabajo, proveedores y frontera IT/OT.	Sección 2.1
Equipo de auditoría	Roles, conocimientos, dedicación y calendario orientativo.	Sección 2.2
Plan de auditoría	Fases, actividades, evidencias y criterios de salida.	Sección 2.3
Amenazas y vulnerabilidades	Catálogo priorizado, estrategias de detección, herramientas web y trazabilidad con identidad, teletrabajo, proveedores, cuentas privilegiadas, calidad de logs y evidencias de auditoría.	Secciones 3 y 6
Metodología de riesgos	Marco jerarquizado: MAGERIT/ENS como base nacional y de dimensiones; ISO/IEC 27005 como proceso; NIST SP 800-30 para escenarios amenaza-vulnerabilidad; OWASP/NIST/ISA como apoyo técnico.	Sección 4 y 4.1
Dimensiones de seguridad	Valoración C/I/D/A/T compatible con MAGERIT/ENS, complementada por privacidad/cumplimiento y OT/safety cuando corresponda.	Sección 7
Riesgo residual L5	Evaluación con dos salvaguardas de eficacia 99% por amenaza prioritaria.	Sección 8
Diseño de red	Nomenclatura, redes, direccionamiento, puertos, zonas de telemetría y esquema de arquitectura.	Secciones 9 a 11
Cloud y normativa	Riesgo alto nivel, controles, ENS, RGPD/LOPDGDD y NIS/NIS2.	Sección 12
Teletrabajo	Modalidades de conexión por perfil, ventanas de conexión, desconexión digital, dispositivos gestionados, MFA, PAM/bastión para TI y control de terceros.	Sección 13
BIA y continuidad	BIA preliminar, distinción MTD/RTO/RPO, hipótesis de recuperación, soluciones IT, evidencias, proveedores y separación PCN/PCTIC/PRD, con validación pendiente.	Secciones 14 y 15

2. Plan de auditoría de servicios críticos

2.1 Ámbito de la auditoría

La auditoría debe concentrarse en los servicios cuya indisponibilidad, compromiso o pérdida de integridad pueda afectar al servicio esencial, a datos personales, a cumplimiento normativo o a la continuidad operacional. El alcance no se limita a servidores: incluye identidad, red, aplicaciones, proveedores y recuperación.

Tabla 2. Ámbito de auditoría de servicios críticos.

Servicio / dominio	Activos incluidos	Motivo de criticidad	Tipo de prueba
CPD crítico y servicios base	Virtualización, almacenamiento, red, AD/DNS/NTP, servicios internos.	Soporta aplicaciones, identidad y operación TI.	Revisión documental, configuración, resiliencia y restauración.
Identidad y acceso	AD, VPN, MFA, cuentas privilegiadas, cuentas de servicio.	Compromiso de identidad amplifica ransomware, fraude y movimiento lateral.	Revisión IAM/PAM, privilegios, trazabilidad y revocación.
Aplicaciones críticas	SAP ERP, CRM, Oficina Virtual, AQUAPP, web pública, APIs.	Impacto en facturación, atención a abonados, trámites y reputación.	Análisis web/API, autenticación, autorización, sesiones y logs.
Cloud/correo	Correo cloud, colaboración, almacenamiento, integraciones y configuración de seguridad.	Canal de phishing, fuga de datos, BEC y dependencia operativa.	CSPM/M365-like review, logs, MFA, DLP, retención y eDiscovery.
Teletrabajo	VPN/ZTNA, portátiles, Android, acceso de TI y usuarios.	Riesgo por acceso remoto, dispositivos fuera de perímetro y horarios no controlados.	Revisión de perfiles, dispositivos gestionados, segmentación y horarios.
Proveedores críticos	CALLMATIC, Servired, front web/cloud, proveedores industriales, soporte remoto y mantenedores autorizados.	Dependencia externa y posible impacto en cadena de suministro.	Revisión contractual, accesos, evidencias, continuidad, registros y ventanas autorizadas; en OT, acceso siempre validado por Operaciones.
Frontera IT/OT	Intercambios IT/OT, DMZ OT, acceso remoto industrial, red de supervisión, historian/intercambio y zonas OT asumidas de forma funcional.	Impacto en disponibilidad, safety, continuidad operacional, calidad del agua y medioambiente.	Revisión documental y de arquitectura, entrevistas con Operaciones, validación de flujos, logs y monitorización pasiva; sin escaneos activos salvo autorización explícita.
Backups y continuidad	Backups, repositorios, bóveda, copias de configuración, restauración y DR.	La recuperación es crítica ante ransomware y fallo de CPD.	Pruebas documentales de restauración, aislamiento, inmutabilidad y propietarios.

2.2 Equipo de proyecto de auditoría

El equipo combina gobierno, técnica, negocio y operación. La dedicación se plantea para una auditoría inicial de 8 a 10 semanas, ajustable según número real de sedes, aplicaciones, servidores y proveedores. Las dedicaciones son orientativas para planificación, no compromisos contractuales.

Tabla 3. Equipo de proyecto de auditoría y dedicación orientativa.

Rol	Perfil y conocimientos	Dedicación orientativa	Responsabilidad
Patrocinio CISO/RSI	Gobierno, ENS, riesgo, priorización y relación con dirección.	10-15%	Aprobar alcance, criterios de aceptación y escalado de hallazgos.
Jefe de auditoría / PMO	Gestión de auditoría, evidencias, entrevistas, control de alcance.	50-70%	Coordinar plan, cronograma, reuniones, riesgos y entregables.
Arquitecto de seguridad	Red, identidad, segmentación, cloud, defensas y continuidad.	40-60%	Diseñar pruebas, revisar arquitectura y proponer controles.
Especialista redes/CPD	Firewall, routing, VLAN, VPN, balanceo, DNS, servidores y backups.	40-60%	Inventariar red, puertos, flujos, dependencias y recuperación.

Rol	Perfil y conocimientos	Dedicación orientativa	Responsabilidad
Especialista IAM/PAM	AD, MFA, cuentas privilegiadas, cuentas de servicio y ciclo de vida.	30-50%	Auditar identidades, privilegios, grupos y acceso remoto.
Especialista aplicaciones/AppSec	Web, API, OWASP, autenticación, sesiones, logs y SDLC.	30-50%	Revisar aplicaciones públicas y proponer pruebas web/API.
Especialista cloud/correo	Seguridad SaaS/IaaS, logs, IAM cloud, DLP, retención, cifrado.	25-40%	Revisar postura cloud/correo y controles regulatorios.
Especialista OT/Operaciones	Entornos industriales, ISA-95/Purdue a alto nivel, safety, disponibilidad, mantenimiento, proveedores OT y continuidad operacional.	25-40%	Validar hipótesis IT/OT, métodos de recogida, ventanas, cambios, pruebas no intrusivas y criterios de parada.
Continuidad/BIA	Procesos críticos, RTO/RPO, MTD, PCN/PCTIC/PRD y pruebas.	30-50%	Conducir talleres BIA y definir continuidad tecnológica.
DPD/Jurídico/Cumplimiento	RGPD/LOPDGDD, ENS, NIS/NIS2, contratos y brechas.	10-25%	Validar implicaciones regulatorias, datos personales y proveedores.
Proveedor externo especializado	Pentest web, escaneo, revisión cloud, auditoría OT pasiva o Red/Purple Team autorizado.	Según alcance	Ejecutar solo pruebas autorizadas y emitir evidencias verificables; en OT, limitarse a revisión pasiva/documental salvo autorización expresa.

2.3 Desarrollo del Plan de Auditoría

El proceso se aborda por oleadas, evitando pruebas intrusivas sobre OT y sistemas críticos sin ventana aprobada. En entornos OT, la recogida de información se basará por defecto en entrevistas, documentación, diagramas, visita controlada, revisión de configuración aportada y monitorización pasiva. Cualquier técnica activa deberá ser excepcional, justificada, aprobada por Operaciones, probada fuera de producción cuando sea posible y acompañada de criterio de parada, reversibilidad y responsable operativo. Cada fase debe producir evidencias trazables y un criterio de cierre, evitando que una ausencia de documentación se confunda con validación positiva.

Tabla 4. Plan de auditoría: etapas, salidas y criterios de cierre.

Fase	Actividad	Salida esperada	Criterio de cierre
0. Preparación	Aprobar alcance, calendario, responsables, ventana de pruebas, canales y reglas de confidencialidad.	Acta de inicio y plan de auditoría.	Alcance firmado por CISO/RSI, CIO y Operaciones si aplica OT.
1. Descubrimiento documental	Recopilar inventario, topología, organigrama, contratos, procedimientos, matrices de acceso, backups y logs.	Mapa de servicios, dependencias y lagunas de evidencia.	Evidencias mínimas recogidas o ausencia documentada.
2. Inventario y nomenclatura	Normalizar activos, redes, aplicaciones, propietarios y criticidad.	Catálogo de activos y plan de nomenclatura.	Activos críticos identificados y asignados a propietario.
3. Detección de vulnerabilidades	Escaneo autenticado IT, revisión cloud, análisis web/API, revisión IAM, OSINT y validación de exposición. En OT: descubrimiento pasivo, entrevistas y revisión de	Registro de vulnerabilidades priorizadas.	Hallazgos clasificados por criticidad, explotación y activo; métodos OT validados por Operaciones.

Fase	Actividad	Salida esperada	Criterio de cierre
	evidencias, evitando escaneo activo de planta.		
4. Análisis de amenazas	Cruzar vulnerabilidades con amenazas: ransomware, credenciales, web, proveedores, cloud, teletrabajo y OT.	Escenarios de riesgo y matriz de prioridad.	Riesgos trazados a activos, vulnerabilidades y controles.
5. BIA y continuidad	Talleres con negocio y Operaciones para estimar impacto temporal, MTD, RTO, RPO, operación local, dependencias y restricciones OT.	BIA preliminar y estrategias de recuperación.	Valores propuestos validados o marcados como preliminares; en OT no son compromisos hasta aprobación de negocio y Operaciones.
6. Evaluación residual	Aplicar salvaguardas L5, estimar riesgo residual y registrar limitaciones.	Tabla 5. Riesgo residual por amenaza.	Riesgo residual justificado y excepciones aprobables.
7. Informe y plan de mejora	Consolidar hallazgos, quick wins, riesgos críticos, roadmap y decisiones de fase siguiente.	Informe de auditoría, anexos, matriz de trazabilidad y registro de hipótesis pendientes.	Revisión por CISO/RSI, DIS/CIO, DPD y Operaciones; aceptación explícita de limitaciones, riesgos residuales e hipótesis no confirmadas.

3. Estrategias de detección de amenazas y herramientas

La detección debe combinar revisión documental, análisis técnico, telemetría y contraste externo. En esta fase no se ejecutan ataques destructivos, explotación intrusiva, obtención de acceso, persistencia ni post-explotación; las pruebas sobre web, API o red se plantean como auditoría autorizada, controlada, limitada por tasa y con ventana aprobada. SIEM, NDR, EDR/XDR y fuentes de inteligencia se utilizan aquí como capacidades de visibilidad, priorización e investigación. La priorización de amenazas y vulnerabilidades se basa en cinco factores: exposición real, criticidad del activo, explotación conocida o facilidad de abuso, impacto sobre servicio esencial/datos personales y existencia de evidencias de control.

Estrategia	Qué detecta	Herramientas o fuentes sugeridas	Cautela
OSINT y superficie expuesta	Dominios, subdominios, metadatos, tecnologías expuestas, filtraciones públicas, certificados, reputación y servicios publicados.	theHarvester, Amass, Shodan/Censys, crt.sh, FOCA, Wappalyzer/WhatWeb, fuentes de inteligencia y repositorios de IOCs.	Solo fuentes públicas y alcance autorizado; registrar fuente, fecha, criterio de búsqueda y evidencia. Sin scraping volumétrico, fuerza bruta ni enumeración agresiva.
Escaneo de vulnerabilidades IT	Servicios obsoletos, CVE, configuraciones débiles, exposición innecesaria, versiones con explotación conocida y desviaciones de hardening.	Nessus/Tenable, OpenVAS/Greenbone, Nuclei con plantillas controladas, Nmap de verificación, revisión de configuración y CMDB.	Escaneo autenticado, limitado y trazable en ventana; sin PoC de explotación ni denegación. Conservar hora, alcance, perfil usado, exclusiones y resultado.
Análisis web/API	OWASP Top 10, autenticación, autorización, sesiones, cabeceras, TLS, validación de entradas, exposición de ficheros, API abuse y calidad de logging de aplicación.	OWASP ZAP, Burp Suite, Nikto, testssl.sh, SecurityHeaders, Wappalyzer/WhatWeb, Nuclei con plantillas no intrusivas, revisión de logs de aplicación.	Pruebas rate-limited; no fuzzing agresivo, explotación innecesaria, payloads peligrosos ni pruebas de carga sobre producción. Evidencias reproducibles sin afectar servicio.
Identidad y privilegios	Cuentas huérfanas, privilegios excesivos, falta de MFA, cuentas de servicio débiles, rutas de escalada, sesiones anómalas y cambios en grupos privilegiados.	Revisión AD, logs de autenticación, MFA/PAM/VPN, BloodHound en modo auditoría autorizado, scripts defensivos y revisión de grupos.	No alterar permisos ni ejecutar técnicas ofensivas fuera de laboratorio/alcance. Priorizar lectura, exportación controlada, timestamp, usuario, origen y trazabilidad.

Estrategia	Qué detecta	Herramientas o fuentes sugeridas	Cautela
Cloud/correo	MFA ausente, permisos excesivos, forwarding sospechoso, reglas maliciosas, consentimientos OAuth, DLP ausente, retención y logs insuficientes.	CSPM nativo, Secure Score/Defender-like, registros de inicio de sesión, auditoría SaaS, logs de correo, alertas de forwarding y revisión de permisos.	Validar residencia de datos, licenciamiento, retención, permisos de auditoría y custodia. No acceder a buzones/contenidos sin autorización y base jurídica.
Endpoint y malware	Ausencia o degradación EDR, ejecución sospechosa, configuración débil, persistencia, precursores de ransomware y abuso de herramientas legítimas.	EDR/XDR, inventario MDM, Sysmon/Windows logs, antimalware, SIEM, telemetría de procesos, integridad y estado de agente.	No manipular malware real fuera de entorno controlado. Validar cobertura, salud del agente, retención de eventos y capacidad de exportar evidencias.
Telemetría red y detección	Tráfico anómalo, conexiones externas, exfiltración, movimiento lateral, C2, saltos entre segmentos, DNS sospechoso y cambios de comportamiento.	NDR, IDS/IPS, NetFlow, Zeek/Suricata, SIEM, DNS logs, firewalls, proxies y, si procede, grabación pasiva de tráfico.	La captura debe ser proporcional y custodiada; con tráfico cifrado se documentan limitaciones. En OT, visibilidad pasiva y validada por Operaciones.
Frontera IT/OT	Accesos remotos, flujos no autorizados, dependencias no documentadas, rutas de intercambio, exposición de servicios industriales y eventos del jump server.	Revisión de firewalls, DMZ OT, jump server, logs VPN/PAM, historian/intercambio, sensores pasivos OT, entrevistas y diagramas.	No usar Nmap/Nessus/fuzzing ni explotación contra OT de producción. Toda técnica activa requiere aprobación de Operaciones, ventana, prueba previa y criterio de parada.
Proveedores	Accesos de terceros, continuidad, evidencias, subcontratación, integraciones, cuentas temporales y calidad de registros aportados.	Cuestionario, revisión contractual, logs de accesos, ticketing, registros de sesión, pruebas de restauración, SLA/OLA y evidencias periódicas.	No asumir controles del proveedor sin evidencia. Exigir trazabilidad mínima: usuario, fecha, origen, destino, acción, aprobación y revocación.

3.1 Categorización y priorización de amenazas

Categoría	Amenaza principal	Activos afectados	Prioridad	Razón
Ransomware y extorsión	Cifrado, robo de datos, interrupción, borrado de copias y presión reputacional.	CPD, backups, endpoints, AD, aplicaciones, cloud.	Crítica	Combina malware, credenciales, vulnerabilidades y backups; puede afectar continuidad, datos, identidad y recuperación.
Compromiso de credenciales	Phishing, robo de sesión, abuso de VPN/ZTNA, privilegios excesivos, BEC y cuentas de servicio.	AD, VPN, cloud/correo, PAM, aplicaciones.	Crítica	Permite movimiento lateral, fraude, borrado de evidencias, acceso a cloud y abuso de proveedores.
Explotación web/API	Inyección, abuso de autorización, sesión, subida de ficheros, exposición de datos y APIs mal protegidas.	Oficina Virtual, AQUAPP, CRM, APIs, web pública.	Alta	Servicios expuestos a Internet con impacto en abonados, datos personales y posible entrada inicial.
Fallo o indisponibilidad CPD	Fallo técnico, error operativo, ataque o pérdida de servicios base.	Servidores, almacenamiento, red, AD/DNS, backups.	Crítica	Afecta aplicaciones y operación corporativa.
Proveedor crítico	Caída, brecha, acceso remoto comprometido,	CALLMATIC, cloud/correo, Servired,	Alta	Dependencia externa con responsabilidad interna no transferible.

Categoría	Amenaza principal	Activos afectados	Prioridad	Razón
	subcontratación no controlada.	web front, proveedores OT.		
Falta de visibilidad	Inventario incompleto, logs insuficientes, telemetría no centralizada.	Todos los dominios.	Alta	Impide detectar, responder, auditar y recuperar con garantías.
Vulnerabilidades críticas	CVE explotables, configuraciones débiles, servicios expuestos y parches pendientes en activos críticos.	Servidores, red, aplicaciones, cloud, endpoints.	Alta	La prioridad depende de explotación conocida, exposición, criticidad del activo y facilidad de abuso.
Riesgo IT/OT	Intervenciones no coordinadas, acceso remoto industrial, flujos no validados, cambios sin ventana o pruebas intrusivas.	Frontera IT/OT, sedes, procesos de agua.	Crítica	Impacto potencial en disponibilidad, safety, medioambiente, calidad del agua y continuidad de servicios esenciales.
Teletrabajo no administrado	Dispositivos no gestionados, horarios no controlados, VPN amplia, falta de segmentación.	Portátiles, Android, VPN, aplicaciones internas.	Alta	Amplía superficie de ataque fuera del perímetro tradicional.
Cloud/correo mal gobernado	Permisos excesivos, fuga de datos, phishing/BEC, reglas de reenvío maliciosas, retención y logs insuficientes.	Correo, colaboración, datos personales, identidades.	Alta	Afecta confidencialidad, cumplimiento, identidad y entrada inicial de ataques.

3.2 Calidad de logs, telemetría y custodia de evidencias

Para que la auditoría sea útil en investigación posterior, no basta con identificar herramientas: cada fuente debe aportar eventos interpretables, con marca temporal fiable, origen, destino, usuario o cuenta técnica, acción, resultado y contexto. La revisión debe comprobar sincronización horaria, normalización, retención, cifrado en tránsito/reposo cuando proceda, control de acceso a los logs, integridad, cadena de custodia y propietario de la fuente. Esta sección define mínimos de evidencia; no constituye un diseño cerrado de SOC.

Fuente de evidencia	Eventos mínimos esperados	Criterios de calidad y custodia	Riesgos vinculados
Identidad / AD / MFA	Inicios de sesión, fallos, cambios de grupos, altas/bajas, bloqueo/desbloqueo, privilegios y cambios en cuentas de servicio.	NTP común, usuario unívoco, origen real, retención suficiente, alertas sobre privilegios y exportación verificable.	R2, R6, R1
VPN/ZTNA/PAM/bastión	Conexión, aprobación, sesión, destino, comandos/actividad administrativa si aplica, caducidad y revocación.	Cuenta nominativa, MFA, registro de sesión, trazabilidad por ticket/ventana y custodia restringida.	R2, R5, R8, R9
Aplicaciones web/API	Autenticación, autorización, errores, cambios críticos, llamadas API sensibles, administración y eventos de seguridad.	Correlación con IP real/XFF cuando exista proxy, identificador de aplicación, sesión, usuario y resultado; sin datos personales innecesarios en logs.	R4, R6, R10
Cloud/correo	Inicio de sesión, MFA, reglas de reenvío, consentimientos, cambios de permisos, DLP, envío anómalo y administración.	Retención y auditoría habilitadas, permisos de lectura controlados, residencia/contrato verificados y evidencias exportables.	R10, R2, R6

Fuente de evidencia	Eventos mínimos esperados	Criterios de calidad y custodia	Riesgos vinculados
Endpoint / EDR-XDR	Ejecución, procesos sospechosos, bloqueo, aislamiento, salud del agente, cambios de configuración y detecciones no bloqueadas.	Cobertura por activo crítico, agente activo, retención mínima, integración SIEM y preservación de eventos de alta criticidad.	R1, R7, R6
Red / DNS / NDR / firewalls	Flujos permitidos/bloqueados, DNS, proxy, cambios de reglas, conexiones externas, saltos entre segmentos y anomalías.	Origen/destino/puerto/protocolo, regla aplicada, NAT/XFF cuando proceda, sincronización horaria y retención adecuada.	R6, R7, R4
DMZ OT / jump / historian	Acceso remoto industrial, sesión, destino, transferencia, flujo IT/OT, cambios aprobados y eventos de monitorización pasiva.	Lectura no intrusiva, validación de Operaciones, sin agentes o sensores que alteren operación, custodia separada de evidencias OT.	R8, R5, R6
Backups / DR	Ejecución de copia, errores, restauración, cambios de política, acceso a repositorios, borrados y uso de credenciales.	Integridad, segregación, retención, prueba de restauración, evidencias de éxito/fallo y propietario del entorno.	R1, R3, R11
Proveedores / ticketing	Solicitud, aprobación, ventana, cuenta, origen, destino, actuación, cierre, revocación y evidencias adjuntas.	Vincular logs técnicos con ticket/contrato/SLA; exigir evidencias verificables y revisión posterior del acceso.	R5, R2, R8

3.3 Alcance de SIEM, NDR, EDR/XDR e inteligencia

Las capacidades de supervisión se valoran en esta fase para determinar si ACME puede observar, registrar y conservar señales suficientes sobre los riesgos identificados. No se definen reglas de correlación detalladas, umbrales de alerta, SLA operativos, automatizaciones SOAR ni playbooks de respuesta en esta fase.

Capacidad	Alcance
SIEM	Confirmar fuentes críticas, normalización, retención, correlación básica de auditoría, dashboards ejecutivos y capacidad de búsqueda para investigación.
EDR/XDR	Comprobar cobertura, salud de agentes, detecciones relevantes, eventos exportables e integración con riesgos de ransomware y endpoint.
NDR / IDS / NetFlow	Validar visibilidad de tráfico, DNS, conexiones externas, saltos entre segmentos y posibles anomalías con enfoque pasivo.
OSINT e inteligencia	Aportar contexto sobre exposición, IOCs, reputación, amenazas sectoriales y explotación conocida para priorizar vulnerabilidades.
Ticketing y evidencias	Relacionar hallazgos, pruebas, logs, decisiones, excepciones, accesos de terceros y acciones de remediación.

4. Metodología seleccionada para el análisis de riesgos

La metodología recomendada es híbrida, pero no acumulativa ni inconexa. MAGERIT/ENS actúa como referencia principal para activos, dimensiones, salvaguardas y coherencia con el contexto nacional; ISO/IEC 27005 ordena el ciclo de gestión de riesgos —contexto, identificación, análisis, evaluación, tratamiento, aceptación, comunicación y revisión—; NIST SP 800-30 refuerza la construcción de escenarios amenaza-vulnerabilidad-probabilidad-impacto; y OWASP, NIST SP 800-82 e ISA/IEC 62443 se usan solo como lentes

técnicas para web/API y OT. La regla de uso es que cada marco debe aportar una función concreta y una evidencia verificable, no una cita decorativa.

Capa metodológica	Uso en ACME Waters	Motivo de elección
MAGERIT / ENS	Dimensiones, activos, salvaguardas, trazabilidad nacional y alineamiento con el alcance subjetivo ENS.	Encaja con entidad vinculada al sector público y servicios esenciales.
ISO/IEC 27005	Proceso de riesgo: contexto, identificación, análisis, evaluación, tratamiento, comunicación y mejora.	Es adecuada para SGSI y continuidad con ISO/IEC 27001.
NIST SP 800-30	Amenazas, vulnerabilidades, precondiciones, probabilidad, impacto y riesgo residual.	Aporta una lógica clara de evaluación de riesgos de sistemas de información.
OWASP WSTG/ASVS	Pruebas web/API, autenticación, autorización, sesiones, validación y logging.	Necesaria para Oficina Virtual, AQUAPP, CRM y APIs.
NIST SP 800-82 / ISA-IEC 62443	Criterio prudente en frontera IT/OT, zonas, conductos, seguridad industrial y monitorización pasiva.	Evita trasladar controles IT a OT sin validar impacto operativo.
CVSS/EPSS/explotación conocida	Priorizar vulnerabilidades por severidad, probabilidad de explotación, exposición y criticidad del activo.	Reduce el riesgo de tratar todas las vulnerabilidades como iguales.

4.1 Criterio de uso de marcos y trazabilidad

Para que el análisis sea defendible, cada marco se emplea con una finalidad concreta y se vincula a evidencias. El resultado debe permitir reconstruir por qué se prioriza un riesgo, qué control lo reduce y quién valida la hipótesis.

Componente	Marco o criterio principal	Uso	Evidencia de cierre
Activos, dimensiones y salvaguardas	MAGERIT / ENS	Clasificar activos, valorar C/I/D/A/T y justificar prioridades en servicios esenciales.	Inventario, propietario, criticidad y dimensión afectada.
Proceso de riesgo	ISO/IEC 27005	Ordenar identificación, análisis, evaluación, tratamiento, aceptación y revisión.	Registro de riesgos con responsable, tratamiento y riesgo residual.
Escenarios amenaza-vulnerabilidad	NIST SP 800-30	Construir escenarios con fuente de amenaza, vulnerabilidad, probabilidad e impacto.	Escenario documentado y trazado a V1-V12 y R1-R11.
Aplicaciones web/API	OWASP WSTG/ASVS/Top 10	Definir pruebas autorizadas, no destructivas y controles de aplicación.	Resultado de pruebas, alcance, limitaciones y remediación priorizada.
OT e IACS	NIST SP 800-82 / ISA-IEC 62443	Mantener hipótesis industriales prudentes, zonas/conductos funcionales y auditoría no intrusiva.	Validación de Operaciones, flujos permitidos y restricciones de prueba.
Continuidad y recuperación	BIA / PCN / PCTIC / PRD	Relacionar impacto temporal, dependencias, MTD/RTO/RPO orientativos y soluciones técnicas.	Taller BIA, pruebas de restauración y aprobación de negocio.
Normativa	ENS, RGPD/LOPDGDD, NIS/NIS2	Identificar obligaciones probables y cautelas de cumplimiento sin emitir asesoramiento legal cerrado.	Revisión por DPD/Jurídico y contraste con fuentes oficiales vigentes.

5. Inventario de activos y plan de nomenclatura

La fase requiere identificar activos con una nomenclatura común, no necesariamente completar una CMDB definitiva. La nomenclatura propuesta permite clasificar activos por dominio, ubicación, tipo, criticidad y secuencia, facilitando auditoría, BIA, riesgo y operación.

Regla de nomenclatura. ACME-[DOMINIO]-[UBICACIÓN]-[TIPO]-[ENTORNO]-[NNN]. Ejemplo: ACME-IT-CEU-SRV-PROD-001. Los dominios mínimos son IT, OT, CLD, NET, APP, IAM, BCK, PRV y MOB.

Tabla 6. Plan de nomenclatura de activos.

Código	Dominio	Ejemplo	Uso
IT	Sistemas corporativos	ACME-IT-CEU-SRV-PROD-001	Servidores, virtualización y servicios base.
NET	Red y comunicaciones	ACME-NET-CEU-FW-PROD-001	Firewalls, switches, routers, balanceadores, VPN.
IAM	Identidad y acceso	ACME-IAM-CEU-AD-PROD-001	AD, MFA, PAM, cuentas privilegiadas y servicios de directorio.
APP	Aplicaciones	ACME-APP-CEU-CRM-PROD-001	SAP, CRM, Oficina Virtual, AQUAPP, web, APIs.
CLD	Cloud/SaaS	ACME-CLD-EU-MAIL-PROD-001	Correo, colaboración, almacenamiento cloud, tenants.
BCK	Backup y recuperación	ACME-BCK-CEU-REP-PROD-001	Repositorios, bóvedas, copias, DR y pruebas.
MOB	Movilidad	ACME-MOB-ES-AND-PROD-001	Portátiles, Android, MDM y teletrabajo.
PRV	Proveedor	ACME-PRV-CALLMATIC-SVC-PROD-001	Servicios críticos y accesos de terceros.
OT	Operaciones industriales	ACME-OT-PLT01-HMI-PROD-001	HMI, historian, estaciones ingeniería, red de planta, comunicaciones OT.

Familia de activos	Activos principales	Propietario sugerido	Criticidad
CPD y servicios base	Virtualización, almacenamiento, red, AD/DNS/NTP, monitorización.	DIS/CIO + Infraestructura	Crítica
Identidad	AD, MFA, VPN, PAM, cuentas de servicio, grupos.	DIS/IAM + DC	Crítica
Aplicaciones públicas	Oficina Virtual, AQUAPP, APIs, web, CRM externo.	Aplicaciones + Seguridad	Alta/Crítica
Aplicaciones internas	SAP ERP, CRM interno, MAIN, repositorios.	Aplicaciones + Negocio	Alta
Cloud/correo	Correo, colaboración, almacenamiento, logs, DLP.	DIS/Cloud + DPD	Alta
Proveedores	CALLMATIC, Servired, front web/Amazon, proveedores industriales.	Compras + Jurídico + DIS	Alta/Crítica

Familia de activos	Activos principales	Propietario sugerido	Criticidad
Endpoint y movilidad	Portátiles, Android, puestos administrativos, equipos TI.	DIS/Endpoint	Alta
Backups/DR	Bóveda, copias, repositorios, pruebas, configuraciones críticas.	Infraestructura + Continuidad	Crítica
Frontera IT/OT	Jump servers, firewalls, logs, accesos remotos, sensores pasivos.	DIS + Operaciones	Crítica
OT alto nivel	Supervisión, control local, comunicaciones de planta, historian y estaciones de ingeniería.	Operaciones	Crítica

6. Vulnerabilidades actuales o inferidas y priorización

Al no existir inventario completo ni topología verificada, las vulnerabilidades se clasifican como confirmadas si proceden del enunciado y como hipótesis pendientes de confirmación si se deducen de ausencia de evidencias. La auditoría deberá confirmar, descartar o graduar cada una mediante evidencias reproducibles; una hipótesis no debe tratarse como hallazgo cerrado hasta disponer de prueba documental, configuración revisada, registro técnico o validación del propietario del activo.

ID	Vulnerabilidad / debilidad	Estado	Riesgo asociado	Prioridad
V1	Inventario, CMDB y dependencias incompletas.	Hipótesis pendiente de confirmación	R6, R3, R5	Crítica
V2	Teletrabajo sin administración adecuada, perfiles, ventanas de conexión, dispositivos gestionados y derecho de desconexión no gobernados.	Indicada por enunciado; pendiente de graduar	R2, R9	Alta
V3	Exposición de aplicaciones públicas y APIs sin evidencia de pruebas periódicas, control de autorización y revisión de cabeceras/TLS.	Hipótesis pendiente de confirmación	R4	Alta
V4	AD/VPN/MFA adquirido pero no necesariamente extendido ni integrado con PAM, bastión, cuentas privilegiadas y cuentas de servicio.	Hipótesis pendiente de confirmación	R2, R1, R6	Crítica
V5	Backups/restauración sin evidencia de pruebas completas ni protección frente a ransomware.	Hipótesis pendiente de confirmación	R1, R3	Crítica
V6	Logs, telemetría, sincronización horaria, retención, normalización, correlación y custodia de evidencias no centralizados o no demostrados.	Hipótesis pendiente de confirmación	R6, R1, R2, R4, R8, R10	Alta

ID	Vulnerabilidad / debilidad	Estado	Riesgo asociado	Prioridad
V7	Gestión de vulnerabilidades, explotación conocida y parcheo no demostrados como proceso continuo.	Hipótesis pendiente de confirmación	R7	Alta
V8	Dependencias de proveedores críticos sin evidencias uniformes de continuidad, cuentas nominativas, caducidad, revocación y trazabilidad de accesos.	Hipótesis pendiente de confirmación	R5, R2	Alta
V9	Frontera IT/OT y mantenimiento remoto industrial no documentados en detalle.	Hipótesis pendiente de confirmación	R8	Crítica
V10	Gobierno cloud/correo insuficientemente demostrado: permisos, MFA condicional, DLP, retención, logs, forwarding y cifrado.	Hipótesis pendiente de confirmación	R10	Alta
V11	Puertos, servicios y flujos internos no inventariados por aplicación, origen, destino y condición de uso.	Hipótesis pendiente de confirmación	R6, R7, R4	Alta
V12	Ausencia de BIA aprobado y de RTO/RPO validados por negocio.	Indicada por enunciado; pendiente de graduar	R3, R1, R5	Crítica

7. Valoración de dimensiones de seguridad para activos principales

La valoración utiliza una escala Bajo/Medio/Alto/Crítico. Se consideran confidencialidad, integridad, disponibilidad, autenticidad/trazabilidad y privacidad/cumplimiento, manteniendo compatibilidad con el enfoque MAGERIT/ENS. La dimensión OT/safety no sustituye a las dimensiones de seguridad de la información, sino que complementa la valoración cuando el activo puede afectar disponibilidad operacional, seguridad de personas, calidad del agua o medioambiente. Esta tabla no sustituye una valoración MAGERIT completa; justifica prioridades hasta disponer de inventario, propietarios y evidencias definitivas.

Activo / servicio	C	I	D	A/T	Privacidad / cumplimiento / OT	Justificación resumida
AD/IAM/VPN/MFA	Alto	Crítico	Crítico	Crítico	ENS/RGPD	Controla acceso a sistemas; su compromiso permite escalada, persistencia y pérdida de trazabilidad.
CPD y servicios base	Alto	Crítico	Crítico	Alto	ENS / servicio esencial	Soporta aplicaciones, red, identidad y recuperación; indisponibilidad

Activo / servicio	C	I	D	A/T	Privacidad / cumplimiento / OT	Justificación resumida
						impacta operación global.
SAP ERP	Alto	Crítico	Alto	Alto	Financiero/cumplimiento	Afecta facturación, compras, contabilidad y continuidad administrativa.
CRM / CALLMATIC	Alto	Alto	Crítico	Alto	Datos personales	Canal de atención a abonados; impacto reputacional y de protección de datos.
Oficina Virtual / AQUAPP / APIs	Crítico	Alto	Alto	Alto	Datos personales / exposición pública	Servicios expuestos a Internet con datos de clientes y potencial puerta de entrada.
Cloud/correo	Crítico	Alto	Alto	Alto	RGPD/LOPDGDD	Canal de comunicación, phishing, BEC, datos y evidencias.
Backups y DR	Alto	Crítico	Crítico	Alto	Continuidad	Última línea de defensa ante ransomware y fallo de CPD; integridad y restauración son críticas.
Endpoints/Android	Medio	Alto	Alto	Medio	Datos y acceso remoto	Puerta de entrada habitual; mayor exposición por movilidad y teletrabajo.
Frontera IT/OT	Medio	Crítico	Crítico	Crítico	OT/safety/medio ambiente	Cualquier intervención, flujo indebido o acceso remoto no validado puede afectar proceso, disponibilidad, seguridad física o medioambiente.
OT alto nivel	Medio	Crítico	Crítico	Alto	Safety/medioambiente	Prioridad en disponibilidad, integridad del proceso, seguridad de personas, calidad

Activo / servicio	C	I	D	A/T	Privacidad / cumplimiento / OT	Justificación resumida
						del agua y continuidad; confidencialidad es secundaria frente a operación segura.
Proveedores críticos	Alto	Alto	Alto	Alto	Contratos/continuidad	Riesgo de cadena de suministro y accesos externos con responsabilidad interna.

8. Impacto y riesgo residual con dos salvaguardas L5

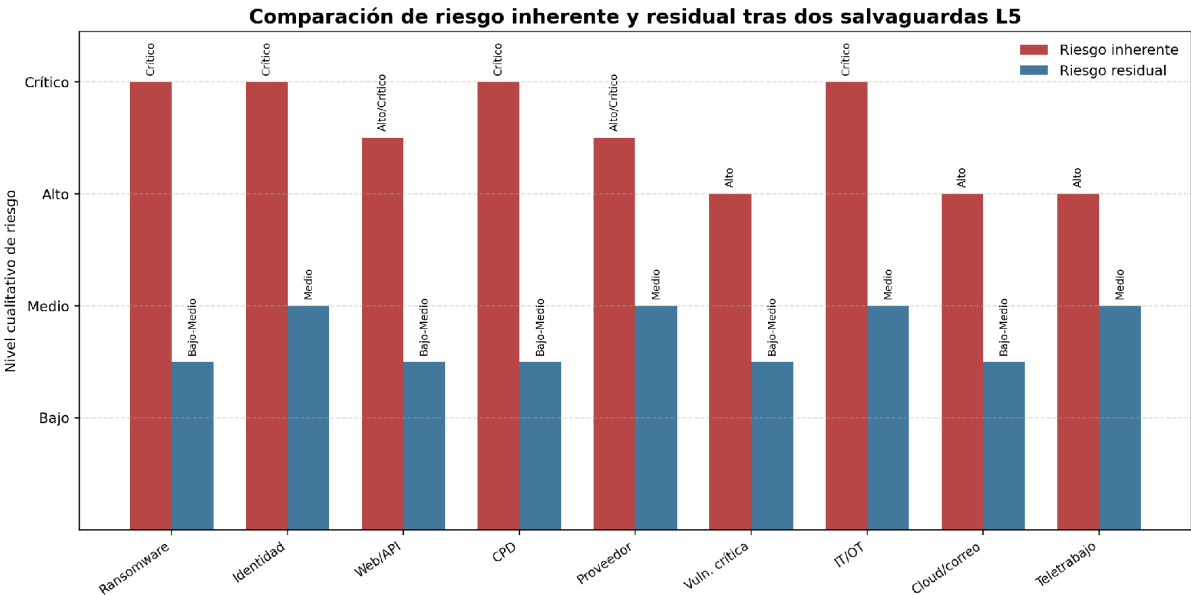
Para cumplir el supuesto académico, se asume que cada amenaza prioritaria dispone de dos salvaguardas independientes de eficacia L5=99%. La lectura debe ser prudente: este supuesto sirve para demostrar el mecanismo de reducción de probabilidad, no para afirmar que la organización ha alcanzado tal eficacia ni que el riesgo desaparece. En la práctica, una eficacia del 99% solo sería defendible si la salvaguarda está implantada, probada, monitorizada, mantenida, auditada y cubre realmente el vector de ataque. Si las salvaguardas no son independientes, no cubren el vector real o no existen evidencias, el riesgo residual deberá elevarse.

Criterio de cálculo cualitativo. Con dos salvaguardas L5 independientes, la probabilidad residual teórica se reduce de forma drástica. Sin embargo, el impacto potencial no desaparece; por ello, en servicios esenciales el riesgo residual se expresa como Bajo, Medio o Bajo-Medio, nunca como cero. La aceptación del residual requiere propietario, evidencias y revisión periódica.

Tabla 7. Riesgo residual estimado con dos salvaguardas L5.

Amenaza	Impacto sin salvaguardas	Salvaguarda L5 1	Salvaguarda L5 2	Riesgo residual estimado	Observación
Ransomware CPD	Crítico	EDR/XDR + hardening + bloqueo ejecución no autorizada	Backups inmutables/aislados, restauración probada y credenciales de backup segregadas	Bajo-Medio	Impacto sigue alto si backup, AD o cuentas de servicio quedan comprometidos; L5 exige evidencias de prueba.
Compromiso de identidad	Crítico	MFA resistente, PAM, bastión y cuentas privilegiadas nominativas	Ciclo de vida de identidades, revisión de privilegios, control de cuentas de servicio, alertas y revocación rápida	Medio	El riesgo persiste por phishing, robo de sesión, abuso de cuentas de servicio, excepciones operativas y errores de revocación.
Explotación web/API	Alto/Crítico	WAF/API security, TLS robusto y exposición mínima	Pruebas OWASP controladas, SDLC seguro, corrección priorizada y logging de aplicación	Bajo-Medio	Depende de frecuencia de pruebas, cobertura de autorización y exposición real; no requiere explotación destructiva.
Indisponibilidad CPD	Crítico	Alta disponibilidad/replicación de servicios base	Backups/DR probados por entorno	Bajo-Medio	No se elimina dependencia física, eléctrica, red y proveedores.
Incidente proveedor	Alto/Crítico	Cláusulas de seguridad, continuidad, notificación y	Landing zone, segmentación, MFA, registro de sesión, caducidad, revisión	Medio	La responsabilidad no se transfiere por contrato; requiere evidencias, pruebas y derecho de auditoría.

Amenaza	Impacto sin salvaguardas	Salvaguarda L5 1	Salvaguarda L5 2	Riesgo residual estimado	Observación
		cuentas nominativas temporales	posterior y revocación		
Vulnerabilidad crítica	Alto	Gestión continua de vulnerabilidades priorizada por exposición, explotación conocida y criticidad	Mitigación temporal, hardening, parcheo probado y verificación posterior	Bajo-Medio	El residual sube si no hay inventario, ventana de mantenimiento o confirmación de remediación.
Frontera IT/OT	Crítico	DMZ OT, jump server, MFA, cuentas nominales y registro de sesión	Validación de Operaciones, segmentación, monitorización pasiva y prohibición de acciones intrusivas sin autorización	Medio	El impacto OT exige prudencia incluso con controles fuertes; la eficacia L5 no justifica contención automática ni escaneos activos.
Cloud/correo	Alto	MFA, acceso condicional, permisos mínimos, DLP y cifrado	Logs, retención, alertas y revisión de forwarding/reglas OAuth/consentimientos	Bajo-Medio	Depende de configuración real, licenciamiento, contrato y capacidad de auditoría del proveedor cloud.
Teletrabajo	Alto	Dispositivo gestionado, MDM/EDR, cifrado y postura mínima	VPN/ZTNA por aplicación, MFA, segmentación, ventanas por perfil, logging y revocación	Medio	El residual persiste por entorno doméstico, phishing, pérdida de equipo, sesiones activas y excepciones de guardia.



Nota: riesgo residual no equivale a riesgo cero; requiere evidencia, prueba, mantenimiento y validación continuada.

Figura 5. Comparación de riesgo inherente y residual tras dos salvaguardas L5.

9. Diseño lógico de infraestructura de red de ACME

El diseño se formula a alto nivel porque no se dispone de topología real. Se asume una sede central en Ceuta con CPD crítico, oficinas nacionales e internacionales, servicios cloud/correo, frontales públicos y relación IT/OT con instalaciones distribuidas. El objetivo preventivo no es configurar firewalls en detalle, sino fijar dominios de confianza, rutas mínimas de comunicación y controles que reduzcan exposición, abuso de credenciales y movimiento lateral. La regla de diseño es denegar por defecto, publicar solo a través de

capas intermedias, impedir accesos directos de usuarios a servidores o bases de datos y canalizar la administración mediante bastiones/PAM.

Suposición OT de trabajo. Se presupone una organización OT distribuida por instalaciones tipo captación, tratamiento, desalación, distribución, depuración/reutilización y centros de operación. No se inventan PLC, SCADA, DCS, fabricantes, protocolos concretos ni topologías de planta; se modelan zonas funcionales: supervisión, control local, ingeniería/mantenimiento, historian/intercambio y acceso remoto industrial. La frontera IT/OT se trata como límite de seguridad y continuidad: cualquier flujo desde IT hacia OT deberá pasar por DMZ OT, bastión/jump server industrial, aprobación de Operaciones y registro de sesión. Por defecto, la auditoría OT será documental, entrevistada y pasiva; las pruebas activas solo se admitirán con autorización explícita, ventana aprobada, criterio de parada y reversibilidad.

Zona lógica	Función	Controles de seguridad	Flujos permitidos
Internet / usuarios externos	Acceso a web, Oficina Virtual, AQUAPP y APIs públicas.	CDN/WAF, protección DDoS, TLS, filtrado, logging y publicación mínima.	Solo hacia CDN/WAF o DMZ pública por 443; 80 únicamente redirección. Sin acceso directo a backend ni BBDD.
DMZ pública	Frontales web, reverse proxy, balanceo y API gateway.	Firewall, WAF, hardening, EDR, logs, separación de secretos y revisión de exposición.	Hacia zona de aplicaciones por 443 u otros puertos estándar justificados. Nunca hacia BBDD salvo excepción documentada.
Zona aplicaciones CPD	SAP, CRM, backend web y servicios corporativos.	Segmentación este-oeste, EDR, hardening, control de cambios y cuentas de servicio limitadas.	A BBDD por puerto estándar, a identidad por Kerberos/LDAPS/DNS/NTP, a SIEM y backup. Sin acceso de usuario directo.
Zona bases de datos	BBDD de aplicaciones críticas y repositorios de datos.	Microsegmentación, cifrado, auditoría, backup, cuentas técnicas y bloqueo de administración directa.	Solo desde servidores de aplicación o bastión/PAM autorizado. Sin tráfico desde DMZ pública, usuarios o VPN general.
Zona identidad	AD, DNS, MFA/PAM y servicios de autenticación.	PAM, MFA, administración separada, logs reforzados, control de cuentas privilegiadas y DNS interno.	Kerberos/LDAPS/DNS/NTP internos. Sin exposición directa a Internet ni administración desde red de usuarios.
Zona administración	Bastiones, PAM, herramientas de gestión y jump servers.	MFA, grabación de sesión, cuentas nominales, horario, aprobación y separación de privilegios.	Administración hacia servidores autorizados. Entrada solo desde perfiles TI o seguridad validados; nunca desde usuario general.
Zona seguridad	SIEM, EDR/XDR, NDR, colectores, repositorio de logs, fuentes de inteligencia y evidencias de auditoría.	Acceso restringido, retención, integridad, segregación, sincronización horaria, normalización, custodia de evidencias y control de cambios.	Recepción de logs/telemetría desde zonas críticas; acceso de analistas autorizado. Escaneos solo con ventana y alcance; sin reglas SIEM ni playbooks detallados en esta fase.
Zona backup/DR	Repositorios, bóveda, copias, restauración y configuraciones críticas.	Red separada, credenciales distintas, inmutabilidad cuando sea viable, cifrado y pruebas de restauración.	Conexiones programadas desde agentes o servidores autorizados. Restauración bajo control; sin acceso de usuarios.
VPN/ZTNA teletrabajo	Acceso remoto de empleados, TI y perfiles autorizados.	MFA, postura de dispositivo, EDR/MDM, segmentación por aplicación, horarios y logs.	Acceso solo a aplicaciones o zonas asignadas por perfil. No debe equivaler a conectividad plana a la red interna.
Zona proveedores	Acceso temporal de terceros, soporte y mantenedores autorizados.	Landing zone, cuentas nominales, MFA, aprobación, registro, caducidad, revisión	Solo a activo/proceso autorizado durante ventana aprobada.

Zona lógica	Función	Controles de seguridad	Flujos permitidos
		posterior y, si es proveedor OT, validación de Operaciones.	Prohibido movimiento lateral o acceso a redes generales.
DMZ OT / frontera IT-OT	Intercambio controlado entre IT y OT; zona de amortiguación para reporting, historian espejo y mantenimiento industrial.	Firewall industrial, jump server, proxy/historian, registro de sesión, monitorización pasiva, control de cambios y aprobación OT.	Flujos explícitos y mínimos: historian/reporting, mantenimiento validado y logs. Sin tránsito IT → OT directo ni conexiones de proveedor a planta sin bastión.
Zonas OT de planta	Supervisión, control local, ingeniería, historian local y operación industrial, modelados sin fabricantes ni topología de detalle.	Segmentación por instalación, acceso local controlado, gestión de cambios, copias de configuración y monitorización no intrusiva.	Tráfico industrial interno; salida controlada a DMZ OT. No exponer protocolos industriales a IT general o Internet. Sin contención automática desde IT.

9.1 Criterios preventivos del diseño lógico

Decisión preventiva	Riesgos reducidos	Criterio aplicado
Separar DMZ, aplicaciones y BBDD	R1, R4, R7	Evita que una explotación web alcance directamente datos o servidores críticos.
Administración solo mediante bastión/PAM	R2, R6, R7	Reduce abuso de credenciales, sesiones no trazadas y administración desde redes de usuario.
VPN/ZTNA por aplicación y perfil	R2, R9	El teletrabajo no debe crear conectividad plana; cada perfil accede solo a lo necesario.
Backup/DR segregado de usuarios y servidores productivos	R1, R3, R11	Limita impacto de ransomware y permite restauración controlada con evidencias.
Separar IT/OT mediante frontera validada	R8, R5, R6	DMZ OT, jump server industrial, flujos mínimos, monitorización pasiva y aprobación de Operaciones antes de cualquier cambio o prueba activa.
Zona de seguridad con logs y telemetría centralizada	R6, R7	Permite trazabilidad, detección temprana y auditoría sin mezclar operación de seguridad con redes generales.

9.2 Criterios industriales para frontera IT/OT y auditoría OT

El diseño IT/OT se mantiene deliberadamente funcional y prudente. Su objetivo es identificar riesgos y dependencias, no detallar una planta real. Las medidas industriales deben preservar disponibilidad, integridad del proceso, seguridad de las personas, calidad del agua, continuidad operacional y medioambiente.

Aspecto	Criterio industrial	Límite / condición
Hipótesis OT	Describir instalaciones y zonas funcionales a alto nivel: supervisión, control local, ingeniería, historian/intercambio y acceso remoto industrial.	No inventar PLC, SCADA, DCS, marcas, protocolos concretos ni topologías de planta no aportadas.
Recogida de información	Priorizar entrevistas, documentación, diagramas, visita controlada, revisión de configuración aportada y sensores pasivos.	Escaneos activos, fuzzing o explotación quedan excluidos salvo autorización explícita de Operaciones y prueba previa.
Frontera IT/OT	Separar dominios mediante firewall industrial, DMZ OT, jump server, registro de sesión, flujos mínimos y trazabilidad.	No debe existir tránsito IT → OT directo ni acceso de proveedor a planta sin bastión y ventana aprobada.

Aspecto	Criterio industrial	Límite / condición
Acceso remoto industrial	Usar cuentas nominales, MFA, aprobación previa, destino único, caducidad, registro y revisión posterior.	Toda intervención debe tener responsable de Operaciones, criterio de parada y capacidad de reversión.
Monitorización	Usar visibilidad pasiva o telemetría existente para detectar flujos anómalos sin interferir en el proceso.	No desplegar sensores, taps, agentes o cambios de red que puedan afectar latencia, disponibilidad o determinismo sin validación.
BIA OT	Tratar MTD/RTO/RPO como hipótesis preliminares para talleres con negocio y Operaciones.	No presentar los valores como compromisos cerrados hasta completar BIA formal, pruebas y validación operacional.

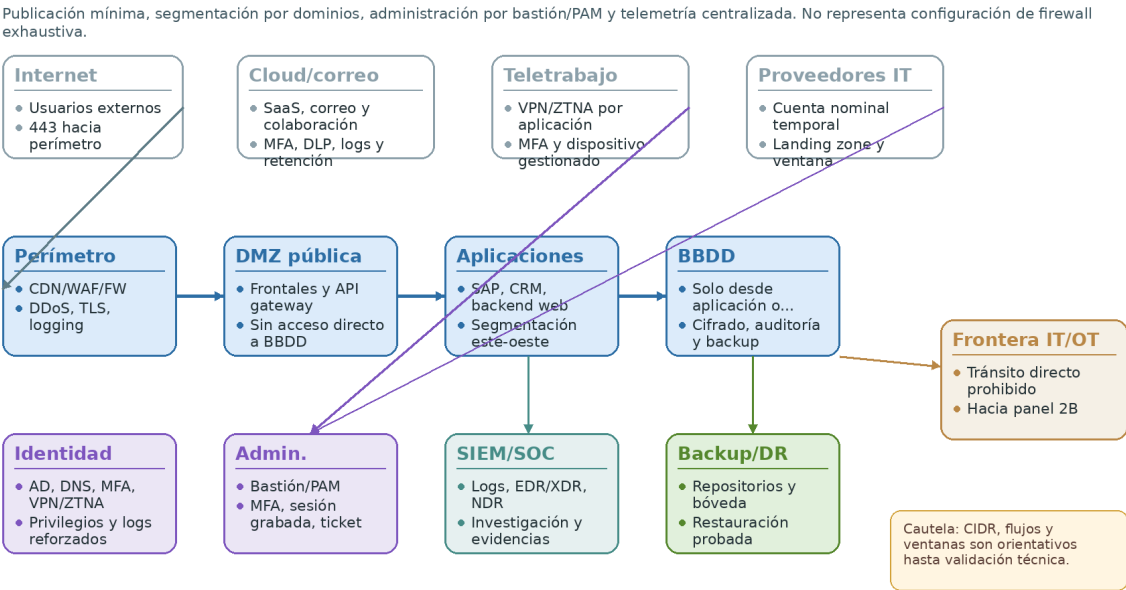


Figura 6. Arquitectura lógica IT/CPD: publicación, segmentación, administración y telemetría.

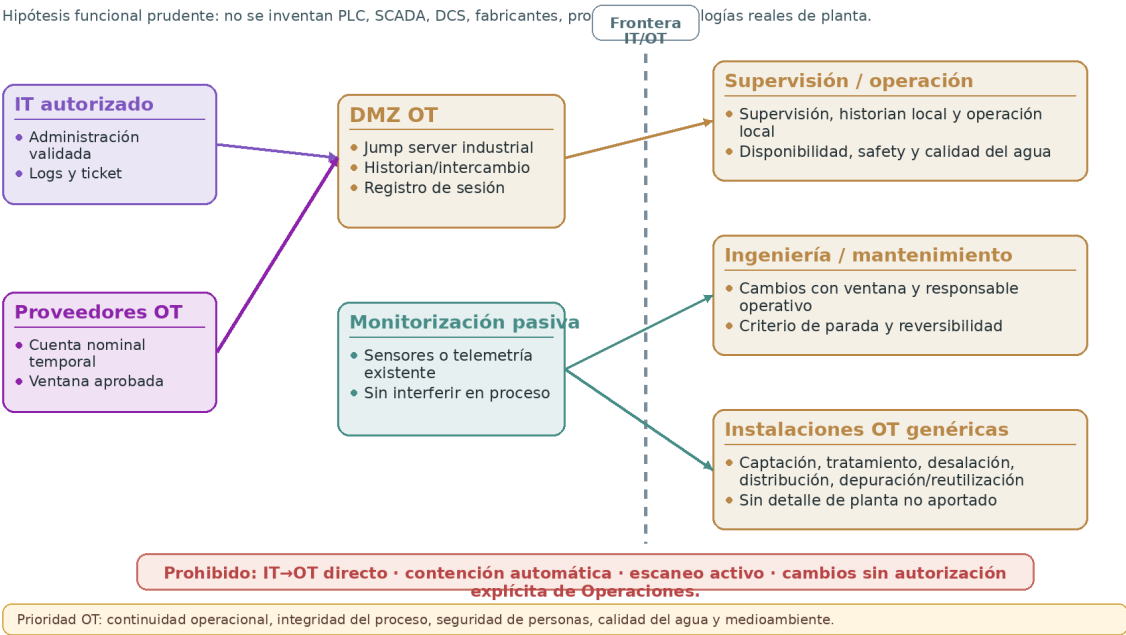


Figura 7. Frontera IT/OT: DMZ OT, jump server industrial, monitorización pasiva e instalaciones OT genéricas.

10. Redes necesarias, direccionamiento y máscaras

Se propone un direccionamiento RFC1918 jerárquico, orientativo y no implantable sin validación. La prioridad es separar dominios,

facilitar reglas de firewall, inventario y trazabilidad. Se reserva 10.10.0.0/16 para CPD y sede central, 10.20.0.0/16 para cloud conectado, 10.30.0.0/16 para frontera OT/OT genérica y 10.40.0.0/16 para sedes. Las máscaras propuestas son bloques de trabajo: deberán ajustarse al número real de activos, alta disponibilidad, crecimiento, sedes y posibles solapes con proveedores o cloud.

Tabla 8. Redes necesarias, direccionamiento y máscaras orientativas.

Red / VLAN	CIDR	Uso	Controles mínimos
Usuarios corporativos HQ	10.10.10.0/24	Puestos internos corporativos.	NAC, EDR, salida filtrada; sin acceso directo a servidores/BBDD.
Servidores aplicación	10.10.20.0/24	Backends, SAP, CRM, servicios internos.	Firewall interno, EDR, hardening y acceso solo desde DMZ/app publishing o bastión.
Bases de datos	10.10.30.0/24	BBDD críticas.	Acceso solo desde aplicaciones; cifrado, auditoría y administración vía bastión/PAM.
Administración/PAM	10.10.40.0/24	Bastiones, PAM, administración privilegiada.	MFA, grabación, salto obligatorio y cuentas nominales.
Seguridad/SOC	10.10.50.0/24	SIEM, NDR, repositorios de logs, escáneres.	Acceso restringido, integridad, retención y escaneos autorizados.
Backups/DR	10.10.60.0/24	Repositorios, bóveda, backup networks.	Inmutabilidad, segregación, cuentas protegidas y pruebas de restauración.
Gestión/OOB	10.10.70.0/24	Gestión de equipos de red/servidores.	Solo administración desde bastiones; sin navegación ni usuario final.
DMZ pública	10.10.80.0/24	Frontales, reverse proxy, API gateway.	WAF, firewall, EDR, publicación controlada; sin acceso a BBDD.
VPN/ZTNA empleados	10.10.90.0/24	Pool lógico de acceso remoto.	MFA, postura, segmentación por aplicación/perfil; no acceso plano a LAN.
Proveedores terceros	10.10.100.0/24	Landing zone de accesos temporales.	Aprobación, cuentas nominales, caducidad, logs y destino único.
Cloud servicios	10.20.10.0/24	Servicios cloud integrados y conectividad privada.	IAM cloud, NSG/firewall, cifrado, logs y segmentación por workload.
Cloud seguridad/logs	10.20.20.0/24	Conectores SIEM, almacenamiento logs, DLP.	Retención, cifrado, acceso restringido y separación de cuentas.
DMZ OT	10.30.10.0/24	Frontera IT/OT, historian/intercambio, jump OT y registro de sesiones.	Firewall industrial, sensor pasivo, aprobación OT, registros y sin tránsito IT → OT directo.
OT planta 01	10.30.101.0/24	Instalación OT genérica 1, sin detallar controladores ni topología.	Segmentación local, monitorización pasiva, cambios validados y sin rutas directas a IT.
OT planta 02	10.30.102.0/24	Instalación OT genérica 2, sin detallar controladores ni topología.	Segmentación local, monitorización pasiva, cambios

Red / VLAN	CIDR	Uso	Controles mínimos
			validados y sin rutas directas a IT.
OT ingeniería/mantenimiento	10.30.200.0/24	Estaciones ingeniería y mantenimiento.	Acceso controlado, ventanas, registro, validación Operaciones y sin herramientas intrusivas salvo autorización.
Oficinas nacionales	10.40.10.0/24 - 10.40.99.0/24	Sedes/oficinas España.	SD-WAN/VPN, firewall local, EDR y acceso mínimo a servicios centrales.
Oficinas internacionales	10.40.100.0/24 - 10.40.199.0/24	Europa, América del Sur, Asia.	Segmentación regional, acceso mínimo, logs y control de salida.

11. Puertos estándar y flujos mínimos

Todos los puertos deberán justificarse por aplicación, origen, destino, propietario y criticidad. La regla base es denegar por defecto y permitir solo flujos documentados. La tabla no sustituye una matriz firewall; define flujos estándar mínimos para el análisis de riesgos. Todo acceso administrativo debe originarse en bastión/PAM, todo acceso a BBDD debe venir de la capa de aplicación y todo protocolo industrial debe permanecer en OT o DMZ OT salvo excepción aprobada.

Tabla 9. Puertos estándar y flujos mínimos autorizables.

Servicio	Puerto estándar	Origen permitido	Destino	Condición
HTTP	80/TCP	Internet	CDN/WAF/DMZ pública	Solo redirección a HTTPS; no backend ni autenticación.
HTTPS / API	443/TCP	Internet, usuarios, aplicaciones autorizadas	WAF/DMZ/API gateway o aplicación publicada	TLS fuerte, logging, WAF y control de sesión.
DNS	53/TCP-UDP	Clientes y servidores internos	DNS internos / resolutores autorizados	No resolución directa desde usuarios a Internet; logs cuando aplique.
NTP	123/UDP	Activos internos	NTP corporativo	Fuente horaria común para logs y evidencias.
Kerberos	88/TCP-UDP	Clientes y servidores IT	AD	Solo red interna y autenticación corporativa; sin exposición externa.
LDAPS	636/TCP	Aplicaciones autorizadas	AD/LDAP	Preferible a LDAP simple; cifrado obligatorio.
SMB	445/TCP	Servidores y usuarios autorizados	File servers / servicios concretos	Bloqueado entre segmentos no necesarios; nunca Internet ni DMZ pública.
RDP	3389/TCP	Bastión/PAM	Servidores autorizados	Nunca desde VPN general ni proveedores directos; MFA, grabación, aprobación y destino autorizado.
SSH	22/TCP	Bastión/PAM	Linux/red autorizados	Claves/certificados, salto administrado, registro y destino autorizado; no acceso directo a OT.

Servicio	Puerto estándar	Origen permitido	Destino	Condición
Bases de datos	1433/3306/5432/TCP	Servidores aplicación	BBDD	Solo origen aplicación o bastión autorizado; sin usuario directo.
SMTP envío	25/587/TCP	Servidores/correo	Relay/correo cloud	SPF/DKIM/DMARC, antimalware y control de relays.
IMAPS	993/TCP	Clientes gestionados autorizados	Correo	Preferir acceso gestionado, MFA y políticas condicionales.
VPN IPsec	500/4500/UDP	Usuarios/dispositivos autorizados	Concentrador VPN	MFA, postura, segmentación y registro.
OpenVPN si aplica	1194/UDP	Clientes autorizados	VPN legacy	Solo si existe; plan de racionalización hacia acceso por perfil.
Syslog TLS	6514/TCP	Sistemas y sensores	SIEM/log collector	Preferible frente a 514 sin cifrar; integridad y retención.
SNMPv3	161/162/UDP	Monitorización autorizada	Equipos red/servidores	Solo SNMPv3; comunidades por defecto eliminadas.
OPC UA si aplica	4840/TCP	OT interno / DMZ OT si aplica	Historian/supervisión	Solo si existe y está documentado. Uso restringido a OT/DMZ OT, validado por Operaciones; no usar para escaneo activo ni desde IT general.
Modbus TCP si aplica	502/TCP	OT interno / DMZ OT si aplica	Dispositivos OT	Solo si existe y está documentado. Uso restringido a OT/DMZ OT, validado por Operaciones; no usar para escaneo activo ni desde IT general.
EtherNet/IP si aplica	44818/TCP-UDP	OT interno / DMZ OT si aplica	Control industrial	Solo si existe y está documentado. Uso restringido a OT/DMZ OT, validado por Operaciones; no usar para escaneo activo ni desde IT general.
S7comm si aplica	102/TCP	OT interno / DMZ OT si aplica	Control industrial	Solo si existe y está documentado. Uso restringido a OT/DMZ OT, validado por Operaciones; no usar para escaneo activo ni desde IT general.

12. Seguridad cloud: riesgos, controles y regulación

Regulación a considerar: ENS por el vínculo subjetivo de ACME con el sector público; RGPD y LOPDGDD para datos personales; y NIS/NIS2 como referencia europea para sectores esenciales, gestión de riesgos, incidentes, continuidad y cadena de suministro, según resulte aplicable y conforme al estado normativo vigente. Esta fase no emite asesoramiento legal cerrado ni determina por sí sola la calificación jurídica de ACME; identifica obligaciones probables y controles de diligencia que deberán validarse con DPD, Jurídico y

fuentes oficiales antes de cerrar el plan.

Riesgo cloud	Punto clave a proteger	Controles recomendados	Justificación
Compromiso de cuenta	Identidad, sesiones, MFA, OAuth, forwarding.	MFA, Conditional Access/ZTNA, bloqueo legacy auth, revisión de reglas, alertas.	Reduce phishing, BEC y persistencia.
Fuga de datos	Correo, documentos, almacenamiento y colaboración.	DLP, clasificación, cifrado, enlaces controlados, etiquetado, revisión de compartidos.	Protege datos personales y documentación crítica.
Configuración débil	Permisos, tenants, almacenamiento, integraciones.	CSPM/CASB, baseline, revisión periódica, mínimo privilegio, alertas.	Evita exposición accidental y privilegios excesivos.
Pérdida de evidencias	Logs, auditoría, retención, eDiscovery.	Retención mínima, SIEM, exportación, integridad, sincronización horaria.	Permite investigación, cumplimiento y trazabilidad.
Dependencia proveedor	Continuidad de correo/cloud y salida ordenada.	SLA, plan de contingencia, exportación, backups SaaS si aplica, pruebas.	Reduce impacto ante caída, bloqueo o cambio contractual.
Residencia/transferencia	Ubicación de datos y encargados/subencargados.	DPA, evaluación de transferencias, cifrado, revisión contractual.	Alineación RGPD/LOPDGDD y obligaciones sectoriales.

Cautela normativa. El estado concreto de transposición y aplicación nacional de NIS2 debe verificarse en BOE, autoridades competentes, INCIBE/CCN-CERT y asesoramiento jurídico. En este informe se usa NIS2 como referencia europea de gestión de riesgos, notificación, continuidad y cadena de suministro. ENS, RGPD y LOPDGDD se citan como marcos aplicables o potencialmente aplicables al contexto, pero la determinación jurídica definitiva queda fuera del alcance de este documento.

13. Proyecto de mejora del teletrabajo y acceso remoto

El teletrabajo se trata como proyecto de reducción de riesgo, no solo como despliegue de VPN. Debe combinar identidad, dispositivo gestionado, horario, segmentación, registro, derecho a la desconexión digital y perfiles diferenciados. El departamento de TI podrá tener disponibilidad ampliada, pero únicamente bajo esquema de guardias autorizadas, PAM, bastión, MFA, registro de sesión y justificación. Para el resto de perfiles, el acceso debe limitarse a ventanas funcionales compatibles con jornada, descansos, bajas y desconexión digital.

Tabla 10. Modalidades de teletrabajo y acceso remoto por perfil.

Perfil	Modalidad de conexión	Rango / disponibilidad	Controles mínimos
TI administración	PAM + bastión + VPN/ZTNA administrada, con cuentas nominativas y separación de funciones.	Disponibilidad ampliada solo mediante guardias autorizadas, emergencia documentada o ventana aprobada.	MFA fuerte, dispositivo gestionado, EDR/MDM, grabación de sesión, aprobación, ticket, alertas y revisión posterior.
Usuarios corporativos	VPN/ZTNA a aplicaciones concretas, sin acceso plano a red interna ni a servidores.	Horario laboral y ventanas aprobadas; bloqueo o alerta fuera de jornada salvo autorización expresa; respeto de descanso, bajas y desconexión digital.	MFA, EDR/MDM, cifrado de disco, acceso por rol, postura de dispositivo, expiración de sesión y logging.
Dirección	Acceso seguro a correo, colaboración, cuadros ejecutivos y aplicaciones autorizadas.	Horario flexible por necesidad directiva, pero sin privilegios administrativos por defecto ni bypass de controles.	MFA resistente, protección de correo, DLP, dispositivo corporativo, revisión de sesiones y alerta ante ubicaciones anómalas.
Atención/CRM	Acceso a CRM/CALLMATIC o entorno virtualizado/publicado, evitando descarga masiva local.	Turnos aprobados; sin acceso fuera de turno salvo contingencia autorizada por responsable.	VDI o app publish, MFA, logs, DLP, bloqueo de copia local

Perfil	Modalidad de conexión	Rango / disponibilidad	Controles mínimos
			cuando aplique y control de exportaciones.
Personal de campo	Acceso móvil a apps operativas, partes de trabajo y datos mínimos necesarios.	Según cuadrante, guardias y necesidad operativa; respeto de descansos y bajas salvo emergencia formal.	MDM Android, cifrado, MFA adaptado, borrado remoto, geolocalización solo si está justificada y legalmente validada.
Proveedores IT	Landing zone de terceros + cuenta nominativa temporal + acceso por aplicación o activo concreto.	Ventana autorizada por ticket, con caducidad automática y aprobación del propietario del servicio.	MFA, registro de sesión, acceso mínimo, prohibición de cuentas compartidas, revisión posterior y revocación automática.
Proveedores OT	Jump server industrial en DMZ OT, nunca conexión directa a planta desde Internet o red corporativa.	Solo ventana aprobada por Operaciones, con responsable operativo disponible y criterio de parada.	Validación OT, supervisión, grabación, reversibilidad, cuenta nominativa temporal y prohibición de cambios no autorizados.

La posible reubicación en la nube debe enfocarse a servicios de acceso seguro: identidad centralizada, ZTNA/SASE, VDI o publicación de aplicaciones críticas, MDM/UEM, DLP y logs centralizados. No se recomienda exponer aplicaciones internas directamente ni implantar una VPN plana. Cada conexión debe resolverse por aplicación, perfil, dispositivo y contexto, con trazabilidad y revocación efectiva.

13.1 Criterios mínimos de acceso remoto, privilegios y terceros

Los controles de acceso se formulan como salvaguardas para reducir probabilidad e impacto, no como soluciones absolutas. El acceso remoto debe verificarse por identidad, dispositivo, contexto, perfil y destino. Las cuentas privilegiadas, de servicio y de terceros requieren controles reforzados porque concentran riesgo de movimiento lateral, persistencia, interrupción y pérdida de trazabilidad.

Elemento	Criterio de control	Riesgos reducidos	Evidencia esperada
Identidad y MFA	MFA obligatorio para acceso remoto, cloud/correo, administración y aplicaciones críticas; excepciones documentadas, temporales y aprobadas.	R2, R9, R10	Política MFA, cobertura por perfiles, logs de autenticación y revisión de excepciones.
VPN/ZTNA	Acceso por aplicación, rol y contexto; prohibido usar VPN como túnel plano a redes internas o servidores.	R2, R6, R9	Matriz perfil-aplicación, reglas de acceso, logs y pruebas de denegación de rutas no autorizadas.
Cuentas privilegiadas	Administración solo mediante PAM/bastión, cuentas nominativas, MFA, grabación de sesión, aprobación y caducidad.	R1, R2, R6, R7	Inventario de administradores, sesiones grabadas, tickets, revisiones periódicas y revocaciones.
Cuentas de servicio	Inventario, propietario, mínimo privilegio, rotación controlada, secretos protegidos y prohibición de uso interactivo salvo excepción aprobada.	R1, R2, R6, R7	Catálogo de cuentas, permisos, propietario, fecha de revisión, bóveda de secretos y alertas de uso anómalo.
Dispositivo gestionado	Teletrabajo solo desde equipos corporativos o móviles gestionados, cifrados y con EDR/MDM activo; BYOD restringido a casos aprobados.	R1, R2, R9, R10	Estado MDM/EDR, cifrado, versión, cumplimiento de postura y capacidad de borrado remoto.
Proveedores y terceros	Cuentas nominativas, temporales, auditables y revocables; acceso a destino único durante ventana aprobada; sin cuentas compartidas.	R2, R5, R8, R9	Ticket de acceso, contrato/orden, logs, grabación cuando aplique, caducidad y revisión posterior.
Derecho de desconexión	Ventanas de conexión por perfil; fuera de jornada solo emergencia,	R2, R9	Reglas horarias, integración con RR. HH., registro de excepciones y

Elemento	Criterio de control	Riesgos reducidos	Evidencia esperada
	guardia o autorización registrada; bajas y descansos deben bloquear o suspender accesos ordinarios.		revisión de accesos fuera de ventana.

El acceso remoto se concede por perfil, aplicación y ventana autorizada. Los controles reducen riesgo; no eliminan phishing, pérdida de equipo ni errores de revocación.

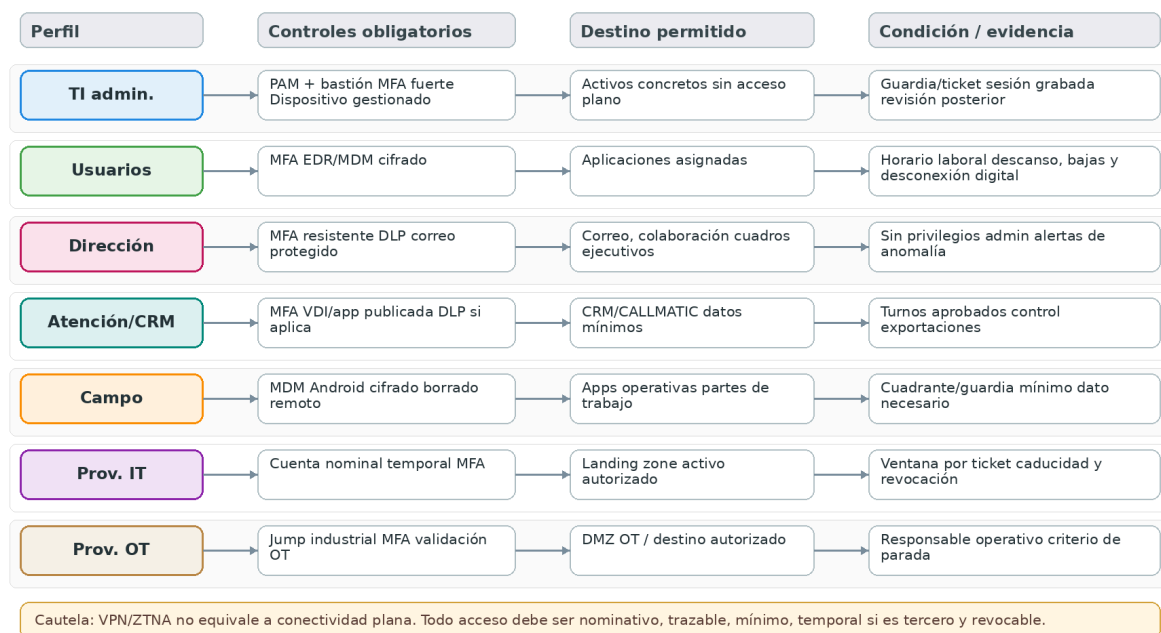


Figura 8. Modelo de teletrabajo seguro por perfiles y condiciones de acceso.

14. BIA preliminar: análisis de impacto sobre el negocio

El BIA identifica procesos críticos, aplicaciones soporte, impacto temporal, dependencias, MTD, RTO, RPO, alternativas manuales y soluciones tecnológicas. Los valores siguientes son una propuesta preliminar para facilitar talleres con negocio, Operaciones, TI, DPD y proveedores. No son objetivos aprobados ni compromisos de servicio: solo podrán consolidarse cuando se validen impactos, costes, dependencias, restricciones OT, evidencias de backup/replicación y resultados de pruebas de recuperación.

Criterio de uso del BIA. MTD define el tiempo máximo tolerable de interrupción desde negocio/operación; RTO define el objetivo técnico de recuperación y debe ser menor o igual que el MTD; RPO define la pérdida máxima de datos aceptable. En esta fase son hipótesis de trabajo para priorizar controles y soluciones. La aprobación exige validación del propietario del proceso, viabilidad técnica, pruebas documentadas y revisión de dependencias con proveedores, quedando fuera del alcance de este documento en la fecha de su redacción.

Campo BIA	Descripción	Evidencia necesaria
Proceso	Actividad de negocio o servicio esencial afectado.	Mapa de procesos y responsable.
Aplicación / activo soporte	Sistema, servicio o proveedor que soporta el proceso.	Inventario y propietario técnico.
Impacto temporal	Efecto acumulado a 1h, 4h, 8h, 24h, 48h, 72h y >1 semana, separando impacto operativo, económico, regulatorio, reputacional, privacidad y OT/safety.	Taller con negocio/Operaciones y registro de impacto por proceso.
MTD	Tiempo máximo tolerable de interrupción antes de daño inaceptable para negocio, servicio esencial, cumplimiento, seguridad o medioambiente.	Aprobación del propietario del proceso y, si aplica, de Operaciones.
RTO	Tiempo objetivo para recuperar el proceso o servicio hasta un nivel mínimo aceptable.	Validación TI/Operaciones mediante diseño y prueba.

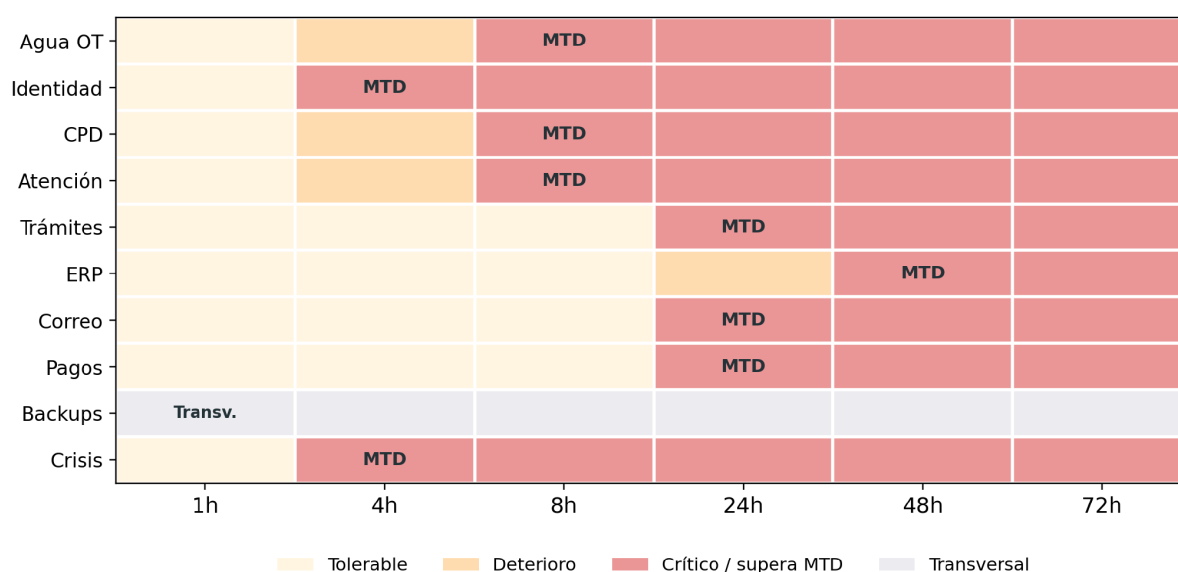
Campo BIA	Descripción	Evidencia necesaria
	Debe ser viable técnicamente y menor o igual que el MTD.	
RPO	Pérdida máxima de datos aceptable medida como antigüedad de la última copia, réplica o punto de recuperación usable.	Validación de backup, replicación, retención y restauración.
Dependencias	Personas, proveedores, datos, identidad, red, OT, cloud, energía, comunicaciones, sedes y canales alternativos.	Matriz de dependencias con propietario y contacto de emergencia.
Alternativa manual	Procedimiento temporal si la aplicación no está disponible.	Procedimiento probado o pendiente.
Solución tecnológica	HA, replicación, backup inmutable, DR, backup SaaS, canales alternativos, recuperación limpia, operación local, etc.	Diseño técnico, prueba de recuperación y evidencia de resultado.
Nivel mínimo de servicio	Capacidad mínima aceptable durante contingencia: servicio completo, degradado, manual, local o diferido.	Aprobación del propietario del proceso y procedimiento alternativo probado o documentado.
Criterio de aprobación	Condición para pasar de hipótesis de trabajo a objetivo aprobado de continuidad.	Acta de taller, prueba técnica, evidencia de restauración, responsable y aceptación de riesgo residual.

Tabla 11. BIA preliminar de procesos críticos, MTD, RTO y RPO.

Proceso / servicio	Aplicación o soporte	Impacto si cae	MTD orientativo	RTO propuesto	RPO propuesto	Solución IT idónea
Continuidad operacional del agua	Supervisión OT, historian/intercambio, comunicaciones de planta, operación local y proveedores industriales.	Afectación potencial a continuidad del servicio esencial, calidad del agua, safety, medioambiente y coordinación de instalaciones.	Hipótesis: 2-8 h según instalación; validar por criticidad sanitaria/ambiental y autonomía local.	Hipótesis: 1-4 h para supervisión central o coordinación; operación local/manual debe sostener el servicio.	Hipótesis: 15-60 min para datos críticos de supervisión/historian; no aplica igual a control local autónomo.	Operación local autónoma, procedimientos manuales, comunicaciones redundantes, historian/local cache, repuestos, copias de configuración, contactos OT y pruebas no intrusivas validadas por Operaciones.
Identidad corporativa	AD, DNS, MFA, VPN/ZTNA, PAM, cuentas privilegiadas y cuentas de servicio.	Bloquea acceso a aplicaciones, teletrabajo, administración, recuperación y escalado técnico.	4 h	1-2 h para servicios mínimos de autenticación, DNS y acceso administrativo de emergencia.	≤1 h para cambios críticos; restauración desde backup consistente y controlado.	Controladores redundantes, DNS/NTP redundante, backup de estado/configuración, cuentas break-glass controladas, PAM/bastión alternativo y prueba de restauración.
CPD y virtualización	Hosts, almacenamiento, red, servicios base,	Afecta múltiples aplicaciones y puede impedir	4-8 h	2-4 h para servicios base priorizados.	≤1 h en servicios críticos; validar por aplicación.	Cluster HA, almacenamiento redundante, replicación

Proceso / servicio	Aplicación o soporte	Impacto si cae	MTD orientativo	RTO propuesto	RPO propuesto	Solución IT idónea
	orquestración y gestión.	recuperación ordenada.				selectiva, backup inmutable, red de recuperación y DR parcial en cloud/segundo sitio.
Atención a abonados	CRM, CALLMATIC, telefonía/contact center y datos de cliente.	Pérdida de atención, reclamaciones, impacto reputacional y saturación de canales alternativos.	8 h	4 h para atención mínima o canal alternativo.	1 h para datos transaccionales; conciliación posterior si opera degradado.	SLA proveedor, colas alternativas, export CRM crítico, telefonía redundante, portal de avisos y guion de contingencia.
Trámites online	Oficina Virtual, AQUAPP, APIs, web pública y base de datos asociada.	Impacto en clientes, pagos/trámites, reputación y presión sobre atención.	24 h	8 h para servicio mínimo o página informativa/transaccional degradada.	2-4 h según trámite y datos transaccionales.	WAF/CDN, frontales redundantes, backup BD consistente, despliegue automatizado, DR aplicativo y canal informativo alternativo.
ERP y administración	SAP ERP, finanzas, compras, facturación interna y reporting.	Impacto financiero y administrativo acumulativo; no siempre inmediato para operación del agua.	48 h	24 h para funciones críticas administrativas.	4 h en datos financieros/transaccionales críticos; validar cierre/conciliación.	Backup consistente, réplica BD, procedimientos manuales temporales, colas de integración y recuperación priorizada.
Correo y colaboración	Correo cloud, colaboración, documentos, calendario y canales de coordinación.	Afecta comunicación, coordinación de incidentes, proveedores y evidencias.	24 h; 2-4 h para comunicación de crisis.	8 h para servicio ordinario; 1 h para canal de crisis fuera de banda.	Proveedor/retención; objetivo ≤4 h para mensajes y documentos críticos si existe backup SaaS.	SLA cloud, backup SaaS, retención, exportaciones, cuentas de emergencia, canal alternativo fuera de banda y árbol de llamadas.
Pagos y cobros	Servired, pasarela, ERP/CRM y conciliación.	Impacto económico, atención a cliente, conciliación y reputación.	24 h	8 h para canal de cobro o alternativa operativa.	1-4 h para transacciones; conciliación diferida obligatoria.	SLA proveedor, canal alternativo, conciliación diferida, controles antifraude y procedimientos de regularización.
Backups y recuperación	Repositorio, bóveda, copias de configuración, backup SaaS y	Sin recuperación fiable ante ransomware, fallo grave o	Capacidad transversal: no debe estar indisponible	RTO heredado del servicio que recupera; pruebas por entorno.	RPO heredado del servicio; definido por política de copia/replicación.	Regla 3-2-1-1-0, copias inmutables/offline, segregación de credenciales,

Proceso / servicio	Aplicación o soporte	Impacto si cae	MTD orientativo	RTO propuesto	RPO propuesto	Solución IT idónea
	evidencias de restauración.	corrupción de datos.	durante una crisis prolongada.			restauración limpia, escaneo previo, copias de configuración OT si aplica y registro de pruebas.
Gestión de crisis y comunicación	Comité de crisis, canales internos, telefonía alternativa, correo alternativo y repositorio documental.	Descoordinación, mensajes contradictorios, retrasos regulatorios y mala priorización.	2-4 h	1 h para activar comité y canal alternativo.	No aplica a datos operativos; sí aplica a preservación de evidencias y actas.	Canales fuera de banda, árbol de llamadas, sala de crisis, repositorio seguro, plantillas, TLP y actas de decisión.



Valores orientativos; pendientes de validación de negocio, TI, Operaciones, DPD y proveedores. No son RTO/RPO aprobados.

Figura 9. BIA preliminar como mapa de calor por procesos y ventanas temporales.

15. Esbozo de Plan de Continuidad y soluciones IT

El Plan de Continuidad de Negocio completo no se aprueba en este apartado; aquí se fija una referencia técnica para conectar riesgos, BIA, prioridades de recuperación y soluciones tecnológicas. El PCN define cómo continúa la organización; el PCTIC concreta la continuidad de los servicios tecnológicos; el PRD/DRP aborda la recuperación ante desastre; y los planes de recuperación de entornos detallan cómo restaurar aplicaciones, plataformas o servicios concretos. Ninguno de estos documentos debe considerarse aprobado sin pruebas, evidencias, responsables y validación de negocio.

Artefacto / componente	Alcance y contenido mínimo	Relación con soluciones IT y evidencias
PCN · Plan de Continuidad de Negocio	Marco organizativo para continuar procesos críticos: activación, prioridades, roles, comunicación, sedes, personas, proveedores y retorno a la normalidad.	Se alimenta del BIA formal. Debe probarse mediante simulacros, tabletop y evidencias de decisión.
PCTIC · Plan de Continuidad TIC	Continuidad de servicios tecnológicos que soportan procesos: CPD, identidad, red, cloud/correo, aplicaciones, teletrabajo, seguridad y datos.	HA, replicación, backup, DR parcial, canales alternativos, inventario de dependencias y pruebas técnicas documentadas.

Artefacto / componente	Alcance y contenido mínimo	Relación con soluciones IT y evidencias
PRD/DRP · Recuperación ante desastre	Recuperación de infraestructura o servicios tras desastre mayor: CPD, pérdida de almacenamiento, ransomware, indisponibilidad de cloud o fallo prolongado.	Runbooks de restauración, red de recuperación, copias inmutables/offline, validación de integridad y criterios de retorno seguro.
Plan de recuperación de entorno	Documento específico por aplicación, plataforma o entorno: identidad, CRM, ERP, Oficina Virtual, correo, backup, historian/intercambio o soporte OT.	Inventario técnico, dependencias, orden de arranque, credenciales de emergencia, responsables, pruebas y evidencias; coherente con plantillas INCIBE.
Plan de crisis y comunicación	Activación del comité, comunicación interna/externa, autoridades, clientes, proveedores, DPD y responsables de negocio.	Canales fuera de banda, sala de crisis, plantillas, árbol de llamadas, TLP y registro de decisiones.
Estrategia de backup y recuperación	Frecuencia, retención, cifrado, inmutabilidad, aislamiento, restauración limpia, segregación de credenciales y priorización por BIA.	3-2-1-1-0, backup SaaS, copias de configuración OT si aplica, restauraciones recurrentes y actas de resultado.
Continuidad OT	Operación local, procedimientos manuales, autonomía mínima, repuestos, contactos de proveedores, copias de configuración y criterios de retorno seguro.	Pruebas no intrusivas por defecto, validación de Operaciones, monitorización pasiva y prohibición de cambios que afecten safety o continuidad sin autorización.
Proveedores críticos	Continuidad de CALLMATIC, Servired, cloud/correo, frontales web y proveedores industriales: contactos, escalado, subcontratación, evidencias y salida ordenada.	SLA/OLA, informes de continuidad, pruebas conjuntas, accesos remotos controlados, evidencias periódicas y cláusulas de notificación.
Pruebas, mantenimiento y mejora	Calendario de pruebas, revisión tras cambios, auditoría, lecciones aprendidas, actualización documental y concienciación.	Restauraciones reales o controladas, simulacros, tickets correctivos, actas firmadas y métricas sin convertirlas en SLA no validados.

Criterio de validación. Ninguna solución de continuidad se considerará eficaz por diseño: debe existir propietario, procedimiento, entorno de prueba o restauración controlada, resultado documentado, incidencias detectadas, acciones correctoras y aceptación del riesgo residual. Para proveedores críticos, la evidencia debe incluir contactos de emergencia, compromiso de continuidad, capacidad de escalado y prueba o simulación documentada.

16. Registro ejecutivo de riesgos actualizado

El registro consolida R1-R11 e incorpora explícitamente cloud/correo, teletrabajo y BIA/continuidad como riesgos tratados en el análisis. La matriz deberá revisarse cuando exista nueva evidencia técnica, cambios de arquitectura o incidentes relevantes.

Tabla 12. Registro ejecutivo de riesgos actualizado.

Código	Escenario	Vulnerabilidades asociadas	Impacto dominante	Riesgo actual	Tratamiento prioritario
R1	Ransomware sobre CPD, servidores y backups.	V4, V5, V6, V7	Disponibilidad, datos, recuperación	Crítico	EDR/XDR, hardening, segmentación, bloqueo de ejecución, backups inmutables, restauración probada y detección de precursores.
R2	Compromiso de identidad, VPN, AD o cuentas privilegiadas.	V2, V4, V6	Acceso, trazabilidad, continuidad	Crítico	MFA, PAM, revisión de privilegios, ciclo de vida, control de cuentas de servicio, alertas y revocación rápida.
R3	Indisponibilidad del CPD o servicios base.	V1, V5, V12	Continuidad	Crítico	HA, backup/DR, BIA, pruebas de recuperación.

Código	Escenario	Vulnerabilidades asociadas	Impacto dominante	Riesgo actual	Tratamiento prioritario
R4	Explotación de aplicaciones públicas y APIs.	V3, V7, V11	Datos, reputación, entrada inicial	Alto	WAF/API security, pruebas OWASP controladas, SDLC, logging, parcheo y validación de autorización; sin explotación innecesaria en producción.
R5	Incidente en proveedor crítico.	V8	Continuidad, datos, cadena suministro	Alto	Contratos, evidencias, accesos temporales, segmentación, logs de terceros, pruebas de continuidad y derecho de auditoría.
R6	Falta de inventario, trazabilidad, visibilidad, calidad de logs o custodia de evidencias.	V1, V6, V11	Gobierno, detección, investigación, respuesta	Alto	CMDB, mapa de fuentes de log, SIEM, logs normalizados, NTP, retención, custodia, cobertura de telemetría, reporting y cierre de lagunas de visibilidad.
R7	Vulnerabilidades críticas o configuraciones débiles.	V7, V11	Explotación, movimiento lateral	Alto	Gestión de vulnerabilidades priorizada por explotación conocida, exposición, criticidad del activo, hardening, parcheo y verificación.
R8	Riesgo IT/OT por intervención, acceso remoto, flujo o prueba no coordinada.	V9	OT, safety, medioambiente, calidad del agua	Crítico	Frontera IT/OT, DMZ OT, jump server, validación Operaciones, monitorización pasiva, logs de acceso industrial, sin escaneos activos ni contención automática.
R9	Teletrabajo no administrado.	V2	Identidad, endpoint, acceso remoto	Alto	ZTNA/VPN segmentada, MDM/EDR, horarios, perfiles, MFA, postura de dispositivo y revisión de sesiones.
R10	Cloud/correo mal configurado o sin gobierno suficiente.	V10	Datos, phishing, cumplimiento	Alto	MFA, acceso condicional, DLP, CASB/CSPM, logs, retención, cifrado y revisión de forwarding/reglas sospechosas.
R11	MTD/RTO/RPO preliminares no validados o sin capacidad técnica demostrada.	V12	Continuidad, recuperación, cumplimiento y operación esencial	Crítico	BIA formal, PCN/PCTIC/PRD, planes de recuperación por entorno, pruebas, evidencias, responsables y validación de negocio/Operaciones/proveedor es.

Anexo IV. Gestión de la ciberseguridad y arquitectura tecnológica

1. Objeto, alcance y enfoque

El presente anexo define el modelo tecnológico y operativo para gestionar la ciberseguridad de ACME Waters. Parte de la FASE 3.1, donde quedaron priorizados los escenarios R1-R11, y los transforma en proyectos, servicios, controles, decisiones de implantación y evidencias verificables. Su función no es sustituir el análisis de riesgos ni anticipar la respuesta a incidentes, sino convertir el riesgo aprobado en una cartera gobernable de capacidades tecnológicas.

El documento no pretende describir la situación inicial con detalle, porque no existe inventario completo ni topología verificada. Por ello, el GAP se plantea como distancia entre una situación inicial no consolidada —visibilidad parcial, controles no integrados, dependencias de terceros, relación IT/OT no detallada y recuperación no evidenciada— y una arquitectura objetivo gobernable, monitorizable y recuperable.

1.1 Trazabilidad metodológica entre anexos

Entrada	En qué se traduce	Evidencia esperada
FASE 1 · Estrategia	Convierte ENS, NIST CSF 2.0 y horizonte a cinco años en proyectos tecnológicos priorizados a tres años.	Roadmap trienal, marcos seleccionados y criterios de seguimiento.
FASE 2 · Organización	Aterrizaje DC/CISO-RSI, DIS/CIO, SOC híbrido/MDR y Operaciones en servicios recurrentes con propietarios.	Modelo Global de Servicios, responsabilidades y evidencias mínimas.
FASE 3.1 · Riesgos R1-R11	Transforma ransomware, identidad, CPD, aplicaciones, proveedores, visibilidad, vulnerabilidades e IT/OT en cartera P1-P12.	Plan Director de Seguridad y arquitectura por capas.
FASE 3.2 · Gestión tecnológica	Ordena herramientas, servicios, presupuesto y certificaciones como medios de reducción de riesgo, no como fines.	Pilotos, RFP, criterios de aceptación, control de costes y reporting.
FASE 3.3 · Respuesta	Se integra como bloque operativo de severidades, runbooks, escalado, comunicación y SOAR controlado.	Dependencias explícitas hacia respuesta a incidentes y SOAR operativo.

2. Plan Director de Seguridad: cartera de proyectos

El Plan Director de Seguridad ordena los proyectos necesarios para cerrar el GAP entre el punto de partida y los objetivos a corto, medio y largo plazo. El horizonte táctico de esta fase se fija a tres años y se alinea con la visión a cinco años definida en la estrategia. Los proyectos no deben interpretarse como compras aisladas, sino como una cartera integrada con responsables, dependencias, evidencias y revisión periódica.

Tabla 13. Cartera resumida de proyectos del Plan Director de Seguridad.

ID	Proyecto	Objetivo	Horizonte
P1	Gobierno, ENS y SGSI	Definir políticas, evidencias, comité de seguimiento, priorización por riesgo y preparación de certificación ENS/ISO 27001.	Año 1-3
P2	Inventario, CMDB y criticidad	Inventariar activos críticos, identidades, proveedores, aplicaciones, datos, flujos y dependencias IT/OT.	Año 1
P3	Identidad, MFA y PAM	Extender MFA, implantar PAM inicial, cuentas nominativas, revisión de privilegios y ciclo de vida de identidades.	Año 1-2
P4	Endpoint, movilidad y código malicioso	EDR/XDR, MDM, hardening, antimalware avanzado, control de configuración y protección de portátiles/Android.	Año 1-3

P5	SIEM, SOC híbrido y MDR	Centralizar logs críticos, normalizar eventos, contratar apoyo MDR/SOC y desarrollar reporting ejecutivo.	Año 1-3
P6	SOAR y automatización controlada	Preparar integraciones y gobierno de automatización; implantar orquestación inicial para enriquecimiento, ticketing, evidencias y notificaciones; runbooks detallados en el bloque de respuesta a ciberataques.	Año 1-3
P7	Segmentación y frontera IT/OT	Separar dominios IT/OT, controlar accesos remotos industriales, flujos autorizados y cambios validados por Operaciones.	Año 1-3
P8	Aplicaciones públicas y APIs	WAF/API security, pruebas periódicas, logging, autenticación, autorización, gestión de sesiones y SDLC seguro.	Año 1-3
P9	Gestión de vulnerabilidades	Modelo continuo de descubrimiento, priorización, remediación, excepción documentada, verificación y métricas.	Año 1-3
P10	Cifrado, claves y protección de datos	Estrategia de cifrado en tránsito, reposo, backups, dispositivos, secretos y gestión de claves.	Año 1-3
P11	Backups, recuperación tecnológica y pruebas	Backups segregados, protección frente a ransomware, restauración probada por entorno, evidencias, recuperación de configuraciones críticas, continuidad cloud/correo y continuidad de proveedores, sin fijar RTO/RPO hasta BIA.	Año 1-3
P12	Proveedores críticos y terceros	Clasificación, controles contractuales, accesos temporales, evidencias, continuidad, logs y salida ordenada.	Año 1-3

3. Modelo Global de Servicios de Ciberseguridad

El modelo de servicios convierte la arquitectura en operación recurrente. Cada servicio debe tener propietario, entradas, salidas, evidencias, criterio de escalado y relación con el riesgo que trata. La DC/CISO-RSI mantiene gobierno, control y exigencia de evidencias; la DIS/CIO ejecuta operación técnica; Operaciones valida impacto en servicios esenciales e IT/OT. Este reparto evita que la gestión de la ciberseguridad dependa únicamente de herramientas o de proveedores.

Servicio	Responsable	Contenido mínimo
Gobierno y cumplimiento	DC/CISO-RSI	Políticas, ENS, riesgos, evidencias, indicadores, auditorías y comité de seguimiento.
Arquitectura y control de cambios	DIS/CIO + DC	Validar proyectos, cambios técnicos, arquitectura, excepciones y riesgos residuales.

IAM/PAM/MFA	DIS/IAM	Altas, bajas, recertificación, privilegios, cuentas de servicio, terceros y accesos remotos.
SOC híbrido/MDR	SOC interno + proveedor	Monitorización, triage, escalado, investigación inicial, reporting y coordinación internacional.
SIEM y telemetría	DIS/SOC	Ingesta, normalización, retención, correlación, alertas, dashboards y custodia de logs.
SOAR y ticketing	SOC + DIS	Orquestación, enriquecimiento, evidencias, tickets, notificaciones y automatización controlada con aprobación humana, segregación de funciones y registro de acciones.
Gestión de vulnerabilidades	DIS + responsables activos	Descubrimiento, priorización, remediación, excepción, verificación y reporting.
Prevención de código malicioso	DIS/SOC	EDR/XDR, correo, navegación, sandboxing, MDM, hardening y respuesta inicial.
Seguridad de aplicaciones	Equipos aplicación + DC	WAF/API, pruebas, logging, SDLC, autenticación, autorización y revisión de sesiones.
Continuidad y recuperación	TI + Operaciones	Backups, restauración probada, mapa de entornos recuperables, evidencias de pruebas, recuperación de servicios base, coordinación con Operaciones y continuidad de proveedores críticos.
Seguridad IT/OT	Operaciones + DIS + DC	Frontera IT/OT, acceso remoto industrial, monitorización pasiva y validación operacional.
Gestión de terceros	Compras + DC + DIS	Clasificación, cláusulas, accesos, evidencias, continuidad, revisión y salida.

4. Marcos de referencia y certificaciones

La arquitectura se apoya en un marco global de normativa ciber que combina obligación nacional, gestión de riesgos, operación tecnológica y seguridad industrial. Las certificaciones deben justificar evidencia y madurez, no convertirse en un fin administrativo.

Marco	Uso	Justificación
ENS RD 311/2022	Marco principal nacional y referencia de cumplimiento	Debe guiar medidas, evidencias, trazabilidad, auditoría y certificación progresiva por la naturaleza pública y los servicios electrónicos de ACME Waters.
NIST CSF 2.0	Marco global de gestión, no certificación	Ordena objetivos en Govern, Identify, Protect, Detect, Respond y Recover. Útil para comunicar al Consejo, priorizar roadmap y mantener continuidad entre anexos.
ISO/IEC 27001	Certificación recomendable a medio plazo	SGSI certificable para gobierno, riesgos, mejora continua, auditoría y coherencia internacional. Debe implantarse de forma progresiva, no como ejercicio documental aislado.
ISO/IEC 27005	Apoyo metodológico de riesgos	Refuerza el ciclo de identificación, análisis, evaluación, tratamiento, aceptación,

		seguimiento y revisión de riesgos ya iniciado en FASE 3.1.
NIST SP 800-207	Referencia Zero Trust IT	Aplicar solo a IT: identidad, contexto, mínimo privilegio, segmentación y trazabilidad.
NIST SP 800-82r3 / ISA/IEC 62443	Referencia OT/IACS	Usar como guía para OT sin inventar topología: disponibilidad, safety, fiabilidad, mantenimiento y monitorización prudente.
ISO 22301	Certificación futura opcional	Considerarla tras BIA, PCN/PCTIC y PRD formales. En FASE 3.2 solo se prepara la arquitectura tecnológica de recuperación; no se fijan RTO/RPO/MTD.

Criterio de certificación. ENS e ISO/IEC 27001 son objetivos principales porque generan evidencia, auditoría y disciplina de mejora continua. NIST CSF 2.0, ISO/IEC 27005, NIST SP 800-207, NIST SP 800-82r3 e ISA/IEC 62443 se emplean como marcos de apoyo y diseño; no deben presentarse como certificaciones inmediatas ni como sustitutos del análisis de contexto.

5. Modelo global de arquitectura de seguridad

El modelo global se organiza por capas y servicios. Debe permitir gobernar, proteger, monitorizar, detectar y recuperar, manteniendo la separación entre IT corporativo y OT. La capa IT puede evolucionar a Zero Trust; la capa OT requiere validación operacional y controles no intrusivos.

Capa	Capacidades
Gobierno	ENS, SGSI, riesgo, evidencias, políticas, métricas, proveedores y comité.
Identidad	IAM, MFA, PAM, cuentas de servicio, terceros, revisión, revocación y trazabilidad.
Protección IT	Hardening, parcheo, EDR/XDR, MDM, WAF/API, DLP, correo, cloud, cifrado y gestión de vulnerabilidades.
Red y CPD	Segmentación progresiva, administración separada, flujos autorizados, bastionado y control de cambios.
Frontera IT/OT	Accesos remotos industriales, transferencia controlada, registro de sesión, ventanas, aprobación y reversibilidad.
Detección	SIEM, NDR, EDR/XDR, MDR/SOC, logs, telemetría, alertas, inteligencia y reporting.
Respuesta y SOAR	Ticketing, enriquecimiento, evidencias, escalado y automatización controlada; playbooks en FASE 3.3.
Recuperación	Backups segregados, restauración probada, continuidad cloud/correo, recuperación de CPD e identidad, proveedores críticos, evidencias y coordinación IT/OT.

Arquitectura tecnológica objetivo por capas

Visión ejecutiva con frontera IT/OT y capacidades principales. La figura resume dominios funcionales; el detalle técnico se desarrolla en el texto.



Figura 10. Arquitectura tecnológica objetivo por capas, con frontera IT/OT y capacidades principales.

6. Análisis de herramientas SIEM y selección

El SIEM debe resolver el GAP de visibilidad: centralizar logs, normalizar eventos, correlacionar señales, generar alertas priorizadas, soportar investigación y producir reporting ejecutivo. La selección no debe basarse solo en coste de licencia, sino en integración, gobierno de datos, retención, escalabilidad, operación MDR/SOC y coste por volumen de ingesta.

Tabla 14. Comparativa ejecutiva de soluciones SIEM y decisión propuesta.

Solución	Tipo	Fortalezas	Limitaciones	Decisión
Wazuh	Open source SIEM/XDR	Coste de licencia bajo, control on-premise, útil	Exige operación propia, tuning, escalado, alta	Complementaria / piloto

		para laboratorios o nodos controlados.	disponibilidad y soporte especializado.	
Elastic Security	SIEM flexible	Gran capacidad de búsqueda, despliegue cloud/on-prem, ecosistema de datos potente.	Requiere diseño de ingestión, operación y gobierno de costes/capacidad.	Alternativa técnica
Microsoft Sentinel	SIEM cloud-native	SIEM escalable multicloud/multiplataforma, integración con identidad, cloud, correo, automatización e inteligencia.	Coste sensible al volumen de logs; exige gobierno de ingesta y retención.	Seleccionada
IBM QRadar	SIEM empresarial	Producto maduro, correlación y suite con SOAR/EDR.	Mayor complejidad y dependencia de suite/proveedor.	Alternativa enterprise
Splunk Enterprise Security	SIEM enterprise	Muy potente para entornos heterogéneos y analítica avanzada.	Coste y operación elevados si el volumen de logs crece sin gobierno.	Alternativa premium
Google Security Operations	SIEM/SOAR cloud	Escala cloud, threat intelligence y enfoque de búsqueda a gran volumen.	Conveniente si la organización ya opera sobre ecosistema Google o SecOps gestionado.	Alternativa cloud

Selección propuesta: Microsoft Sentinel como SIEM principal para ACME Waters. La elección se justifica por su orientación cloud-native, capacidades SIEM/SOAR, integración con identidad, correo, endpoint y cloud, escalabilidad para sedes internacionales y facilidad de contratación de servicios MDR/SOC. No obstante, se trata de una decisión de arquitectura y planificación, no de una adjudicación cerrada: debe validarse mediante piloto, RFP, prueba de ingesta, residencia de datos, cumplimiento ENS/RGPD, integración con fuentes críticas y control de costes.

Criterio de contención de coste: no todo log debe entrar como analítica de alto valor. Debe definirse una política de ingesta por criticidad: identidad, privilegios, endpoints críticos, aplicaciones públicas, cloud/correo, proveedores, frontera IT/OT y eventos de recuperación. Los logs de bajo valor analítico podrán conservarse en almacenamiento alternativo o retención diferenciada si cumplen requisitos de auditoría y forense.

7. Análisis de soluciones SOAR y selección

SOAR debe orquestar tareas repetibles, enriquecer alertas, abrir tickets, preservar evidencias, coordinar escalado y reducir fricción entre SIEM, MDR/SOC, EDR/XDR, inteligencia y herramientas de soporte. En esta fase se selecciona la capacidad, sus criterios de adopción y sus límites; el diseño de playbooks, reglas operativas y acciones de contención se detallan más adelante.

Criterios de selección SOAR aplicados:

Criterio	Aplicación en ACME Waters
Coherencia con SIEM	Priorizar la opción integrada con el SIEM elegido para reducir fricción operativa, duplicidad de conectores y coste de integración.
Madurez operativa	No activar automatización antes de disponer de telemetría mínima, alertas priorizadas, propietarios, ticketing y procedimiento de escalado.
Orquestación inicial	Usar SOAR primero para enriquecimiento, creación de tickets, notificación, recopilación de evidencias y reporting; no para contención automática generalizada.
Aprobación humana	Requerir validación humana en acciones críticas: cuentas privilegiadas, aislamiento de activos, cambios de firewall, proveedores, cloud y cualquier impacto OT.
Trazabilidad y evidencias	Registrar entrada, decisión, acción, responsable, resultado y evidencia para auditoría, investigación y mejora continua.

Criterio	Aplicación en ACME Waters
Control de coste	Medir consumo de ejecuciones, conectores, retención e integraciones; ajustar automatizaciones según valor operativo y coste real.
Restricción OT	No ejecutar respuestas intrusivas ni contención automática en OT sin validación de Operaciones, ventana autorizada y plan de reversión.

Tabla 15. Comparativa ejecutiva de soluciones SOAR y decisión propuesta.

Solución	Encaje	Fortalezas	Limitaciones	Decisión
Microsoft Sentinel Automation / Logic Apps	Integrado con Microsoft Sentinel mediante reglas de automatización, playbooks y conectores.	Menor fricción si Sentinel es SIEM principal; buen encaje con SOC híbrido/MDR, ticketing, evidencias y coordinación cloud.	Requiere gobierno de costes, control de permisos, pruebas y aprobación humana en acciones críticas.	Seleccionada
Splunk SOAR	SOAR independiente con amplia integración, playbooks y case management.	Muy fuerte en SOC avanzados y entornos heterogéneos; alta madurez de orquestación.	Coste y operación más altos; mejor justificado si Splunk ES fuese SIEM principal.	Alternativa premium
IBM QRadar SOAR	Orquestación, automatización y gestión de casos dentro del ecosistema QRadar.	Adecuado para organizaciones que eligen QRadar como plataforma central.	Menos justificable si el SIEM seleccionado no es QRadar y se quiere reducir complejidad.	Alternativa enterprise
Google SecOps SOAR	SOAR integrado en Google Security Operations.	Adecuado si la estrategia cloud y de SecOps se orienta al ecosistema Google.	Dependencia de plataforma y migración de modelo operativo.	Alternativa cloud
TheHive + Cortex	Gestión de casos y análisis automatizado de observables.	Coste bajo, flexibilidad y utilidad para CERT/CSIRT, laboratorios o capacidad complementaria.	Mayor carga de operación, integración, mantenimiento y automatización a medida.	Complementaria

Selección propuesta: Microsoft Sentinel Automation con playbooks basados en Logic Apps. Se adopta por coherencia con el SIEM elegido, integración con conectores de seguridad, menor fricción para el SOC híbrido/MDR y capacidad de orquestar enriquecimiento, ticketing, notificaciones y evidencias. La selección no autoriza automatizaciones de contención sin diseño, prueba y aprobación: las acciones sobre cuentas privilegiadas, sistemas críticos, proveedores o frontera IT/OT deberán quedar sujetas a validación humana, segregación de funciones, control de cambios y reversibilidad.

Criterio de madurez SOAR. En esta fase se habilita la capacidad, se decide la plataforma, se preparan integraciones y se fijan límites de seguridad. La sección 3.3 incluye los playbooks concretos (ransomware, abuso de credenciales, explotación web, proveedor comprometido y alerta en frontera IT/OT) con aprobación humana en acciones críticas. SOAR no sustituye a gobierno, triage, investigación ni decisión operativa.

8. Estrategia de cifrado y gestión de claves

La estrategia de cifrado debe proteger confidencialidad, integridad y trazabilidad sin afectar la disponibilidad de servicios esenciales. Debe cubrir sistemas que soportan aplicaciones y elementos de apoyo: servidores, bases de datos, endpoints, móviles, correo, cloud, backups, logs, secretos y comunicaciones. La gestión de claves debe tratarse como capacidad crítica: propietarios, custodia, rotación, recuperación, segregación de funciones y evidencias de acceso. En OT, cualquier cifrado o inspección que pueda alterar latencia, compatibilidad o operación requerirá validación previa.

Ámbito	Estrategia	Aplicación
Datos en tránsito	TLS 1.2+ con preferencia por TLS 1.3, certificados válidos, eliminación de	Aplicaciones públicas, APIs, VPN, administración, integraciones y correo.

	protocolos obsoletos y revisión de configuración.	
Datos en reposo	Cifrado de discos, bases de datos, repositorios documentales, backups y almacenamiento cloud.	CPD, servidores, bases de datos SAP/CRM, repositorios y copias.
Endpoints y móviles	Cifrado de disco, MDM, bloqueo remoto, protección de claves y separación de datos corporativos.	Portátiles y Android corporativos.
Backups	Cifrado, segregación, control de acceso, inmutabilidad cuando sea viable, verificación de integridad y pruebas de restauración.	Backups de servidores, datos críticos, configuraciones, repositorios y servicios de apoyo.
Gestión de claves	KMS/HSM o servicio equivalente, segregación de funciones, rotación, custodia, acceso mínimo y registro de uso.	Claves maestras, secretos de aplicación, certificados y tokens.
Logs y evidencias	Protección de confidencialidad e integridad, control de acceso y retención conforme a necesidad legal/operativa.	SIEM, evidencias de acceso y registros de auditoría.
OT	No imponer cifrado que afecte latencia, compatibilidad o seguridad operacional sin validación.	Frontera IT/OT, acceso remoto industrial y transferencia de ficheros.

9. Programa de Gestión de Vulnerabilidades

El programa de vulnerabilidades debe ser continuo y basado en riesgo. No basta con escanear: se requiere inventario, priorización, responsables, remediación, verificación, excepción formal y retroalimentación hacia arquitectura, compras, hardening y control de cambios.

Fase	Contenido
1. Alcance	Definir activos cubiertos: servidores, endpoints, aplicaciones, cloud, red, proveedores y frontera IT/OT.
2. Descubrimiento	Combinar inventario, agentes, escaneo autenticado en IT, revisión de configuración y fuentes de vulnerabilidades.
3. Priorización	Ordenar por criticidad de activo, exposición, explotación conocida, impacto en R1-R11 y dependencia operacional.
4. Remediación	Asignar propietario, ventana, parche, hardening, mitigación temporal o aceptación excepcional documentada.
5. OT	Usar métodos pasivos o validados; evitar escaneos activos o pruebas intrusivas sin aprobación de Operaciones.
6. Verificación	Comprobar cierre técnico, evidencia, actualización de inventario y ausencia de impacto operativo.
7. Reporting	Informar cobertura, vulnerabilidades críticas abiertas, antigüedad, excepciones, reincidencia y tendencia.
8. Integración	Conectar SIEM/SOAR/ticketing para trazabilidad, no para contención automática sin validación.

10. Programa de Prevención del Código Malicioso

El programa de prevención de código malicioso debe reducir la probabilidad de ransomware, malware, phishing, ejecución no autorizada y movimiento lateral. Debe combinar controles técnicos, supervisión, hábitos operativos, recuperación y gestión de excepciones. Su eficacia no se mide por disponer de una herramienta concreta, sino por cobertura, configuración, alertas útiles, capacidad de contención aprobada y restauración demostrable.

Dominio	Medidas
Endpoint	EDR/XDR, antimalware avanzado, hardening, control de aplicaciones, bloqueo de macros no justificadas y aislamiento controlado.
Correo y colaboración	Antiphishing, antimalware, reputación, sandboxing de adjuntos, protección de enlaces y formación frente a ingeniería social.
Web y navegación	Filtrado, reputación, proxy o control equivalente, descarga segura y análisis de contenido cuando proceda.
Aplicaciones públicas	WAF/API security, validación de entradas, gestión de sesiones, logging y pruebas periódicas.
Identidad	MFA, PAM, detección de abuso de credenciales y revisión de privilegios.
Backups	Copias segregadas, inmutabilidad cuando sea viable, restauración probada, control de acceso, verificación de integridad y restauración limpia frente a ransomware.
OT	No ejecutar herramientas antimalware o cambios intrusivos sin validación; priorizar control de accesos, transferencia segura y monitorización pasiva.
SOC/MDR	Correlación de señales de endpoint, identidad, correo, red y aplicaciones; escalado y evidencia.

11. Criterios de recuperación y continuidad tecnológica

La arquitectura tecnológica debe preparar la recuperación sin sustituir al PCN, PCTIC o PRD. En esta fase se definen capacidades, responsables y evidencias mínimas; los tiempos de recuperación, prioridades de negocio y tolerancias de caída deberán fijarse posteriormente mediante BIA y planes específicos.

Ámbito	Criterio de recuperación	Evidencia mínima
CPD y servicios base	Mantener copias protegidas de servidores críticos, configuraciones, servicios de directorio, DNS, red y plataformas de soporte, priorizando restauración técnica verificable.	Registro de prueba, responsable, alcance, resultado, incidencias y acciones correctoras.
Identidad y acceso	Incluir IAM, MFA, PAM, cuentas privilegiadas, cuentas de servicio y configuración de acceso remoto dentro del perímetro recuperable.	Exportación o respaldo de configuración, revisión de privilegios y prueba de recuperación controlada.
Aplicaciones y datos	Asegurar backups consistentes de bases de datos, repositorios, configuración de aplicaciones públicas, CRM, Oficina Virtual, AQUAPP y servicios críticos asociados.	Restauración parcial o completa en entorno controlado, con validación funcional y evidencia de integridad.
Cloud/correo	Exigir continuidad, retención, recuperación de configuración y evidencias del proveedor para correo, colaboración y servicios cloud críticos.	Cláusulas, informes, evidencias de backup/retención y prueba o simulación documentada.
Proveedores críticos	Incorporar obligaciones de continuidad, contacto de emergencia, evidencias de recuperación, notificación y salida ordenada.	Anexo contractual, matriz de dependencia, evidencias periódicas y revisión anual.
Frontera IT/OT	Recuperar componentes de acceso, salto administrativo, transferencia de ficheros y registro de sesión sin ejecutar pruebas intrusivas en OT sin validación de Operaciones.	Aprobación operacional, ventana, plan de reversión y evidencia de prueba no intrusiva.
Ransomware	Combinar segregación, inmutabilidad cuando sea viable, control de acceso, verificación de integridad y restauración limpia antes de volver a producción.	Prueba de restauración, comprobación antimalware, registro de decisión y autorización de retorno.

Límite de esta fase	No considerar RTO, RPO, MTD ni prioridades como finales sino como puntos de partida para el proceso de aprendizaje y mejora continua.	Lista de entornos, responsables, dependencias, evidencias de referencia iniciales.
---------------------	---	--

12. Roadmap y presupuesto a tres años

El roadmap concreta el Plan Director en tres años y la visión macro a cinco años sin duplicarla: los tres primeros años construyen gobierno, cobertura, visibilidad y resiliencia recuperable; los años posteriores deberán optimizar madurez, automatización, continuidad formal y mejora continua.

Horizonte	Capacidades principales
Año 1 · Base gobernable	Inventario crítico, ENS/SGSI, IAM/MFA/PAM inicial, SIEM piloto-productivo, MDR/SOC híbrido, EDR/XDR prioritario, backups segregados, mapa de entornos recuperables, primera restauración controlada de servicios base, gestión de vulnerabilidades, cifrado base, proveedores críticos, frontera IT/OT y preparación de integraciones SOAR sin contención automática.
Año 2 · Cobertura y consolidación	Ampliar SIEM, normalización y retención; SOAR inicial para enriquecimiento, ticketing, evidencias y notificaciones; WAF/API; MDM/DLP; NDR crítico; segmentación CPD/usuarios/servidores/proveedores; monitorización OT pasiva validada; recertificación de accesos; pruebas de restauración de aplicaciones críticas, cloud/correo y dependencias de proveedores.
Año 3 · Madurez y optimización	Optimización de costes SIEM/SOAR, playbooks FASE 3.3, automatización controlada con aprobación humana, reporting ejecutivo maduro, PAM extendido, cuentas de servicio, vulnerabilidades por riesgo, pruebas integradas de recuperación tecnológica y madurez IT/OT.

Roadmap tecnológico a 3 años

Secuencia priorizada para implantar capacidades, consolidarlas y optimizarlas sin duplicar el plan global a cinco años.

Presupuesto orientativo anual

Año 1: 1.380-2.190

Año 2: 1.420-2.230

Año 3: 1.300-2.080

Total 3 años: 4.100-6.500

	Año 1 Fundación y cobertura mínima	Año 2 Consolidación y escalado	Año 3 Optimización y mejora continua
Gobierno y PDS	- Plan Director, PMO, ENS/SGSI y trazabilidad. - Inventario/CMDb y criterios de criticidad. - RFP, pilotos y gobierno de costes.	- Extensión de evidencias, auditoría interna y métricas. - Consolidación de cartera y revisiones de arquitectura. - Dependencia crítica de ENS/SGSI.	- Optimización recurrente, reporting ejecutivo y mejora. - Revisión de excepciones y control del riesgo residual. - Cierre del ciclo de implementación inicial.
Identidad y acceso	- MFA extendida, PAM inicial y privilegios críticos. - Altas/bajas/modificaciones y revisiones periódicas. - Base de Zero Trust en IT.	- Cuentas de servicio, terceros y accesos remotos controlados. - Refuerzo de trazabilidad y segregación de funciones. - Mejora de autenticación contextual.	- Optimización de revisiones, revocación y evidencias. - Cobertura madura para admins y proveedores. - Integración con autenticación extendida.
Detección y SOC	- Sentinel piloto/arranque, casos priorizados y retención base. - Integración EDR/XDR y telemetría crítica. - MDR/SOC híbrido y cuadros ejecutivos.	- Cobertura ampliada de logs, NDR y normalización. - SOAR inicial para enriquecimiento/ticketing. - Calidad de datos y escalado.	- Optimización de cobertura y automatizaciones aprobadas. - Trazabilidad, reporting y mejora continua. - Soporte a FASE 3.3 sin sustituirla.
Protección y superficie	- EDR/XDR, MDM y baseline de hardening. - WAF/API security y refuerzo web/correo/cloud. - Programa continuo de vulnerabilidades.	- Segmentación IT, control de exposición y refuerzo de red. - Patching y configuraciones con mayor cobertura. - Protección de datos cifrada más.	- Optimización de excepciones y reducción de superficie. - Revisión continua de aplicaciones y dependencias. - Mejora continua de cobertura.
Continuidad y recuperación	- Backups segregados y restauraciones iniciales probadas. - Capacidades mínimas de recuperación tecnológica. - Dependencias críticas de proveedores.	- Pruebas recurrentes, evidencias y almacenamiento ajustado. - Continuidad de cloud/correo y componentes esenciales. - Mejora robustez frente a ransomware.	- Planificación recurrente de pruebas y mejora. - Revisión de contratos/evidencias de terceros. - Dependencia integrada en operación.
OT y proveedores	- Gobierno de frontera IT/OT y criterios de validación. - Acceso remoto industrial controlado. - Inventario prudente y coordinación con Operaciones.	- Segmentación progresiva y monitorización pasiva selectiva. - Ventanas de intervención y cambios validados. - Requisitos a proveedores industriales.	- Optimización con lecciones aprendidas y trazabilidad. - Madurez en terceros y acceso remoto auditado. - Mejora prudente sin comprometer operabilidad.

Figura 11. Roadmap tecnológico a 3 años con secuencia de implantación y referencia al presupuesto trienal orientativo.

Tabla 16. Presupuesto trienal orientativo por líneas de inversión (rangos estimados).

Línea presupuestaria	Año 1 k€	Año 2 k€	Año 3 k€	Total 3 años k€
Gobierno, ENS, SGSI, auditoría y PMO	90-140	70-110	60-90	220-340
IAM/MFA/PAM y ciclo de vida de identidades	170-260	120-190	100-160	390-610
SIEM Microsoft Sentinel, MDR/SOC y retención	230-360	280-430	300-480	810-1.270
SOAR Microsoft Sentinel/Logic Apps	20-40	90-150	90-170	200-360
EDR/XDR, MDM y prevención de código malicioso	190-290	170-260	160-240	520-790
Vulnerabilidades, WAF/API, hardening y cloud/correo	190-300	220-330	180-280	590-910
Cifrado, KMS/secretos y protección de datos	90-150	80-130	70-110	240-390
Backups, recuperación, almacenamiento y pruebas	190-300	160-250	130-210	480-760
Frontera IT/OT, acceso remoto industrial y monitorización prudente	110-190	160-260	140-230	410-680
Formación, pruebas, integración y contingencia	90-140	80-130	70-120	240-390
TOTAL estimado	1.380-2.190	1.420-2.230	1.300-2.080	4.100-6.500

Las cifras son rangos de planificación, no ofertas ni compromisos de gasto. Incluyen licencias, servicios gestionados, integración, consultoría, soporte, despliegue inicial, almacenamiento y pruebas de recuperación proporcionadas al alcance. No incluyen inversiones OT de planta no inventariadas, renovación masiva de infraestructura, costes de personal interno ni sobrecostes regulatorios específicos. Cada anualidad debe aprobarse por hitos: inventario validado, piloto, RFP, arquitectura aceptada, evidencias de implantación y revisión de riesgo.

Anexo V. Respuesta a ciberataques

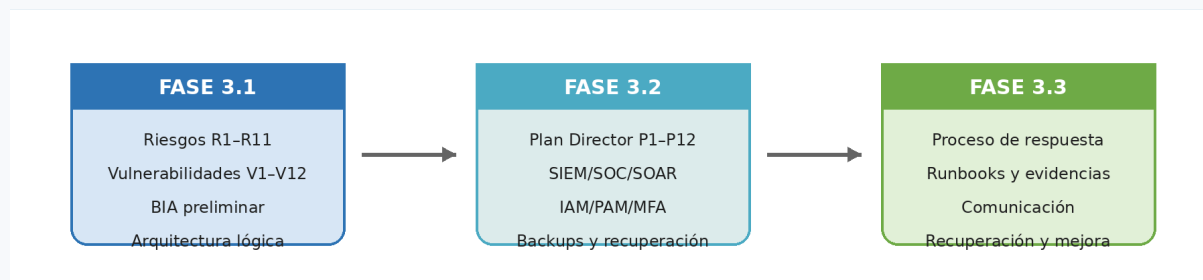
1. Objeto, alcance y entradas de la FASE 3.3

El Anexo V desarrolla el proceso de respuesta a ciberataques de ACME Waters. Su objetivo es convertir la arquitectura tecnológica y el análisis de riesgos de los apartados anteriores en procedimientos operativos, criterios de escalado, servicios de respuesta, recursos, evidencias y runbooks ejecutables bajo control humano.

El alcance incluye incidentes que afecten al CPD crítico, identidad, aplicaciones públicas, cloud/correo, teletrabajo, proveedores críticos, frontera IT/OT, continuidad operacional, datos personales, backups, gestión de vulnerabilidades y recuperación tecnológica. En el ámbito OT, el documento opera sobre dominios funcionales prudentes —frontera IT/OT, DMZ OT, acceso remoto industrial, jump server, proveedores OT y monitorización pasiva— sin inventar fabricantes, PLC, SCADA, DCS, protocolos ni topologías reales de planta. Los indicadores, TTP, IOC, CVE y señales de inteligencia se emplean para clasificación, detección, priorización y evidencias defensivas, no para reproducir explotación, post-explotación o pruebas agresivas contra producción. El documento se formula como documento operativo de trabajo y no convierte MTD/RTO/RPO preliminares en compromisos aprobados. En materia de securización y acceso, las acciones sobre identidad, MFA, PAM, VPN/ZTNA, proveedores, guardia TI ampliada y cuentas de servicio se tratan como medidas de reducción de riesgo sujetas a autorización, registro, mínimo privilegio y reversibilidad, no como garantías absolutas de ausencia de compromiso. La coherencia con SGSI, ENS, protección de datos y obligaciones sectoriales se documenta como criterio de gobierno y evidencia de diligencia, sin sustituir la validación formal por Jurídico, DPD, Cumplimiento o los órganos competentes.

Tabla 17. Entradas documentales y marcos de referencia utilizados por FASE 3.3.

Entrada consolidada	Uso en FASE 3.3	Condición de uso
FASE 3.1 · Riesgos R1-R11 y vulnerabilidades V1-V12	Define los escenarios de ataque y prioriza los runbooks: ransomware, identidad, CPD, web/API, proveedor, visibilidad, vulnerabilidades, IT/OT, teletrabajo, cloud/correo, phishing, DDoS y continuidad.	Mantener la trazabilidad activo → vulnerabilidad → amenaza → riesgo → runbook → control → evidencia, sin convertir la respuesta en un nuevo análisis de riesgos.
FASE 3.1 · BIA preliminar	Aporta hipótesis de criticidad, MTD/RTO/RPO y dependencias para priorizar contención, recuperación, comunicación y canales alternativos durante incidente.	No convertir los valores en compromisos aprobados sin talleres de negocio, TI, Operaciones, DPD y proveedores; registrar siempre si se usan como hipótesis de priorización.
FASE 3.1 · Arquitectura de red	Sirve para definir zonas de contención, rutas de escalado, fuentes de logs y límites IT/OT.	No detallar reglas de firewall ni asumir equipamiento no inventariado. En OT, tratar DMZ, zonas, conductos, accesos remotos y sensores como referencias funcionales hasta disponer de inventario y validación de Operaciones.
FASE 3.2 · Plan Director P1-P12	Traduce capacidades tecnológicas en servicios de respuesta: SIEM, SOC/MDR, SOAR, EDR/XDR, WAF/API, IAM/PAM/MFA, bastión, VPN/ZTNA, backups, proveedores e IT/OT.	No adelantar compras ni licencias no validadas; usar capacidades como objetivo operativo. Las capacidades de acceso se utilizarán bajo mínimo privilegio, aprobación y registro, sin asumir que la presencia de MFA, PAM o ZTNA elimina el riesgo de compromiso.
FASE 3.2 · SIEM/SOAR	Microsoft Sentinel como SIEM principal y Sentinel Automation/Logic Apps como SOAR inicial para enriquecimiento, ticketing, evidencias y notificaciones.	Toda acción crítica requiere aprobación humana; OT queda excluida de contención automática. El SOAR puede documentar, enriquecer y solicitar aprobación, pero no ejecutar cambios, bloqueos, reinicios ni escaneos sobre producción OT.
FASE 1 / FASE 2 · Gobierno, políticas y SGSI	Aporta criterios de gobierno, responsabilidades, política de seguridad, gestión documental, mejora continua y relación entre riesgos, controles y evidencias.	No sustituir políticas aprobadas ni crear obligaciones nuevas sin aprobación formal; registrar qué control, responsable y evidencia soportan cada decisión de respuesta.
Marco normativo y de cumplimiento	ENS, RGPD/LOPDGDD, NIS/NIS2, contratos, obligaciones sectoriales y guías de buenas prácticas orientan comunicaciones, evidencias, diligencia y escalado.	Usar como referencia prudente. La decisión sobre notificación, comunicación externa o interpretación legal corresponde a DPD/Jurídico/Cumplimiento y órganos competentes.

FIGURA 1. Encaje del Plan de Acción.

2. Principios rectores de respuesta

Tabla 18. Principios rectores de respuesta a ciberataques.

Principio	Aplicación
Autoridad definida	Todo incidente debe tener responsable de decisión, responsable técnico y canal de comunicación. La velocidad sin autoridad genera caos.
Seguridad de personas y continuidad del agua	En OT y servicios esenciales prevalecen safety, disponibilidad, calidad del agua, medioambiente y continuidad operacional sobre controles intrusivos.
Evidencia antes que intuición	Las decisiones se registran con hora, responsable, evidencia, hipótesis, acción tomada y resultado.
Mínima acción suficiente	La contención debe reducir daño sin destruir evidencias ni comprometer la recuperación.
Aprobación humana en acciones críticas	Aislamientos masivos, bloqueo de cuentas privilegiadas, cambios de firewall, borrado, restauración y acciones OT requieren aprobación explícita.
Separación IT/OT	No hay contención automática desde IT hacia OT. Toda intervención industrial requiere validación de Operaciones, ventana, reversibilidad y criterio de parada.
Comunicación controlada	La información del incidente se etiqueta, limita y registra. No se difunde por canales no autorizados.
Recuperación limpia	Volver a servicio exige erradicación razonable, restauración o reconstrucción desde origen confiable, comprobación de integridad, prueba funcional, validación del dueño de servicio y autorización de retorno.
Lecciones aprendidas	Cada incidente debe producir mejoras: controles, detecciones, runbooks, inventario, formación o contratos.
Preservación forense proporcional	Antes de borrar, reinstalar, aislar de forma irreversible o restaurar, se debe valorar qué evidencias volátiles o no volátiles pueden perderse y registrar la justificación de la acción.
Hechos, hipótesis e inferencias separadas	Los informes de incidente no deben afirmar causalidad, autoría, exfiltración o alcance definitivo sin evidencias suficientes; cada conclusión debe distinguir lo observado, lo inferido y lo pendiente de confirmar.
BIA como hipótesis de priorización	MTD/RTO/RPO preliminares orientan secuencia y comunicación, pero no son SLA ni compromisos hasta que PCN/PCTIC/PRD los aprueben y prueben.

Principio	Aplicación
Retorno controlado	La recuperación no se declara completa sin evidencias de restauración limpia, monitorización reforzada, aceptación de riesgo residual y validación de negocio u Operaciones cuando aplique.
No intrusión OT en producción	No se ejecutan escaneos activos, fuzzing, explotación, reinicios, parches, despliegue de agentes, cambios de configuración o capturas intrusivas sobre OT de producción como parte de la respuesta salvo procedimiento técnico aprobado por Operaciones, ventana controlada, criterio de parada, reversibilidad y justificación documentada.
Hipótesis OT funcionales y prudentes	Las referencias a DMZ OT, jump server industrial, acceso remoto, sensores pasivos o proveedores OT describen dominios funcionales de respuesta. No implican fabricantes, PLC, SCADA, DCS, protocolos, direcciones ni topologías de planta no inventariadas.
TTP e inteligencia con finalidad defensiva	MITRE ATT&CK, ATT&CK for ICS, IOC, CVE, avisos de fabricante y CSIRT se usan para clasificar, detectar, buscar alcance y mejorar controles; no para documentar PoC, explotación, evasión o post-explotación ofensiva.
Priorización por exposición, explotación e impacto	La urgencia se determina por activo expuesto, criticidad para servicio esencial, explotación conocida, facilidad de propagación, privilegios, datos personales, proveedor, IT/OT y continuidad operacional.
Controles de acceso como reducción de riesgo	MFA, PAM, ZTNA, bastión, mínimo privilegio y revisiones de acceso reducen exposición y trazabilidad de abuso, pero no garantizan por sí solos que una cuenta, sesión, token o proveedor no estén comprometidos.
Acceso remoto acotado y verificable	VPN/ZTNA no se describe como acceso plano a la red interna. Debe conceder acceso por identidad, dispositivo, postura, aplicación o segmento autorizado, con registro, caducidad y capacidad de revocación.
Guardia TI ampliada bajo control	La disponibilidad ampliada de TI durante incidente requiere guardia autorizada, canal fuera de banda, PAM/bastión, MFA, aprobación, registro de sesión y revisión posterior de las acciones realizadas.
Terceros y cuentas no personales gobernadas	Proveedores, integraciones, cuentas de servicio, API y cuentas break-glass deben ser nominativas o trazables a responsable, temporales cuando sea posible, auditables, recertificables y revocables sin dejar huérfanos operativos.
Gobierno SGSI integrado	La respuesta debe alimentar el SGSI: riesgos, controles, evidencias, excepciones, aceptación de riesgo residual, acciones correctivas y revisión por la dirección cuando aplique.
Cumplimiento prudente	ENS, RGPD/LOPDGDD, NIS/NIS2 y contratos se tratan como criterios de diligencia, comunicación y evidencia; no como asesoramiento legal cerrado ni como sustituto de validación especializada.
Trazabilidad de decisión	Toda decisión relevante debe enlazar riesgo, activo, control, evidencia, responsable, aprobación, resultado y mejora posterior.
Mejora continua verificable	Las lecciones aprendidas deben traducirse en acciones con propietario, plazo, prioridad, evidencia de cierre y revisión de efectividad.

3. Marco metodológico y ciclo de vida

La FASE 3.3 combina el ciclo operativo clásico de respuesta a incidentes con la estructura de gobierno, SGSI, gestión de riesgos y mejora continua ya adoptada por ACME Waters. Para mantener coherencia con FASE 1 y FASE 3.2, el proceso se alinea con NIST CSF

2.0, NIST SP 800-61r3, ENISA/CSIRT, ENS, ISO/IEC 27035, ISO/IEC 27005, MITRE ATT&CK, OWASP y referencias OT prudentes. Las referencias normativas se aplican como marcos de gobierno, diligencia y documentación, no como dictamen jurídico ni determinación final de obligaciones.

Criterio metodológico. El ciclo se expresa en fases operativas porque facilita runbooks y entrenamiento: preparación; detección y análisis; triaje y declaración; contención; erradicación; recuperación; cierre; lecciones aprendidas. A efectos de gobierno, estas fases se mapean a Gobernar/Identificar/Proteger/Detectar/Responder/Recuperar.

Tabla 19. Ciclo de vida operativo de respuesta.

Fase operativa	Contenido mínimo	Relación CSF 2.0
Preparación	Políticas, contactos, roles, herramientas, fuentes de log, acceso de emergencia, runbooks, evidencias, pruebas y canales fuera de banda.	GOV, ID, PR
Detección y análisis	Recepción de alerta, validación, enriquecimiento, búsqueda de alcance, preservación inicial y análisis de impacto.	DE, RS
Triage y declaración	Clasificación, severidad, asignación de responsable, ticket maestro, comunicación inicial y decisión de escalar.	RS
Contención	Acciones para limitar propagación o daño, con aprobación humana cuando afecte a servicios críticos, privilegios o OT.	RS
Erradicación	Eliminación de causa raíz, corrección de vulnerabilidades, rotación de credenciales, limpieza y verificación.	RS, PR
Recuperación	Restauración limpia, validación funcional, retorno gradual y monitorización reforzada.	RC
Cierre y aprendizaje	Informe, cronología, evidencias, impactos, causas, controles fallidos, mejoras y actualización de runbooks.	GOV, ID, PR, DE, RS, RC

FIGURA 2. Ciclo de vida de respuesta de ACME Waters.

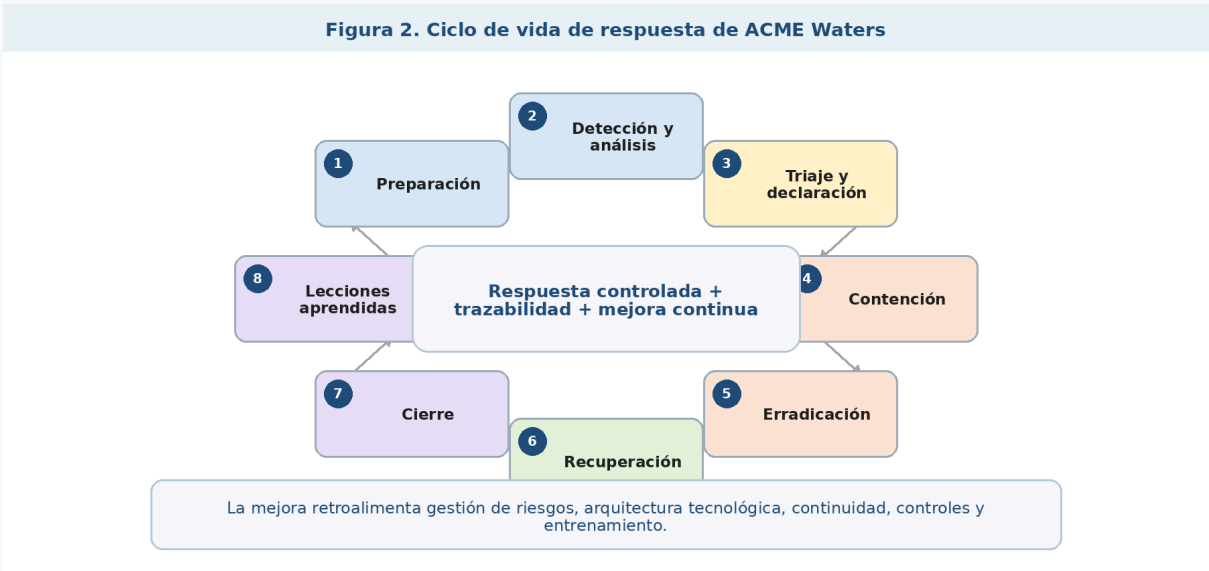


Tabla 20. Hitos de control del ciclo de vida de respuesta.

Hito	Decisión que debe quedar cerrada	Salida mínima documentada
Preparación	¿Existe responsable, canal, contacto y acceso a evidencias?	Ficha de guardia, fuentes de log, contactos, credenciales de emergencia y repositorio seguro.
Detección / análisis	¿El evento es falso positivo, evento de seguridad o incidente?	Ticket inicial, evidencias originales, severidad inicial y criterio de clasificación.
Triaje / declaración	¿Se activa CSIRT, Incident Commander, DPD/Jurídico, Operaciones o Comité de Crisis?	Acta breve de declaración, responsables, canal TLP y frecuencia de situación orientativa.
Contención	¿Qué acción mínima reduce propagación sin destruir evidencias ni afectar OT/continuidad?	Decisión aprobada, alcance, rollback, responsable y resultado de la contención.
Erradicación	¿Se ha eliminado causa razonable, persistencia y vector inicial?	Hipótesis técnica, acciones ejecutadas, validaciones y riesgos remanentes.
Recuperación	¿El servicio puede volver con seguridad y validación funcional?	Evidencia de restauración/reconstrucción, validación del dueño de servicio y monitorización reforzada.
Cierre / mejora	¿Qué ha ocurrido, qué faltó y qué debe cambiar?	Informe post-incidente, lecciones aprendidas, acciones de mejora y actualización de riesgos/runbooks.

Tabla 21. Encaje metodológico de gobierno, cumplimiento y trazabilidad.

Ámbito	Uso dentro de FASE 3.3	Límite / dependencia
Fases previas del Plan Integral	Mantener continuidad metodológica con identificación de riesgos, controles, arquitectura, servicios y evidencias.	No reabrir el análisis de riesgos ni rediseñar arquitectura; registrar dependencias o lagunas para revisión posterior.
SGSI / ISO/IEC 27001	Asegurar que incidentes, acciones correctivas, gestión documental, responsabilidades y revisión de efectividad quedan trazables.	No declarar conformidad certificable ni madurez SGSI sin auditoría o evaluación específica.
ISO/IEC 27005 / gestión de riesgos	Relacionar incidente con riesgo, propietario, tratamiento, control, riesgo residual y aceptación documentada.	No recalcular riesgos de forma completa durante la crisis; registrar hipótesis y remitir a revisión post-incidente.
ENS y obligaciones sectoriales	Apoyar clasificación, evidencias, continuidad, notificación interna, medidas de protección y diligencia operativa.	No sustituir la evaluación formal de categoría, cumplimiento o reporte por los responsables competentes.
RGPD/LOPDGDD y datos personales	Activar DPD/Jurídico cuando exista acceso, exposición, pérdida, alteración o indisponibilidad de datos personales.	No afirmar brecha notificable o no notificable sin evaluación documentada de DPD/Jurídico.
NIS/NIS2 y cadena de suministro	Coordinar incidentes significativos, proveedor crítico, continuidad de servicio esencial y evidencias de terceros.	No asumir aplicabilidad, plazos o autoridad competente sin validación jurídica y de cumplimiento.

4. Organización, autoridad y roles

La respuesta debe operar con doble plano: gobierno de crisis y ejecución técnica. El gobierno decide prioridad, comunicación, aceptación de riesgo y escalado directivo. La ejecución técnica valida hechos, contiene, preserva evidencias y recupera servicios. Esta separación evita que el SOC tome decisiones de negocio o que dirección ordene acciones técnicas sin conocer impacto.

Tabla 22. Organización de respuesta a incidentes.

Rol / célula	Responsabilidad principal	Participantes
Comité de Crisis Ciber	Activar dirección estratégica ante S3/S4, priorizar servicios, aprobar comunicación externa, aceptar riesgos excepcionales.	Presidencia/Alta Dirección, CISO/RSI, CIO/DIS, Operaciones, Jurídico/DPD, Comunicación, Continuidad.
Incident Commander	Dirigir el incidente, mantener cronología, convocar roles, aprobar plan operativo y coordinar situación.	CISO/RSI o delegado designado según severidad.
Líder técnico de respuesta	Coordinar tareas técnicas en SIEM, EDR, red, cloud, identidad, aplicaciones y recuperación.	DIS/CIO o responsable técnico designado.
SOC/MDR	Monitorización, triage, enriquecimiento, búsqueda de alcance, alertas, tickets, reporting y soporte 24x7 según contrato.	SOC interno + proveedor MDR.
Equipo CSIRT operativo	Respuesta técnica transversal, coordinación de evidencias, runbooks, investigación y cierre.	DC, DIS, SOC, Forense, Continuidad y especialistas por dominio.
Operaciones OT	Validar cualquier acción en instalaciones, frontera IT/OT, acceso remoto industrial, continuidad operacional y recuperación OT.	Responsables de Operaciones e instalaciones.
Forense/Evidencias	Preservar evidencias, hashes, cadena de custodia, adquisición, timeline y soporte a informe.	Especialista forense o proveedor autorizado.
Legal/DPD/Cumplimiento	Evaluar datos personales, notificaciones regulatorias, contratos, cadena de suministro, ENS/NIS2 y comunicaciones formales.	DPD, Jurídico, Secretaría del Consejo.
Comunicación	Preparar mensajes internos/externos aprobados, notas a abonados, guion de atención y coordinación con dirección.	Comunicación corporativa + Comité de Crisis.
Continuidad/Recuperación	Priorizar restauración, activar canales alternativos, coordinar BIA/PCN/PCTIC/PRD y evidencias de recuperación.	Responsable continuidad + TI + Operaciones.
Proveedor crítico	Aportar información, logs, estado de servicio, acciones correctoras, evidencias, contactos y plan de recuperación.	CALLMATIC, cloud/correo, Servired, frontales, proveedores OT u otros según incidente.
Responsable SGSI / gobierno de seguridad	Mantener coherencia con políticas, riesgos, controles, evidencias, acciones correctivas, revisión de efectividad y mejora continua.	CISO/RSI o función delegada de gobierno de seguridad.
Propietario de riesgo / dueño de servicio	Validar criticidad, impacto, recuperación, aceptación de riesgo residual y cierre de acciones que afecten al servicio.	Responsable del proceso o servicio afectado, con apoyo de TI, Operaciones y Continuidad.
Cumplimiento / ENS / relación institucional	Coordinar evidencias de diligencia, requisitos sectoriales, relación con órganos internos y preparación de información para autoridades si procede.	Cumplimiento, Secretaría, Jurídico, DPD y CISO/RSI según el caso.

Tabla 23. RACI operativo de decisiones críticas.

Decisión / actividad	CISO/RSI	DIS/CIO	SOC/MDR	Operaciones OT	DPD/Jurídico	Comunicación	Proveedor
Declarar incidente S3/S4	A	C	C	C	C	I	I
Aislar endpoint corporativo	C	A/R	R	I	I	I	I
Deshabilitar cuenta privilegiada	A	R	C	I	I	I	I
Bloquear regla de firewall IT	C	A/R	C	I	I	I	I
Contener flujo IT/OT	A	C	C	A/R	I	I	C
Restaurar servicio crítico	A	R	C	C	I	I	C
Comunicar a abonados o medios	A	I	I	C	C	R	I
Evaluar notificación de brecha de datos	A	C	C	I	R	C	I
Cerrar incidente	A/R	C	C	C	C	I	C
Activar guardia TI ampliada	A	R	C	I	I	I	I
Conceder o reactivar acceso de proveedor	A	R	C	C	C	I	R/C
Rotar secreto de cuenta de servicio	A	R	C	I	I	I	C
Restituir privilegios administrativos	A	R	C	I	I	I	I
Aceptar riesgo residual	A	C	I	C	C	I	C
Abrir acción de mejora SGSI	A/R	C	C	C	C	I	C
Validar comunicación regulatoria	C	I	I	C	A/R	C	I

Regla de autoridad. Leyenda RACI: R = ejecuta; A = aprueba o asume responsabilidad final; C = consulta obligatoria; I = informado. En decisiones OT se requiere aprobación de Operaciones aunque la alerta proceda de IT o SOC. En accesos privilegiados, cuentas de servicio, guardia ampliada y proveedores, la aprobación debe quedar vinculada al ticket maestro, ventana, finalidad, responsable, caducidad y evidencia de revisión posterior.

5. Servicios y recursos de respuesta

La respuesta a ciberataques se apoya en las capacidades decididas en FASE 3.2 y en evidencias definidas en FASE 3.1. Seguidamente se describen como servicios objetivo o servicios mínimos a consolidar; su disponibilidad real debe validarse por inventario, contratos y pruebas.

Tabla 24. Servicios y recursos de respuesta.

Servicio / recurso	Uso en respuesta	Condición mínima
SIEM Microsoft Sentinel	Alerta, correlación, búsqueda, investigación, retención, reporting y reconstrucción temporal de incidentes.	Fuentes críticas definidas, eventos brutos y normalizados, NTP, retención, permisos, trazabilidad de consultas y control de costes.
SOC híbrido/MDR	Triage, investigación inicial, escalado, vigilancia extendida, hunting y coordinación de evidencias.	Contrato, matriz de severidad, horarios, contactos, alcance técnico, criterios de recalificación y registro de fuentes consultadas.
SOAR Sentinel Automation / Logic Apps	Enriquecimiento, ticketing, recopilación de evidencias, notificaciones y tareas repetibles no invasivas.	Playbooks probados, permisos mínimos, aprobación humana, registro de acciones y separación entre lectura, aprobación y ejecución.
Ticketing / gestión de casos	Ticket maestro, subtarefas, evidencias, decisiones, severidad, fuentes consultadas, estado y cierre.	Campos mínimos, retención, acceso restringido, export de informe y trazabilidad alerta-SIEM/SOC-runbook-lección aprendida.
EDR/XDR y MDM	Visibilidad endpoint, árbol de procesos, aislamiento controlado, recolección de telemetría, postura de dispositivo y movilidad.	No aislar equipos críticos sin validar impacto; conservar evidencias y registrar acciones automáticas o manuales.
NDR/IDS/NetFlow/DNS logs	Detectar anomalías, C2, exfiltración, lateralidad, saltos entre segmentos y desviaciones de DNS/proxy/VPN mediante visibilidad de red. En OT se limita a telemetría pasiva o registros ya disponibles.	Sensores pasivos en OT, sin interacción con activos de control; registrar NAT/XFF, puertos, zonas funcionales y límites de visibilidad; proteger capturas con datos sensibles y validar cualquier cambio físico o lógico con Operaciones.
WAF/API security/CDN	Visibilidad y mitigación de ataques web/API, DDoS aplicativo, abuso de autorización y explotación de aplicaciones públicas.	Logs de request, cabeceras, endpoint, usuario/sesión, acción WAF/CDN, pruebas, rollback y validación de negocio.
IAM/MFA/PAM/bastión	Revocación, bloqueo, rotación, acceso de emergencia, sesión administrativa, cuentas privilegiadas, cuentas de servicio, proveedores, guardia TI ampliada y trazabilidad de cambios.	Cuentas nominales y break-glass controladas, MFA, PAM/bastión cuando exista, registro de sesión, aprobación, caducidad, revisión de grupos privilegiados, recertificación y procedimiento de revocación.
Backup/DR	Restauración limpia, recuperación de servicios base, evidencias de integridad, verificación de puntos de restauración y detección de abuso de repositorios.	Backups inmutables o aislados cuando estén disponibles, copias fuera de dominio comprometido, pruebas periódicas de restauración, logs de jobs/accesos/snapshots y prohibición de restaurar sobre entorno comprometido sin erradicación.
Herramientas forenses	Adquisición de logs, imágenes, memoria, PCAP, hash, timeline y custodia.	Uso por personal autorizado; no alterar original.
Canales fuera de banda	Comunicación de crisis si correo/identidad están comprometidos, coordinación de continuidad y soporte al retorno controlado.	Listas actualizadas, pruebas, árbol de llamadas, responsables de activación, repositorio seguro y guiones de atención mínima.

Servicio / recurso	Uso en respuesta	Condición mínima
Proveedores críticos	Soporte, evidencias, recuperación, notificación, continuidad, canales alternativos, estado de servicio, escalado y gestión de accesos de tercero.	Contactos, SLA/OLA, cláusulas, derecho de auditoría, pruebas conjuntas, evidencias de recuperación, cuentas nominativas o trazables, MFA/PAM/bastión cuando aplique, caducidad y criterios de reactivación/revocación de accesos.
Gobierno SGSI / GRC	Trazabilidad de riesgos, controles, excepciones, riesgos residuales, acciones correctivas, evidencias de cierre y revisión de efectividad.	Repositorio autorizado, propietarios asignados, control de versiones, acceso restringido y enlace con ticket maestro e informe post-incidente.
Cumplimiento / DPD / Jurídico	Evaluación prudente de obligaciones regulatorias, datos personales, ENS/NIS/NIS2, contratos, comunicaciones y relación con autoridades si procede.	Activación temprana en S3/S4 o datos personales; separación entre hechos técnicos, hipótesis y conclusiones legales.

Tabla 25. Requisitos mínimos de visibilidad y calidad de logs.

Dominio	Campos mínimos	Controles de calidad y custodia
Identidad / IAM / MFA / PAM	Marca temporal con zona horaria, usuario unívoco, origen, destino, resultado MFA, cambio de privilegio, sesión privilegiada, aprobación, cuenta de servicio/API, break-glass, proveedor si aplica y tipo de evento.	Sincronización NTP, retención suficiente, revisión de grupos privilegiados, cuentas nominales, recertificación, caducidad de accesos temporales y preservación de grabaciones PAM si existen.
Endpoint / EDR / XDR / MDM	Host, usuario, proceso, ruta, hash, comando observado, conexión de red, acción tomada, postura del dispositivo y estado de cifrado.	No limpiar antes de preservar metadatos; registrar cuarentena/aislamiento, política aplicada y limitaciones de dispositivos fuera de control.
Red / NDR / firewall / DNS / proxy / VPN	IP origen/destino real, NAT/XFF, protocolo, puerto, dominio, URL o categoría, flujo, zona, regla, volumen, identidad asociada, dispositivo y política VPN/ZTNA aplicada.	Centralización, integridad, cifrado en tránsito/reposo y custodia. VPN/ZTNA debe evidenciar aplicación, segmento o recurso autorizado, no acceso plano. En OT se usarán sensores pasivos y no capturas intrusivas sin Operaciones.
WAF / API / aplicación	Aplicación, endpoint, método, código, usuario/sesión, request ID, acción WAF/CDN, error, payload indicador y versión/despliegue.	Evitar recopilar más datos personales de los necesarios; preservar logs antes de rotación y mantener trazabilidad con cambios de configuración.
Cloud / correo / SaaS	Auditoría de acceso, cabeceras, reglas inbox, forwarding, OAuth consent, compartición, descargas, DLP, eDiscovery y permisos.	Exportación autorizada, minimización de datos personales, retención/licenciamiento verificado y separación entre buzón comprometido y dato exfiltrado.
CPD / backups / DR	Disponibilidad de servicios base, AD/DNS/NTP, almacenamiento, jobs, snapshots, repositorio, credenciales, errores e integridad de copia.	No sobrescribir evidencias; diferenciar evidencia de ataque de evidencia de restauración y conservar prueba de recuperación limpia.
OT / DMZ OT / jump server	Acceso remoto industrial, bastión, VPN, MFA, ventana, aprobación, destino funcional, transferencia, historian/intercambio, alertas pasivas y testimonio de Operaciones cuando aplique.	Sin escaneo activo, sin contención automática y sin despliegue intrusivo. Registrar validación de Operaciones, ventana, criterio de parada, reversibilidad y límite de la hipótesis OT utilizada.

Dominio	Campos mínimos	Controles de calidad y custodia
Proveedor	Cronología, servicio afectado, cuenta nominativa o responsable trazable, API/VPN/ZTNA, IPs, IOCs, acciones, aprobaciones, ventana, limitaciones, contacto responsable y estado de recuperación.	Identificar la evidencia como aportada por tercero, contrastarla con logs internos, registrar lagunas contractuales o de retención y documentar caducidad, revocación y recertificación del acceso.

6. Taxonomía, severidad y declaración de incidente

La taxonomía permite clasificar de forma homogénea alertas, incidentes y crisis. La severidad no depende solo de la técnica observada: se calcula por alcance, criticidad del activo, impacto operativo, datos personales, posibilidad de propagación, IT/OT, proveedores, visibilidad y presión regulatoria.

Tabla 26. Taxonomía de incidentes ACME Waters.

Clase	Descripción	Riesgos vinculados
IR-01 Ransomware / malware destructivo	Cifrado, extorsión, wiper, borrado de copias, propagación o precursor confirmado.	R1, R3, R6, R11
IR-02 Identidad y privilegios	Phishing, sesión robada, abuso de VPN/ZTNA, cuenta privilegiada, cuenta de servicio, AD/MFA/PAM.	R2, R9, R10
IR-03 Aplicaciones públicas y API	Explotación web, abuso de autorización, exfiltración, subida maliciosa, caída de Oficina Virtual/AQUAPP/API.	R4, R7
IR-04 Cloud/correo/BEC	Forwarding sospechoso, OAuth malicioso, buzón comprometido, fuga de datos, BEC, colaboración cloud.	R10, R2
IR-05 Proveedor y cadena de suministro	Incidente en CALLMATIC, Servired, cloud, web front, proveedor OT o acceso tercero.	R5, R2, R11
IR-06 IT/OT e industrial	Flujo no autorizado o no documentado en frontera IT/OT, acceso remoto industrial fuera de ventana, alerta en DMZ OT/jump server, intervención no coordinada, anomalía observada por monitorización pasiva o riesgo operacional. No presupone topología real de planta.	R8
IR-07 CPD / disponibilidad	Caída de servicios base, almacenamiento, red, AD/DNS, virtualización o plataforma crítica.	R3, R11
IR-08 Vulnerabilidad crítica activa	CVE explotada o explotable en activo expuesto, zero-day o exposición sin parche inmediato.	R7, R4, R8
IR-09 Teletrabajo / endpoint	Dispositivo perdido, no gestionado, EDR alertando, sesión remota anómala o conexión fuera de perfil.	R9, R2
IR-10 Datos personales / fuga	Acceso no autorizado, exfiltración, exposición pública o pérdida de soporte con datos personales.	R4, R10, R5
IR-11 DDoS / indisponibilidad externa	Ataque contra web, API, portal, DNS, CDN, frontales o pasarela que afecta disponibilidad.	R3, R4, R5

Tabla 27. Matriz de severidad.

Nivel	Criterio	Respuesta mínima
S0 · Evento	Alerta o desviación sin evidencia de compromiso.	Ticket de seguimiento; no activar CSIRT.
S1 · Bajo	Actividad sospechosa limitada, sin impacto operativo ni datos afectados, controlada por SOC/DIS.	Triage, documentación y cierre con recomendación.
S2 · Medio	Compromiso o vulnerabilidad en activo no crítico, alcance limitado, sin impacto en servicio esencial.	Activar líder técnico; informar CISO/RSI; contención estándar.
S3 · Alto	Activo crítico afectado, posible propagación, credenciales privilegiadas, datos personales, proveedor crítico o indisponibilidad relevante.	Activar CSIRT, Incident Commander, DPD/Jurídico según caso y seguimiento directivo.
S4 · Crítico / Crisis	Impacto real o probable en continuidad del agua, CPD crítico, identidad central, OT, ransomware extendido, fuga significativa, presión pública/regulatoria o imposibilidad de recuperar.	Comité de Crisis Ciber, dirección, comunicación controlada, continuidad y proveedores críticos.

Tabla 28. Criterios de escalado, crisis y desescalado.

Criterio	Activación mínima	Autoridad / validación
S0 → S1	Alerta repetida, nueva fuente de evidencia o desviación no explicada.	SOC/MDR o DIS documenta seguimiento.
S1 → S2	Compromiso limitado, activo no crítico afectado, usuario o endpoint confirmado.	Líder técnico informa a CISO/RSI.
S2 → S3	Activo crítico, credenciales privilegiadas, proveedor crítico, datos personales probables, propagación o indisponibilidad relevante.	Incident Commander activa CSIRT y consulta a DPD/Jurídico, Operaciones o proveedor según dominio.
S3 → S4	Impacto real o probable en CPD crítico, identidad central, operación esencial, OT, recuperación, fuga significativa, extorsión pública o presión regulatoria/mediática.	Comité de Crisis Ciber, Dirección y responsables de negocio/Operaciones.
Crisis ciber	Necesidad de decisiones ejecutivas, comunicación externa, continuidad, coordinación multiárea o aceptación excepcional de riesgo.	Comité de Crisis Ciber; cualquier comunicación externa requiere validación formal.
Desescalado	Contención efectiva, alcance estabilizado, evidencias preservadas, recuperación validada y ausencia de nuevas señales relevantes.	Incident Commander propone; CISO/RSI y dueño de servicio validan; OT valida si aplica.

Regla de recalificación. Una alerta puede subir de severidad si aparecen nuevos hechos: expansión, privilegios, exfiltración, impacto en datos personales, afectación OT, indisponibilidad o proveedor crítico. La severidad debe revisarse en cada hito de situación.

Tabla 29. Criterios de priorización de amenazas y vulnerabilidades durante la respuesta.

Factor de priorización	Criterio defensivo	Efecto en respuesta
Exposición	Activo accesible desde Internet, proveedor, VPN/ZTNA, API pública, cloud/SaaS o frontera IT/OT.	Elevar prioridad de triage y búsqueda de alcance; validar propietario y ventana de exposición.
Explotación conocida	Evidencia de explotación activa, campaña, aviso de fabricante/CSIRT, IOC coincidente o patrón observado internamente.	Recalificar severidad aunque no exista impacto confirmado; preservar logs retrospectivos.
Criticidad del activo	CPD, identidad central, backups, Oficina Virtual/AQUAPP/API, atención a abonados, cloud/correo, proveedor crítico u OT.	Escalar a responsable de servicio y continuidad; aplicar BIA como hipótesis de priorización.
Credenciales y privilegios	Cuenta privilegiada, cuenta de servicio, token persistente, MFA fatigado, sesión PAM/VPN o grupo administrativo afectado.	Activar RB-02/RB-12; revocación y rotación con aprobación y trazabilidad.
Propagación o destructividad	Señales de lateralidad, cifrado, wiper, borrado de copias, uso masivo de herramientas administrativas o automatización maliciosa.	Activar CSIRT y contención mínima suficiente; evitar acciones que destruyan evidencias.
Datos personales o exfiltración	Descargas masivas, acceso anómalo a BBDD/API/SaaS, DLP, publicación externa o confirmación de proveedor.	Activar DPD/Jurídico y RB-10; separar indicio de exfiltración de exfiltración confirmada.
Proveedor y cadena de suministro	Incidente notificado por tercero, acceso proveedor anómalo, integración/API/VPN afectada o indisponibilidad contractual.	Activar RB-05; exigir evidencias mínimas y contrastar con telemetría interna.
IT/OT y servicio esencial	Flujo no autorizado, acceso remoto industrial, anomalía pasiva, riesgo para safety, calidad del agua, medioambiente o continuidad operacional.	Operaciones valida cualquier acción; no usar escaneo activo, explotación ni contención automática.
Brecha de visibilidad	Fuentes críticas no disponibles, logs incompletos, falta de NTP, retención insuficiente o inventario no confirmado.	No bajar severidad por ausencia de evidencia; registrar limitación y acción de mejora.

7. Proceso operativo común

Todos los runbooks comparten un proceso operativo mínimo. Las acciones concretas varían, pero la disciplina de registro, autorización y evidencia debe ser la misma.

Tabla 30. Proceso común de gestión de incidente.

Paso	Actividad	Evidencia mínima
1. Recepción	Recibir alerta, llamada, reporte de usuario/proveedor, aviso externo, finding de auditoría o evento SOC.	Ticket preliminar, hora, origen, canal, ID de alerta si existe y fuente que lo dispare.
2. Triage inicial	Validar si es falso positivo, evento, incidente o crisis. Enriquecer con activos, usuario, IP, aplicación, fuentes de log, criticidad y contexto de negocio.	Clasificación, severidad inicial, propietario, fuentes consultadas, evidencias descartadas y lagunas de visibilidad.
3. Ticket maestro	Abrir caso único, enlazar subtickets, fijar responsable de registro cronológico y asociar alertas SIEM/SOC/SOAR.	ID de incidente, línea temporal, repositorio de evidencias, IDs de alerta/playbook y relación con runbook.

Paso	Actividad	Evidencia mínima
4. Preservación inicial	Congelar logs relevantes, exportar evidencias, evitar borrado, capturar estado y registrar hash cuando aplique.	Registro de evidencias y custodia.
5. Declaración	Nombrar Incident Commander y decidir si activa CSIRT, Comité de Crisis, DPD/Jurídico, Operaciones o proveedor.	Acta breve de declaración y canales.
6. Alcance	Determinar activos, cuentas, servicios, segmentos, datos, proveedores, fuentes observadas y posible impacto IT/OT, separando hechos técnicos de hipótesis funcionales de operación.	Mapa de alcance, fuentes revisadas, hipótesis de impacto y brechas de visibilidad.
7. Contención	Aplicar acciones mínimas suficientes, priorizando vida, agua, OT, calidad, medioambiente, continuidad, evidencias y recuperación.	Decisiones aprobadas, alcance, reversibilidad, criterio de parada y resultado.
8. Erradicación	Eliminar causa, corregir vulnerabilidad, rotar secretos, limpiar sistemas, retirar persistencia y cerrar vector.	Plan de erradicación y verificaciones.
9. Recuperación	Restaurar o reconstruir servicio limpio, seleccionar punto de restauración confiable, validar integridad, activar canales alternativos y monitorización reforzada conforme a hipótesis BIA.	Autorización de retorno, evidencia funcional, origen de restauración, pruebas realizadas, responsable de negocio/Operaciones y riesgos residuales.
10. Cierre	Documentar impacto, causa, cronología, controles, costes aproximados si se conocen, lecciones, mejoras, riesgos residuales y trazabilidad riesgo → control → evidencia → decisión → mejora.	Informe final, plan de acciones, actualización de SGSI/riesgos/runbooks y responsable de seguimiento.

Tabla 31. Compuertas forenses antes de acciones destructivas o irreversibles.

Momento	Pregunta de control forense	Registro mínimo
Antes de contener	¿Qué evidencia se perderá o alterará si se ejecuta la acción?	Fuente afectada, evidencia ya adquirida, evidencia pendiente y motivo de urgencia.
Durante contención	¿La acción es reversible, limitada e idempotente?	Responsable, aprobación, alcance, hora, herramienta, resultado y plan de reversión.
Antes de erradicar	¿Se han preservado artefactos suficientes para explicar causa, alcance y vector?	Hashes, logs, muestras seguras, exportaciones, snapshots o justificación de no adquisición.
Antes de recuperar	¿El retorno puede contaminar evidencias, reintroducir la amenaza o restaurar datos inconsistentes respecto al RPO orientativo?	Criterio de limpieza, origen de restauración, hash/verificación, validación funcional, dueño aprobador y riesgo residual.
Antes de cerrar	¿Las conclusiones están separadas en hechos, inferencias, limitaciones y acciones pendientes?	Informe de cierre, línea temporal, evidencias referenciadas y mejoras abiertas.

Tabla 32. Trazabilidad detección-alerta-ticket-cierre.

Momento	Control	Salida esperada
Alerta / reporte	Registrar fuente, ID de alerta, canal, hora, activo/usuario y runbook candidato sin declarar compromiso automáticamente.	Ticket S0/S1 o incidente inicial con evidencia original preservada.
Triage	Contrastar la fuente primaria con al menos una fuente independiente cuando exista: identidad, endpoint, red, aplicación, cloud/correo, proveedor u OT.	Severidad inicial S0-S4, fuentes consultadas, hipótesis, falsos positivos descartados y lagunas de visibilidad.
Escalado / desescalado	Actualizar severidad solo por hechos nuevos: propagación, privilegios, datos personales, proveedor, OT, indisponibilidad o evidencia de contención.	Registro de decisión con responsable, evidencia, motivo, hora y comunicación asociada.
Contención	Vincular cada acción a evidencia suficiente, aprobación humana, alcance, reversibilidad y posible pérdida de evidencias.	Ticket actualizado con acción, resultado, rollback, evidencia preservada y efecto observado.
Cierre	Revisar qué detección funcionó, qué fuente faltó, qué alerta fue ruidosa y qué ajuste se requiere.	Lección aprendida con dueño, fecha objetivo, actualización de runbook/caso de uso y validación en ejercicio o simulación.

Tabla 33. Trazabilidad de gobierno en el cierre del incidente.

Elemento	Contenido mínimo	Salida esperada
Riesgo	Riesgo R1-R11 o riesgo operativo afectado, propietario y criticidad.	Registro de riesgo o referencia de FASE 3.1; no recalcular sin revisión posterior.
Control	Control preventivo, detectivo, correctivo o de recuperación que funcionó, falló o faltó.	Control del Plan Director, política SGSI, medida ENS o salvaguarda documentada.
Evidencia	Fuente, ID, hash si aplica, custodia, limitación y relación con el hecho observado.	Registro de evidencias y ticket maestro.
Decisión	Acción, aprobación, alternativas, riesgo aceptado, reversibilidad y resultado.	Registro de decisión y autoridad responsable.
Mejora	Acción correctiva/preventiva, propietario, prioridad, fecha objetivo y criterio de efectividad.	Plan de mejora SGSI, actualización de runbook o revisión de contrato/proveedor.

FIGURA 3. Flujo operativo de respuesta: Alerta/Reporte → Triage → Ticket → Preservación → Declaración → Contención → Erradicación → Recuperación → Cierre. Compuertas: Dirección, DPD/Jurídico, Operaciones OT y Proveedor.



Criterio TLP. TLP limita la distribución de información durante el incidente; no sustituye clasificación formal, cifrado, custodia de evidencias, secreto profesional ni obligaciones legales.

8. Evidencias, custodia y comunicaciones

8.1 Evidencias y cadena de custodia

La respuesta a incidentes debe preservar evidencias suficientes para reconstruir hechos, justificar decisiones y permitir una investigación posterior. La prioridad operativa puede exigir contención rápida, pero toda acción que pueda alterar evidencias debe quedar registrada con hora, responsable, motivo, evidencia previa disponible y efecto observado. En el documento se adopta un enfoque probatorio mínimo: identificar fuente, adquirir o exportar con método reproducible, calcular hash cuando aplique, registrar custodia, normalizar zona horaria y separar hechos de hipótesis.

Tabla 34. Fuentes de evidencia y cautelas.

Fuente	Contenido esperado	Custodia / cautela
Logs SIEM/Sentinel	Alertas, eventos normalizados, búsquedas, reglas activadas, usuario, IP, activo, hora, origen/destino.	Export firmado o controlado, zona horaria, consulta usada y responsable.
EDR/XDR/MDM	Árbol de procesos, hash, ruta, usuario, red, detección, acción tomada, aislamiento, estado dispositivo.	No borrar artefactos antes de adquirir; registrar acción automática o manual.
Identidad/IAM/PAM	Inicio de sesión, MFA, cambios de grupo, elevación, sesión PAM, revocación, cuentas de servicio.	Correlación temporal con NTP; preservar sesión/grabación si existe.
Cloud/correo	Auditoría, forwarding, reglas inbox, OAuth, consentimientos, accesos, eDiscovery, DLP, retención.	Export bajo permisos autorizados; considerar datos personales.
Aplicación/WAF/API	Requests, códigos, sesión, usuario, payload benigno o indicador, reglas WAF, errores, trazas.	Evitar recopilar más datos personales de los necesarios.
Red/NDR/Firewall/DNS/Proxy	Conexiones, dominios, NetFlow, bloqueos, PCAP si procede, NAT/XFF, puertos.	Cifrado y custodia; PCAP puede contener datos sensibles.
Backups/DR	Fecha, cobertura, integridad, prueba de restauración, resultado, incidencias y autorización de retorno.	Separar evidencias de restauración de evidencias forenses.

Fuente	Contenido esperado	Custodia / cautela
OT/DMZ OT/jump server	Sesiones, accesos remotos, ventana, aprobaciones, logs de jump server, historian/intercambio, firewall industrial, sensores pasivos y validación funcional de Operaciones.	No ejecutar acciones intrusivas, escaneos activos ni reinicios para obtener evidencia. Separar impacto operacional confirmado de hipótesis técnica y conservar autorizaciones.
Proveedor	Notificación, cronología, impacto, activos afectados, acciones, evidencias, SLA, informe post-incidente.	Solicitar evidencia suficiente sin asumir responsabilidad transferida.

Tabla 35. Evidencias mínimas por fuente durante respuesta.

Fuente	Evidencias mínimas	Cautela forense
SIEM / SOAR	ID de incidente, regla o analítica activada, consulta ejecutada, eventos brutos relevantes, normalización aplicada, línea temporal, usuario, activo, IP, Logic App/run ID y acciones automatizadas.	Exportar consulta y resultados; conservar hora, zona horaria, usuario que exporta y versión de regla. No basar conclusiones solo en eventos agregados.
EDR / XDR / MDM	Árbol de procesos, hash de binarios, ruta, usuario, host, comando observado, conexiones, cuarentena/aislamiento, artefactos asociados y política aplicada.	Antes de eliminar o limpiar, capturar metadatos y artefactos. Registrar si una acción automática ha alterado el sistema.
IAM / MFA / PAM	Inicios de sesión, MFA, cambios de grupo, elevación, sesiones privilegiadas, grabaciones PAM si existen, creación/revocación de cuentas, tokens y cambios de credenciales.	No afirmar compromiso de cuenta sin correlación suficiente. Mantener trazabilidad NTP, cuenta, origen, destino y aprobación de bloqueo.
Cloud / correo	Auditoría de acceso, reglas de buzón, forwarding, consentimientos OAuth, cambios de permisos, eDiscovery/export, cabeceras, mensajes sospechosos, trazas de envío y descarga.	La disponibilidad de evidencias depende del modelo de servicio y contrato. Exportar bajo autorización y preservar datos personales según necesidad y minimización.
WAF / API / aplicaciones	Peticiones relevantes, códigos HTTP, origen, sesión, usuario, endpoint, payload registrado, bloqueo/permisión, logs de aplicación, errores y cambios de configuración.	Evitar reproducir explotación destructiva en producción. Preservar logs antes de rotación y no concluir exfiltración solo por petición anómala.
Red / firewall / NDR	Flujos, reglas activadas, PCAP si existe, NetFlow, DNS, proxy, VPN, conexiones laterales, tráfico hacia C2 sospechoso y cambios de reglas.	Indicar si se dispone de paquete completo o solo metadatos. Sincronizar cronología con SIEM y EDR.
Backups / DR	Estado de copias, jobs, errores, accesos al repositorio, cambios de política, intentos de borrado, pruebas de restauración y checks de integridad.	No sobrescribir evidencias de backup afectado. La restauración limpia requiere registrar origen, versión, prueba y responsable.
OT / DMZ OT	Logs de acceso remoto industrial, jump server, historian/intercambio, firewall industrial, cambios de configuración autorizados, alertas pasivas, testimonios de Operaciones, ventana, criterio de parada y reversibilidad.	Sin contención automática ni escaneo activo. Preservar sin afectar safety, disponibilidad, calidad del agua, continuidad ni operación. No inferir impacto en planta sin validación operacional.

Fuente	Evidencias mínimas	Cautela forense
Proveedores	Notificación, línea temporal, sistemas afectados, IOC's, evidencias de contención, accesos usados, impacto, medidas aplicadas, contacto responsable y compromisos de actualización.	La evidencia externa debe quedar identificada como aportada por tercero. No asumir veracidad total sin contraste ni introducir datos contractuales no disponibles.
Endpoint / teletrabajo	Inventario del dispositivo, usuario, ubicación, EDR/MDM, red usada, procesos, conexiones, archivos recientes, USB si aplica, cifrado, bloqueo/borrado remoto y cadena de custodia.	Si el dispositivo está perdido o fuera de control, separar hechos confirmados de riesgo estimado. No ordenar borrado remoto sin valorar evidencias y datos personales.

Tabla 36. Campos mínimos de cadena de custodia y cronología.

Campo de custodia	Contenido mínimo	Finalidad
Identificación	ID único, descripción, fuente, sistema, propietario, clasificación/TLP y relación con ticket maestro.	Evitar evidencias anónimas o imposibles de correlacionar.
Adquisición	Fecha/hora con zona horaria, persona que adquiere, método, herramienta, versión, consulta/comando/exportación y ruta de origen.	Hacer reproducible la obtención o explicar por qué no lo es.
Integridad	Hash criptográfico cuando aplique, tamaño, formato, firma/export controlado, ubicación de almacenamiento y control de cambios.	Demostrar que la evidencia no ha sido modificada indebidamente.
Custodia	Quién recibe, quién accede, cuándo, por qué, transferencia, repositorio, permisos y retirada/cierre.	Mantener trazabilidad de accesos y movimientos.
Cronología	Normalización temporal, NTP si existe, desfases conocidos, conversión de zona horaria y correlación entre fuentes.	Evitar líneas temporales falsas por horas locales, UTC o relojes desincronizados.
Limitaciones	Lagunas de logs, retención insuficiente, export parcial, proveedor no colaborador, dispositivo inaccesible o evidencia volátil perdida.	Impedir conclusiones más fuertes que las evidencias disponibles.

Tabla 37. Separación entre hechos, hipótesis, inferencias y limitaciones.

Categoría	Redacción aceptable	Redacción a evitar
Hecho observado	"La cuenta X inició sesión desde IP Y a las 10:42 CET según log IAM exportado el día Z."	"El atacante entró con la cuenta X."
Hipótesis	"Se plantea compromiso de credenciales porque el origen, horario y MFA difieren del patrón habitual."	"La cuenta está comprometida con certeza."
Inferencia técnica	"La secuencia sugiere movimiento lateral porque hay autenticaciones sucesivas hacia tres servidores en cinco minutos."	"Hubo movimiento lateral completo por toda la red."
Limitación	"No se puede confirmar exfiltración porque no hay PCAP ni logs de proxy para la ventana afectada."	"No hubo exfiltración."

Categoría	Redacción aceptable	Redacción a evitar
Conclusión provisional	"Con las evidencias disponibles, el incidente queda clasificado como S2, pendiente de confirmar alcance."	"Incidente cerrado definitivamente sin impacto."

8.2 Comunicación y TLP

Criterio de comunicación y cumplimiento. La clasificación TLP, los comunicados internos, la posible notificación a autoridades, la comunicación a afectados o abonados y la relación con proveedores deben basarse en hechos documentados y ser validados por los roles competentes. FASE 3.3 prepara evidencias y propuestas operativas, pero no determina por sí sola obligaciones legales, plazos regulatorios ni responsabilidad contractual.

Tabla 38. Uso de TLP en respuesta.

Etiqueta	Uso	Ejemplo en ACME Waters
TLP:CLEAR	Información divulgable sin restricciones.	Comunicados públicos aprobados, formación, notas generales sin datos sensibles.
TLP:GREEN	Comunidad amplia pero no pública.	Aprendizajes con equipos internos o sectoriales sin detalles explotables.
TLP:AMBER	Distribución limitada a quienes necesitan saber.	Información técnica de incidente, indicadores, activos afectados, decisiones de contención.
TLP:AMBER+STRICT	Solo destinatarios concretos.	Evidencias sensibles, datos personales, proveedores afectados, hipótesis de causa.
TLP:RED	Solo participantes presentes o designados.	Crisis, credenciales, OT, posible brecha, datos de investigación y estrategia legal.

Control de comunicación. Todo mensaje externo debe ser aprobado por Comité de Crisis o autoridad delegada. Los equipos técnicos no deben comunicar a medios, abonados o terceros no autorizados. Las notificaciones regulatorias requieren validación DPD/Jurídico y fuentes oficiales vigentes.

9. Automatización, SOAR y aprobación humana

Se ha seleccionado Microsoft Sentinel Automation / Logic Apps como SOAR inicial. Ahora se definen usos permitidos, límites y patrones de aprobación. La automatización debe reducir fricción operativa, asegurar trazabilidad y acelerar tareas repetibles, sin sustituir el criterio técnico que solo puede aportar el factor humano.

Tabla 39. Límites de automatización SOAR.

Nivel	Acciones	Condición
Permitido sin aprobación previa	Enriquecer IP/dominio/hash, consultar inventario, adjuntar logs, correlacionar alertas, crear o actualizar ticket, etiquetar severidad preliminar, notificar a canal interno y generar resumen ejecutivo interno.	Sin modificación de sistemas, sin bloqueo, sin revocación y sin comunicación externa. Debe registrar ID de alerta/incidente, hora, origen de datos y resultado.
Requiere aprobación técnica	Aislar endpoint no crítico, bloquear IOC en proxy/EDR/WAF, forzar cambio de contraseña de usuario no privilegiado, ampliar retención de logs, activar captura adicional autorizada o elevar subticket técnico.	Aprobación DIS/SOC o responsable técnico designado; registrar razón, alcance, resultado, reversibilidad y rollback.

Nivel	Acciones	Condición
Requiere aprobación CISO/Incident Commander	Deshabilitar cuentas privilegiadas, cortar VPN de grupo, bloquear proveedor, cambiar regla de firewall crítica, suspender integración cloud, aislar servidor crítico o restaurar servicio crítico.	Evaluar impacto, continuidad, evidencias, comunicaciones, dependencias y reversibilidad. La decisión debe quedar en el registro de decisiones.
Requiere Operaciones OT	Cualquier acción sobre DMZ OT, jump server industrial, flujos IT/OT, cuentas de proveedor OT, sensores, historian/intercambio, cambios de red industrial o adquisición física de evidencias en planta.	Sin aprobación de Operaciones no se ejecuta. La contención automática en OT queda prohibida; debe existir ventana, criterio de parada, reversibilidad, responsable OT y registro de decisión.
No permitido en esta fase	Borrado de evidencias, acciones destructivas, explotación para validar, escaneos activos OT, fuzzing, reinicios o parches sobre OT de producción, contención masiva sin control, restauración automática de producción, cambios permanentes sin CAB/ crisis o comunicación externa no aprobada.	Debe pasar por procedimiento manual, aprobación formal y validación posterior. SOAR solo puede documentar, preparar, enriquecer o solicitar la acción.

9.1 Patrón operativo de Microsoft Sentinel Automation / Logic Apps

El SOAR inicial se plantea como una capa de orquestación sobre alertas, incidentes, tickets, evidencias y aprobaciones. Cada automatización debe ser trazable, reversible cuando modifique un estado, limitada por permisos mínimos y probada antes de producción. Los runbooks del documento son procedimientos auditables; solo determinados pasos se trasladarán a Logic Apps o automatizaciones de Sentinel.

Bloque del flujo SOAR	Uso previsto en ACME Waters	Límite / evidencia obligatoria
Disparador	Alerta SIEM, incidente Sentinel, ticket manual, aviso SOC/MDR o solicitud del Incident Commander.	Debe indicar fuente, hora, severidad preliminar, activo afectado y runbook asociado.
Normalización	Convertir alertas en campos comunes: activo, usuario, IP/dominio/hash, servicio, zona, riesgo R1-R11, severidad S0-S4 y TLP.	No se declara incidente solo por automatización; debe existir validación humana según severidad.
Enriquecimiento	Consultar inventario, identidad, reputación de IOC, últimas alertas, exposición externa, propietario del activo y contexto BIA.	Solo lectura. Si una fuente no responde, registrar fallo y continuar en modo degradado.
Ticketing	Crear o actualizar ticket maestro, subtickets técnicos, tareas de evidencia y tareas de aprobación.	Debe conservar IDs de correlación, propietario, estado, hora y cambios de severidad.
Evidencias	Adjuntar consultas, exportaciones, enlaces internos, metadatos, capturas autorizadas, hashes y resultados de playbook.	No borrar, sobrescribir ni transformar evidencia original sin preservar copia o referencia.
Notificación	Avisar a SOC/MDR, CISO/RSI, DIS/CIO, guardia TI, Operaciones, DPD/Jurídico o proveedor según reglas de severidad.	La comunicación externa requiere aprobación del canal definido y uso de TLP adecuado.
Aprobación	Pedir autorización técnica, CISO/Incident Commander, Operaciones OT o DPD/Jurídico según acción.	La aprobación debe quedar en ticket y registro de decisión antes de ejecutar la acción crítica.
Ejecución controlada	Ejecutar acciones repetibles aprobadas: aislamiento de endpoint no crítico, bloqueo IOC, retención de logs o revocación limitada.	Debe tener alcance, condición de éxito, límite de reintentos, timeout y rollback.

Bloque del flujo SOAR	Uso previsto en ACME Waters	Límite / evidencia obligatoria
Cierre	Generar resumen de acciones, evidencias, resultados, tareas pendientes y lecciones aprendidas.	El cierre automático no está permitido si quedan acciones críticas, evidencias pendientes o aceptación de riesgo.

Tabla 40. Patrón operativo de automatización SOAR inicial.

9.2 Diseño seguro de playbooks y tareas automatizadas

Criterio de diseño	Regla aplicable	Aplicación en FASE 3.3
Idempotencia	Repetir una ejecución no debe agravar el impacto ni duplicar bloqueos.	Antes de bloquear IOC, aislar endpoint o revocar sesión, verificar estado previo y registrar si la acción ya estaba aplicada.
Rollback / reversibilidad	Toda acción modificativa debe tener reversión documentada o justificación de no reversibilidad.	El ticket debe incluir cómo revertir bloqueo, aislamiento, cambio de regla, suspensión de cuenta o retención ampliada.
Modo lectura por defecto	El enriquecimiento, búsqueda, correlación y adjunto de evidencias son las acciones iniciales por defecto.	Las acciones de escritura quedan detrás de una compuerta de aprobación.
Mínimo privilegio	Cada Logic App, identidad gestionada o conector debe tener permisos estrictamente necesarios.	Separar conectores de lectura, ticketing, bloqueo, identidad, cloud y firewall; no usar credenciales genéricas.
Control de concurrencia	Evitar ejecuciones masivas o en cascada sin límite.	Definir límites por runbook, activo, usuario, proveedor y ventana de tiempo.
Timeout y reintentos	Un fallo de conector no debe bloquear la gestión manual del incidente.	Registrar error, avisar al analista y ofrecer paso manual alternativo.
Validación de entradas	Artefactos como IP, dominio, hash, usuario o URL deben validarse antes de usarse en acciones.	Evitar bloqueos por IOC mal parseado, indicadores internos, dominios legítimos o datos incompletos.
Separación de entornos	Los playbooks deben probarse fuera de producción o en modo simulación cuando exista riesgo.	Los cambios sobre producción requieren versionado, revisión y aprobación.
Trazabilidad	Cada ejecución debe generar registro de entrada, decisión, acción, resultado y responsable.	El ticket maestro debe conservar IDs de Sentinel, Logic App, ticket, evidencia y decisión.
Supervisión del SOAR	La plataforma SOAR también es un activo crítico.	Monitorizar fallos de ejecución, colas, credenciales, conectores, cambios de playbook y accesos administrativos.

Tabla 41. Criterios de diseño seguro para playbooks y automatizaciones.

9.3 Catálogo de automatización por runbook

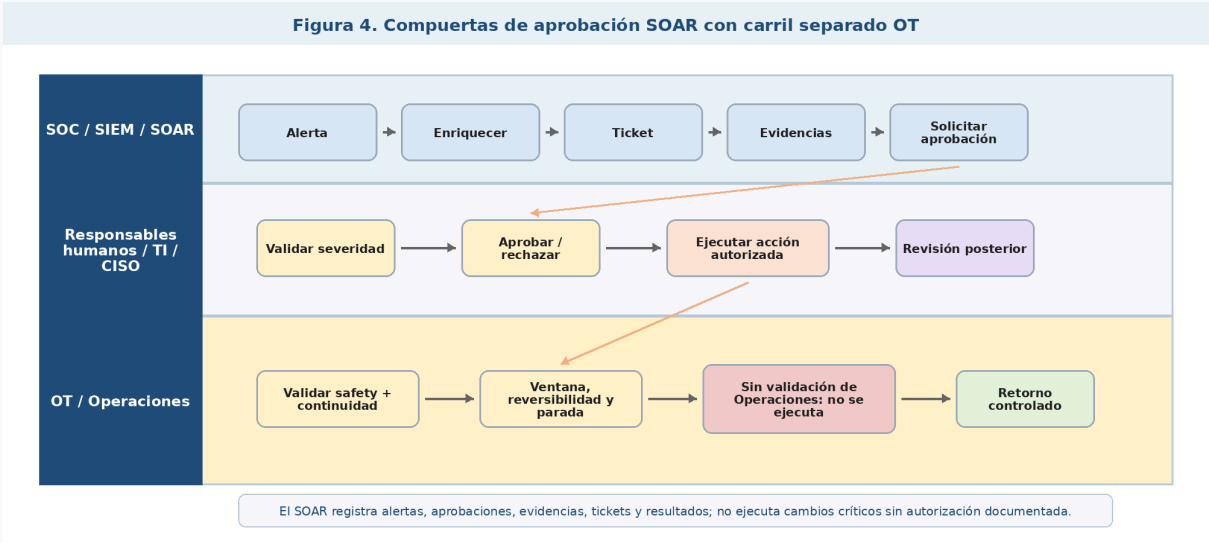
Runbook	Automatización permitida	Aprobación requerida	Prohibido automatizar
RB-01 Ransomware	Correlación de alertas, inventario, búsqueda de IOCs, creación de ticket, preservación de logs, checklist de evidencias de backup y solicitud de aprobación.	Aislamiento de servidores, bloqueo masivo, selección de punto de restauración, restauración o cambios en backups.	Borrado de muestras/evidencias, restauración automática de producción, modificación de repositorios de backup o pago/negociación.

Runbook	Automatización permitida	Aprobación requerida	Prohibido automatizar
RB-02 Identidad	Resumen de inicios de sesión, sesiones activas, tokens, cambios de grupos, cuentas privilegiadas, cuentas de servicio, accesos VPN/ZTNA y creación de tareas IAM/PAM.	Deshabilitar cuentas privilegiadas, cortar VPN/ZTNA de grupo, revocar sesiones críticas, rotar cuentas de servicio o activar guardia TI ampliada.	Cambios masivos de permisos, eliminación de cuentas, revocación indiscriminada de cuentas de servicio o reactivación de privilegios sin aprobación.
RB-03 Web/API	Recopilar logs WAF/API, cabeceras, rutas afectadas, errores, IOC y subtickets AppSec.	Bloqueo WAF, despublicación temporal o cambios de configuración productiva.	Fuzzing, explotación o pruebas de carga desde SOAR.
RB-04 Cloud/correo	Exportar eventos de auditoría, reglas de reenvío, OAuth/consentimientos, mensajes sospechosos y tareas de revisión.	Revocar tokens, bloquear buzón directivo, suspender integración cloud, rotar secretos OAuth/API o aplicar contención tenant-wide.	Borrar correos, reglas, consentimientos, tokens o evidencias antes de preservarlas; reactivar OAuth/API sin recertificación.
RB-05 Proveedor	Abrir caso, pedir información mínima, correlacionar accesos de proveedor y activar seguimiento.	Bloqueo de acceso del proveedor, desconexión de integración o medidas contractuales.	Reactivar accesos o confiar en declaraciones sin evidencia.
RB-06 IT/OT	Recopilar logs existentes de bastión, VPN, DMZ OT, jump server, SIEM/SOC y sensores pasivos; abrir ticket; adjuntar evidencias disponibles; avisar a Operaciones y registrar hipótesis funcional.	Cualquier acción sobre DMZ OT, jump server industrial, sensor, cuenta de proveedor, flujo IT/OT, cambio de red, adquisición física o intervención en planta.	Contención automática OT, escaneo activo, fuzzing, explotación, reinicio, bloqueo, parche, despliegue de agente, cambio de configuración o captura intrusiva en red industrial.
RB-07 CPD	Recopilación de alertas de infraestructura, inventario de dependencias, estado de servicios base, ticketing y checklist de recuperación.	Conmutación, restauración, cambios de DNS/AD/NTP, activación de contingencia o retorno a producción.	Reinicios encadenados, failover automático no probado, borrado de logs o restauración sin validación de integridad.
RB-08 Vulnerabilidad crítica	Consultar inventario afectado, exposición, CVE, explotación conocida, owners y tareas de mitigación.	Mitigación temporal productiva, bloqueo perimetral o parche urgente.	PoC destructiva, escaneo agresivo, escaneo activo sobre OT de producción o cambios no probados.
RB-09 Endpoint/teletrabajo	Correlación EDR/MDM/VPN, geolocalización lógica, inventario y notificación a usuario/soporte.	Aislar endpoint, revocar dispositivo, bloquear acceso remoto, suspender perfil VPN/ZTNA o ejecutar borrado remoto.	Borrado remoto sin autorización y sin preservar evidencia cuando proceda; reactivar acceso remoto desde dispositivo no conforme.
RB-10 Datos personales	Consolidar evidencias, activos, categorías de datos, logs y avisos a DPD/Jurídico.	Comunicación externa, notificación regulatoria o afirmación de alcance cerrado.	Cerrar brecha automáticamente o declarar ausencia de impacto sin evidencias.
RB-11 DDoS	Recoger métricas, logs CDN/WAF, disponibilidad, fuentes, volumen y tareas de mitigación.	Cambios de mitigación, rate-limit agresivo o activación de proveedor anti-DDoS.	Bloqueos indiscriminados que afecten a usuarios legítimos sin validación.
RB-12 Phishing	Extraer indicadores, buscar mensajes similares, crear campaña de contención y avisar internamente.	Retirada masiva de correos, revocación de tokens, reset de MFA/contraseña o bloqueo de dominios amplios.	Reenvío inseguro de muestras, ejecución de adjuntos desde SOAR o cierre sin revisar sesiones y credenciales posteriores.

Tabla 42. Catálogo de automatización permitido por runbook.

Cautela SOAR. Los runbooks de FASE 3.3 son procedimientos operativos auditables; no todos sus pasos deben convertirse en automatizaciones. La prioridad es preservar evidencias, reducir tiempos de coordinación, mantener control humano y evitar acciones irreversibles, especialmente sobre OT, producción, identidad privilegiada, cloud y proveedores críticos.

FIGURA 4. Compuertas de aprobación SOAR.



10. Runbooks de respuesta

Los runbooks se diseñan para escenarios prioritarios de ACME Waters. No son procedimientos cerrados de una herramienta concreta; son guías operativas con decisiones, evidencias, cautelas y puntos de escalado. Deben probarse mediante ejercicios antes de considerarse aprobados. El cierre de cada runbook debe alimentar, cuando proceda, el registro de riesgos, las acciones correctivas del SGSI, la revisión de controles y la actualización de evidencias o contratos, sin convertir el runbook en auditoría de cumplimiento.

Uso de ventanas temporales y BIA. Las marcas 0-15 min, 15-60 min y 1-4 h que aparecen en runbooks son secuencias orientativas para ordenar la actuación. La prioridad real se decide por severidad, impacto, seguridad de personas, continuidad del agua, evidencia disponible, dependencia BIA, disponibilidad de backup confiable, validación de negocio y autorización de Operaciones cuando exista impacto OT.

Tabla 43. Matriz de runbooks prioritarios.

Runbook	Escenario	Riesgos	Severidad inicial	Responsables
RB-01	Ransomware en CPD, servidores o backups	R1, R3, R6, R11	S3/S4	DIS, SOC/MDR, CISO, Continuidad
RB-02	Compromiso de identidad, AD, VPN/ZTNA, MFA, PAM, cuentas de servicio o proveedor	R2, R9, R10	S3/S4	IAM, SOC/MDR, CISO, responsables de servicio
RB-03	Explotación web/API	R4, R7	S2/S3/S4	AppSec, SOC/MDR, DPD
RB-04	Cloud/correo, BEC, OAuth o fuga SaaS	R10, R2	S2/S3/S4	Cloud, IAM, DPD, Comunicación, proveedor SaaS si aplica
RB-05	Proveedor crítico comprometido o caído	R5, R11	S3/S4	Compras, Jurídico, DIS, CISO
RB-06	Alerta IT/OT o acceso remoto industrial sospechoso	R8	S3/S4	Operaciones, DIS, SOC, CISO

Runbook	Escenario	Riesgos	Severidad inicial	Responsables
RB-07	Indisponibilidad CPD o servicios base	R3, R11	S3/S4	Infraestructura, Continuidad, CISO
RB-08	Vulnerabilidad crítica o zero-day explotable	R7, R4, R8	S2/S3/S4	Vulnerabilidades, AppSec, Operaciones
RB-09	Endpoint/teletrabajo comprometido, dispositivo perdido o acceso remoto no conforme	R9, R2	S1/S2/S3	Endpoint, IAM, SOC
RB-10	Brecha o exposición de datos personales	R4, R10, R5	S3/S4	DPD, Jurídico, CISO, Comunicación
RB-11	DDoS o indisponibilidad de servicios públicos	R3, R4, R5	S2/S3/S4	Red, AppSec, proveedor front/CDN
RB-12	Campaña de phishing o robo de credenciales	R2, R10, R9	S1/S2/S3	SOC, IAM, Comunicación interna, Service Desk

Tabla 44. Matriz de visibilidad mínima por runbook.

Runbook	Fuentes primarias	Fuentes de contraste	Evidencia de ticket/cierre
RB-01	EDR/XDR, IAM/AD/PAM, backup/DR, SIEM/SOC.	NDR/NetFlow, DNS, proxy, firewall, aplicación y usuarios.	Host inicial, proceso/hash, cuenta, backup afectado, alcance de propagación y cronología.
RB-02	IAM/MFA/PAM/VPN/ZTNA y SIEM/SOC.	EDR del dispositivo, cloud/correo, DNS/proxy y NDR.	Usuario, sesión/token, MFA, cambio de privilegio, cuenta de servicio, origen, destino, política VPN/ZTNA y motivo de severidad.
RB-03	WAF/CDN/API Gateway, aplicación y logs API/BBDD.	SIEM, NDR/proxy/DNS, trazas de backend, DLP si aplica.	Endpoint, request ID, sesión/usuario, acción WAF, objeto accedido y validación de impacto.
RB-04	Correo, cloud/SaaS, IAM y DLP.	Proxy/DNS/NDR, EDR, SIEM/SOC y reporte de usuario.	Headers, reglas, OAuth/API, descargas/compartición, tokens, permisos, proveedor SaaS y decisiones DPD/Jurídico si aplica.
RB-05	Comunicación formal del proveedor, accesos terceros, contrato/SLA.	SIEM/IAM/VPN/API/firewall internos, negocio y continuidad.	Cronología externa marcada como tercero, accesos a ACME, impacto, lagunas y compromisos de actualización.
RB-06	Jump server, PAM/VPN, firewall industrial, sensores pasivos, registros de proveedor OT y Operaciones.	SIEM/SOC, IAM, DNS/proxy, NDR pasivo, cambios autorizados y orden de trabajo.	Ventana, aprobación de Operaciones, flujo observado, destino funcional, impacto operacional confirmado o descartado, criterio de parada y límites de análisis.

Runbook	Fuentes primarias	Fuentes de contraste	Evidencia de ticket/cierre
RB-07	Monitorización CPD, infraestructura, AD/DNS/NTP y SIEM.	NDR/firewall, cambios, usuarios, proveedor y EDR si hay indicios de ataque.	Servicio afectado, métricas, cambios recientes, causa probable, validación de recuperación y deuda pendiente.
RB-08	Inteligencia/fabricante/CSIRT, inventario y exposición.	SIEM/WAF/proxy/NDR, gestión de vulnerabilidades y proveedor.	CVE/aviso, activos, versión, exposición, decisión de mitigación y verificación posterior.
RB-09	EDR/XDR/MDM, IAM/VPN/ZTNA y reporte de usuario.	DNS/proxy/NDR, cloud/correo y SOC/MDR.	Activo, usuario, cifrado/postura, última conexión, sesiones, política VPN/ZTNA, revocación y decisión de aislamiento/borrado.
RB-10	DLP/SIEM/cloud, aplicación/API/BBDD y DPD/Jurídico.	WAF/proxy/NDR, proveedor y reporte externo.	Categorías de datos, periodo, accesos, transferencia/exposición, limitaciones y decisión jurídica.
RB-11	CDN/WAF/balanceador, NDR/NetFlow/red/DNS y monitorización.	Aplicación/APM, proveedor front/cloud/ISP y usuarios.	Volumen, capa, endpoints, impacto, mitigaciones, rollback y diferenciación frente a explotación.
RB-12	Usuarios, correo/SIEM/SOC, IAM/MFA.	EDR/XDR, proxy/DNS/NDR y cloud/correo.	Muestra preservada, headers, URLs/hashees, destinatarios, clics/sesiones, tokens revocados, cuentas afectadas y comunicaciones internas.

Criterio de cobertura de amenazas. Los runbooks traducen las amenazas priorizadas de FASE 3.1 a acciones defensivas observables. Las tácticas y técnicas se nombran solo para orientar detección, triage, alcance, comunicación y cierre; no se documentan cargas, PoC, explotación, evasión ni post-explotación.

Tabla 45. Trazabilidad entre amenazas priorizadas, riesgos y runbooks.

Amenaza priorizada	Riesgos / vulnerabilidades	Runbooks vinculados	Señales defensivas y cautelas
Ransomware, wiper o extorsión	R1, R3, R6, R11; debilidades de backup, identidad, exposición y segmentación.	RB-01, RB-07, RB-10	Cifrado/borrado masivo, notas de rescate, desactivación de controles, borrado de snapshots, lateralidad y abuso de cuentas. No detonar muestras ni ejecutar malware fuera de laboratorio autorizado.
Compromiso de credenciales e identidad	R2, R9, R10; MFA, PAM, VPN/ZTNA, cuentas de servicio y grupos privilegiados.	RB-02, RB-12, RB-04	Inicio imposible, MFA fatigue, sesión concurrente, token/OAuth sospechoso, cambio de grupo, regla de reenvío, uso de cuenta de servicio o acceso VPN/ZTNA fuera de política. Revocación y rotación con aprobación, trazabilidad y evaluación de impacto.
Ataques web/API	R4, R7; exposición pública, autorización, validación de entrada, secretos y backend.	RB-03, RB-08, RB-10	Picos 4xx/5xx, payload indicador, abuso de autorización, subida anómala, consultas fuera de patrón o errores de aplicación. No reproducir explotación ni pruebas agresivas contra producción.

Amenaza priorizada	Riesgos / vulnerabilidades	Runbooks vinculados	Señales defensivas y cautelas
Cloud/correo/BEC/SaaS	R10, R2, R5; configuración cloud, colaboración, correo, OAuth y DLP.	RB-04, RB-12, RB-10	Reglas inbox, forwarding, consentimientos OAuth, descargas, compartición externa, suplantación o fraude. Separar buzón comprometido de dato exfiltrado confirmado.
Proveedor y cadena de suministro	R5, R2, R11; accesos terceros, integraciones, SLA/OLA, subcontratación y continuidad.	RB-05, RB-06, RB-10	Aviso de proveedor, VPN/API/ZTNA de tercero anómala, caída de servicio o IOC comunicado. Evidencia de tercero se marca como tal, se contrasta con logs internos y el acceso se reactiva solo con cuenta nominativa/trazable, caducidad y aprobación.
Vulnerabilidad crítica o zero-day	R7, R4, R8; CVE, exposición, parche, workaround y producto gestionado.	RB-08, RB-03, RB-06	Aviso de fabricante/CSIRT, explotación conocida, versión vulnerable, activo expuesto o IOC. Validación por inventario, logs y fuente oficial; no usar PoC contra producción.
Teletrabajo y endpoint	R9, R2; dispositivo no gestionado, pérdida, EDR/MDM, VPN/ZTNA y postura.	RB-09, RB-02, RB-12	Alerta EDR, postura no conforme, conexión remota fuera de perfil, dispositivo perdido o malware. Borrado/aislamiento solo con impacto y evidencia registrados.
DDoS e indisponibilidad externa	R3, R4, R5; DNS, CDN/WAF, ISP, portal, API y atención a abonados.	RB-11, RB-03, RB-07	Volumetría, saturación, errores 5xx, degradación por endpoint o fallo DNS. Mitigaciones reversibles y coordinadas con proveedor.
IT/OT y acceso remoto industrial	R8; frontera IT/OT, DMZ OT, jump server, proveedor OT y monitorización pasiva.	RB-06, RB-05, RB-08	Acceso fuera de ventana, flujo no documentado, alerta pasiva, cambio no aprobado o riesgo operacional. Operaciones aprueba toda acción; no escaneo activo, fuzzing, reinicio ni explotación en OT de producción.
Datos personales y fuga	R4, R10, R5; BBDD, API, SaaS, proveedor y exposición pública.	RB-10, RB-03, RB-04, RB-05	Acceso masivo, descarga, publicación, DLP, reporte externo o evidencia de proveedor. Activar DPD/Jurídico y distinguir indicio, alcance probable y confirmación.

Tabla 46. Matriz de prioridad preliminar de recuperación por runbook.

Runbook	Uso de BIA/MTD/RTO/RPO	Dependencias de recuperación	Criterio de retorno
RB-01 Ransomware	Priorizar servicios esenciales, CPD crítico y backups; RTO/RPO solo como hipótesis hasta aprobación formal.	Identidad, DNS/NTP, backup inmutable o aislado, EDR limpio, comunicaciones de crisis y proveedores de infraestructura.	Restauración o reconstrucción verificada, sin señales de cifrado activo, validación del dueño y monitorización reforzada.

Runbook	Uso de BIA/MTD/RTO/RPO	Dependencias de recuperación	Criterio de retorno
RB-02 Identidad	Priorizar identidad porque habilita administración, teletrabajo, cloud y recuperación de otros servicios.	IAM/MFA/PAM, cuentas break-glass, bastión, dispositivos de administración, cuentas de servicio, proveedores y canales fuera de banda.	Rehabilitación por mínimo privilegio, sesiones/tokens revocados, secretos rotados, cuentas de servicio recertificadas y aprobación IAM/CISO.
RB-03 Web/API	Priorizar trámites online y atención a abonados según impacto; no prometer disponibilidad sin prueba funcional.	WAF/CDN/API Gateway, backend, BBDD, secretos, proveedor front y DPD si hay datos.	Parche o mitigación probado, logs revisados, validación funcional y autorización de negocio.
RB-04 Cloud/correo	Priorizar correo y canales alternativos según necesidad de crisis; RPO depende de retención y capacidades SaaS.	Tenant cloud, auditoría, eDiscovery, DLP, IAM, OAuth/API, proveedor SaaS y canal alternativo de comunicación.	Configuración segura restaurada, permisos mínimos, tokens/OAuth revisados, auditoría activa y validación Cloud/IAM/DPD si aplica.
RB-05 Proveedor	Priorizar por proceso afectado en BIA y criticidad contractual; no asumir RTO del proveedor sin evidencia.	SLA/OLA, contactos 24x7, accesos de tercero, alternativas operativas y evidencias del proveedor.	Reactivación solo con informe mínimo, acciones correctoras, evidencias y aprobación del dueño de servicio.
RB-06 IT/OT	Prioridad máxima si hay safety, calidad del agua, medioambiente o continuidad operacional; PCN/Operaciones prevalecen.	Operaciones, ventana OT, proveedor industrial, respaldos de configuración, procedimientos manuales, canales alternativos y criterios de safety/calidad.	Retorno solo por personal OT autorizado, con criterio de parada, reversibilidad, evidencia funcional y validación de Operaciones.
RB-07 CPD	Priorizar servicios base según BIA preliminar; MTD/RTO/RPO orientan secuencia sin crear compromiso.	Virtualización, almacenamiento, red, AD/DNS/NTP, backups, DR, proveedores y canales alternativos.	Recuperación escalonada, integridad validada, dependencias estables y aprobación del dueño de servicio.
RB-08 Vulnerabilidad crítica	Priorizar por exposición, explotación conocida, criticidad del activo y dependencia de servicio esencial; no priorizar solo por CVSS.	Inventario, fabricante/CSIRT, workaround, parche, WAF/EDR/firewall, propietarios, ventana y validación no intrusiva en OT.	Mitigación o parche verificado, monitorización reforzada, ausencia de explotación posterior relevante y riesgo residual aceptado.
RB-09 Endpoint/teletrabajo	Priorizar usuarios que sostienen servicio esencial, guardia TI, atención a abonados o recuperación; no reactivar por urgencia sin postura conforme.	MDM/EDR, cifrado, IAM/MFA, VPN/ZTNA, equipo limpio o reimagen, soporte y canal de entrega seguro.	Dispositivo conforme, acceso remoto por perfil mínimo, sesiones antiguas revocadas, usuario revalidado y monitorización reforzada.
RB-10 Datos personales	Priorizar sistemas con datos personales por volumen, sensibilidad, exposición, proveedor y obligación de evaluación DPD/Jurídico.	DPD/Jurídico, aplicación/BBDD/SaaS, logs de acceso, DLP, proveedor, evidencias de contención y comunicación aprobada.	Exposición contenida, alcance documentado, medidas compensatorias validadas y decisión DPD/Jurídico registrada.
RB-11 DDoS	Priorizar disponibilidad externa y atención a abonados; usar degradación controlada si no hay capacidad plena.	CDN/WAF/DNS/ISP, aplicación, página estática, call center, comunicación y proveedor anti-DDoS si aplica.	Tráfico estable, mitigación reversible, validación de negocio y cierre con proveedor.
RB-12 Phishing	Priorizar cuentas con privilegio, proveedores, dirección, finanzas, atención a abonados y acceso a servicios críticos.	Correo, IAM/MFA, VPN/ZTNA, EDR, proxy/DNS, comunicación interna y Service Desk.	Campaña contenida, credenciales/tokens saneados, usuarios avisados, cuentas sensibles revisadas y ausencia de accesos posteriores relevantes.

10.1 Criterios forenses transversales por runbook

Los runbooks deben ejecutarse con prioridad operativa, pero sin perder la capacidad de reconstruir el incidente. Cuando exista conflicto entre contención y preservación, la decisión debe documentarse y aprobarse según severidad, impacto y criticidad del activo. Las siguientes reglas no añaden nuevos controles técnicos: fijan mínimos de evidencia, cautela probatoria y límites de conclusión.

Tabla 47. Criterios forenses específicos por runbook.

Runbook	Evidencia crítica antes/durante contención	Cautela probatoria
RB-01 Ransomware	EDR, árbol de procesos, hashes, extensión/nota de rescate, cuentas usadas, accesos a backup, muestras si son seguras, logs de cifrado/borrado y línea temporal.	Aislar rápido puede ser correcto; borrar malware o restaurar sin preservar metadatos reduce capacidad de reconstruir alcance. No afirmar recuperación limpia sin verificación.
RB-02 Identidad	IAM, MFA, PAM, cambios de grupos, sesiones privilegiadas, origen lógico, tokens, cambios de credencial, cuentas de servicio, accesos VPN/ZTNA y correlación con endpoints.	No tratar todo login anómalo como compromiso confirmado. Bloqueos masivos, rotación de cuentas de servicio o corte de acceso remoto requieren aprobación y registro de impacto.
RB-03 Web/API	WAF, logs de aplicación, cabeceras, parámetros, sesión, cuenta afectada, payload registrado, cambios de código/configuración y evidencias de acceso a datos.	No reproducir explotación destructiva. No afirmar exfiltración por una petición sospechosa sin correlación con transferencia o acceso a datos.
RB-04 Cloud/correo	Auditoría SaaS, reglas inbox, forwarding, OAuth/API consent, eDiscovery, mensajes, cabeceras, accesos, descargas, cambios de permisos y proveedor SaaS si aplica.	Diferenciar cuenta comprometida, buzón abusado, token/OAuth malicioso y dato exfiltrado. Las evidencias cloud dependen de retención, licencia y contrato.
RB-05 Proveedor	Comunicación formal, IOCs, línea temporal del proveedor, accesos usados contra ACME, evidencias de contención, impacto declarado y cambios de credenciales/conectividad.	Marcar todo dato externo como evidencia de tercero. No convertir afirmaciones del proveedor en hechos internos sin contraste.
RB-06 IT/OT	Logs de jump server, acceso remoto industrial, firewall/DMZ OT, historial/intercambio, alertas pasivas, orden de trabajo, autorización de Operaciones, proveedor OT e impacto operacional.	No escanear, explotar, reiniciar ni contener OT automáticamente. Prioridad: safety, continuidad, calidad del agua, medioambiente y preservación no intrusiva.
RB-07 CPD	Alertas de infraestructura, AD/DNS/NTP, almacenamiento, virtualización, red, cambios recientes, logs de backup/DR, tickets de proveedor y evidencias de disponibilidad.	No reiniciar en cadena ni restaurar sin preservar logs críticos. Diferenciar fallo operativo, cambio fallido e indicio de ataque antes de cerrar causa.
RB-08 Vulnerabilidad crítica	Aviso CVE/fabricante/CSIRT, inventario afectado, versión, exposición, owner, logs retrospectivos, intentos de explotación, mitigaciones y evidencia de verificación.	No ejecutar PoC ni escaneo agresivo en producción. En OT, validar con Operaciones y métodos no intrusivos; no cerrar sin verificación posterior.
RB-09 Endpoint/teletrabajo	EDR/MDM, último contacto, cifrado, usuario, red, política VPN/ZTNA, procesos, conexiones, archivos recientes, USB, ubicación conocida y acciones remotas.	Si se decide borrado remoto, registrar justificación, aprobación y evidencias disponibles antes de destruir datos. No reactivar teletrabajo sin postura conforme y cuenta revisada.
RB-10 Datos personales	Categorías de datos, sistemas afectados, accesos, consultas, descargas, destinatarios, volumen estimado si existe y evidencias de contención.	No afirmar brecha notificable, exfiltración o número de afectados sin validación DPD/Jurídico y evidencia suficiente.
RB-11 DDoS	Métricas CDN/WAF/DNS/ISP, NetFlow/NDR, volumen, capa afectada, endpoints, códigos de error, mitigaciones aplicadas, impacto a usuarios y comunicaciones de proveedor.	No confundir DDoS con explotación web/API o fallo de proveedor sin evidencias. Preservar métricas antes de cambiar mitigaciones y registrar falsos positivos.
RB-12 Phishing	Muestra encapsulada, headers, URLs, adjuntos, hashes, destinatarios, reportes de usuario, clics, sesiones, MFA, tokens y accesos posteriores.	No ejecutar adjuntos ni reenviar muestras por canales inseguros. El cierre exige revisar credenciales, sesiones, tokens y cuentas sensibles afectadas.

RB-01. Ransomware en CPD, servidores o backups

Tabla 48. Ficha de runbook.

Campo	Contenido
Riesgos vinculados	R1, R3, R5, R6, R7, R11

Campo	Contenido
Objetivo	Detectar, contener y recuperar un ataque de ransomware preservando evidencias, evitando propagación y priorizando servicios según BIA preliminar.
Severidad mínima sugerida	S3 si afecta a servidor crítico, AD, backups o varias estaciones; S4 si afecta CPD, recuperación, datos personales, operación esencial o hay extorsión pública.

Tabla 49. Disparadores y validación inicial.

Disparador / fuente	Qué valida
EDR/XDR/MDM	Cifrado o borrado masivo, ejecución anómala, abuso de herramientas administrativas, desactivación de controles, hashes, árbol de procesos y host inicial.
SIEM/SOC/MDR	Correlación de identidad, endpoint, red y backup: cambios de GPO, autenticaciones laterales, creación de tareas, alertas encadenadas y severidad preliminar.
IAM/PAM/VPN/AD	Uso anómalo de cuentas privilegiadas o de servicio, cambios de grupo, accesos fuera de ventana y sesiones administrativas relacionadas.
NDR/DNS/proxy/firewall	Conexiones laterales, C2, SMB/RDP/WinRM fuera de patrón, dominios sospechosos, transferencia inusual y saltos entre segmentos.
Backup/DR/infraestructura	Borrado de snapshots, fallos de repositorio, cambios de política, credenciales de backup fuera de patrón o alertas de integridad.
Usuario/Operación	Ficheros cifrados, notas de rescate, aplicaciones inaccesibles o comportamiento anómalo reportado por negocio.

Tabla 50. Acciones iniciales.

Secuencia orientativa	Acciones
0-15 min	Abrir ticket maestro, preservar alerta original, identificar primer activo afectado, hora de inicio, usuario, segmento y proceso observado.
15-60 min	Activar CSIRT, congelar logs, identificar alcance preliminar, revisar AD/IAM, backups, EDR, red y servicios críticos.
1-4 h	Establecer sala de crisis, priorizar contención por segmento, preparar recuperación limpia y evaluar necesidad de comunicación externa/regulatoria.

Tabla 51. Contención controlada.

Contención	Condición de aprobación
Aislar endpoints o servidores afectados desde EDR/XDR.	Aprobación técnica; en servidores críticos requiere Incident Commander y validación de continuidad.
Deshabilitar cuentas comprometidas y revocar sesiones.	Aprobación IAM/CISO; priorizar cuentas privilegiadas y cuentas de servicio sospechosas.
Bloquear IOCs en EDR, proxy, DNS, firewall o WAF.	Aprobación SOC/DIS; registrar rollback y alcance.
Proteger repositorios de backup y detener tareas sospechosas.	Aprobación infraestructura/continuidad; no borrar evidencias.

Contención	Condición de aprobación
Separar segmentos si hay propagación.	Aprobación DIS/CISO; evaluar impacto en servicios críticos.
Seleccionar punto de restauración confiable.	Confirmar aislamiento/inmutabilidad, fecha/hora, cobertura RPO orientativa, integridad y ausencia de manipulación antes de usarlo.
Retornar servicios por oleadas controladas.	Orden aprobado por Incident Commander, Continuidad y dueño de servicio; detener retorno si reaparecen indicadores o fallos de integridad.
Inteligencia externa / extorsión	Capturas o referencias a publicación/extorsión preservadas por personal autorizado; no interactuar con actor, no descargar material sensible innecesario y coordinar con Jurídico/DPD.

Tabla 52. Erradicación, recuperación y retorno.

Erradicación / recuperación	Criterio de salida
Eliminar persistencia, tareas, binarios, credenciales comprometidas y vectores iniciales.	No iniciar recuperación hasta tener causa razonablemente contenida.
Restaurar desde backup inmutable/aislado o reconstruir sistemas.	Validación antimalware, integridad y funcionalidad antes de retorno.
Priorizar identidad, DNS/NTP, CPD, comunicaciones de crisis, atención mínima y servicios de abonados según BIA.	Aprobación de retorno por Incident Commander y dueño de servicio.
Mantener monitorización reforzada al menos durante la fase de estabilización.	Sin nuevas señales de cifrado, C2 o movimiento lateral.

Tabla 53. Evidencias mínimas.

Evidencia	Detalle
Alerta y ticket	ID SIEM/SOC/EDR, severidad inicial y recalificaciones, runbook aplicado, fuentes consultadas y lagunas de visibilidad.
Endpoint/servidor	Hashes, rutas, procesos, árbol de ejecución, usuario, host, comandos, nota de rescate, extensión afectada e IOCs.
Identidad	Cuentas usadas, cambios de privilegio/GPO, sesiones PAM/VPN/AD, cuentas de servicio y aprobaciones de bloqueo.
Red	Flujos NDR/NetFlow, DNS, proxy, firewall, conexiones laterales, C2, segmentos afectados y NAT/XFF cuando aplique.
Backups/DR	Estado, fecha, integridad, prueba de restauración, repositorio, credenciales, jobs, snapshots y accesos al repositorio.
Cronología	Hora inicial, primera alerta, primera contención, declaración, restauración y cierre con zona horaria/NTP.

Tabla 54. Comunicación y escalado.

Comunicación	Criterio
Dirección	S3/S4 con informe de situación periódico: impacto, alcance, servicios, decisiones y riesgos.
DPD/Jurídico	Activar si hay indicios de datos personales, exfiltración o extorsión con publicación.
Operaciones	Activar si afecta continuidad del agua o frontera IT/OT.

Comunicación	Criterio
Proveedores	Notificación controlada a MDR, backup, cloud, soporte y proveedores críticos afectados.

Límites/No hacer:
No pagar, negociar ni responder al atacante desde canales no aprobados. No borrar sistemas cifrados sin adquisición/evidencia mínima. No restaurar sobre entorno comprometido. No aislar OT ni provocar cortes industriales sin Operaciones.

Tabla 55. Cierre del runbook.

Entregable de cierre	Contenido mínimo
Informe técnico	Cronología, vector probable, alcance, datos afectados, activos, IOCs, acciones, controles fallidos y mejoras.
Plan de mejora	EDR, hardening, MFA/PAM, backups, segmentación, detecciones, pruebas de restauración y formación.
Mejora de detección	Ajustes de fuentes de alerta, normalización, retención, severidad, ticketing, falsos positivos y actualización del runbook/casos de uso.

RB-02. Compromiso de identidad, AD, VPN, MFA o PAM

Tabla 56. Ficha de runbook.

Campo	Contenido
Riesgos vinculados	R2, R1, R6, R9, R10
Objetivo	Contener abuso de identidades, privilegios, cuentas de servicio, VPN/ZTNA, MFA y PAM; preservar trazabilidad y evitar movimiento lateral, fraude, borrado de evidencias o compromiso cloud.
Severidad mínima sugerida	S2 para cuenta estándar limitada; S3 para cuenta privilegiada, servicio, TI o proveedor; S4 si afecta AD, PAM, MFA, cloud tenant, guardia TI ampliada o recuperación.

Tabla 57. Disparadores y validación inicial.

Disparador / fuente	Qué valida
SIEM/IAM/MFA	Inicio de sesión imposible, origen u horario anómalo, MFA fatigue, cambios de credencial, bloqueo/desbloqueo y modificación de grupos privilegiados.
PAM/bastión	Sesión privilegiada no planificada, destino o comando fuera de patrón, grabación disponible, uso de cuenta break-glass o sesión fuera de ventana.
VPN/ZTNA/proxy	Acceso desde dispositivo no conforme, país no habitual, cambio brusco de IP, sesión concurrente o navegación posterior incompatible con el perfil.
Cloud/correo/SaaS	Consentimiento OAuth sospechoso, reglas de reenvío, acceso a buzones, descarga masiva o cambio de permisos vinculado a la cuenta.
EDR/XDR/MDM	Dispositivo origen comprometido o sin postura válida, token usado desde endpoint alertado, malware o ejecución de herramientas de robo de credenciales.

Disparador / fuente	Qué valida
SOC/MDR	Correlación multi-fuente y recalificación de severidad por privilegio, activo crítico, datos personales o propagación.
Cuentas de servicio/API	Uso fuera de horario, origen no autorizado, error repetido, rotación pendiente, privilegio excesivo o dependencia crítica afectada.
Guardia TI ampliada	Acceso administrativo fuera de horario, sesión de emergencia, uso de break-glass o solicitud extraordinaria vinculada al incidente.

Tabla 58. Acciones iniciales.

Secuencia orientativa	Acciones
0-15 min	Identificar cuenta, origen, dispositivo, aplicación, privilegios, grupos, sesiones activas, tokens, cuenta de servicio asociada, proveedor si aplica y último cambio.
15-60 min	Preservar logs IAM/PAM/VPN/ZTNA/cloud, revisar elevaciones y accesos laterales, abrir ticket maestro y confirmar si existe guardia TI o tercero implicado.
1-4 h	Determinar si hay impacto en correo, cloud, aplicaciones, backups, servidores, cuentas de servicio, proveedor o continuidad de administración.

Tabla 59. Contención controlada.

Contención	Condición de aprobación
Revocar sesiones y tokens.	Aprobación IAM/SOC; urgente si hay indicios de abuso activo.
Forzar cambio de credenciales y MFA re-registration.	Aprobación IAM; validar usuario por canal alternativo.
Deshabilitar cuenta.	CISO/IAM si privilegiada, servicio o proveedor; evaluar impacto operativo.
Suspender acceso VPN/ZTNA del perfil afectado.	Aprobación DIS/CISO si afecta a grupo completo.
Bloquear origen malicioso.	Aprobación SOC/DIS; documentar falso positivo e impacto.
Recuperar administración segura.	Usar cuentas break-glass y PAM/bastión controlados hasta completar recertificación de privilegios.
Rehabilitar servicios dependientes de identidad.	Validación por dueño de servicio y ausencia de uso anómalo posterior.
Suspender acceso de proveedor o tercero afectado.	Aprobación CISO/IAM y dueño de servicio; mantener canal alternativo y registrar impacto contractual/operativo.
Rotar secreto de cuenta de servicio o API.	Aprobación IAM/DIS y dueño de aplicación; validar dependencias, ventana, rollback y continuidad antes de ejecutar.
Activar guardia TI ampliada controlada.	Aprobación Incident Commander/CISO; acceso por PAM/bastión/MFA, finalidad acotada, ventana, registro y revisión posterior.

Tabla 60. Erradicación, recuperación y retorno.

Erradicación / recuperación	Criterio de salida
Revisar grupos, permisos, delegaciones, GPO, cuentas de servicio y cambios recientes.	Sin cambios no autorizados pendientes; cuentas privilegiadas, proveedor y servicio recertificadas o suspendidas con plan.
Rotar secretos o claves asociadas.	Aplicar primero a cuentas privilegiadas, servicio, API, integraciones y proveedor, con validación de dependencias.
Revisar persistencia: forwarding, OAuth apps, scheduled tasks, SSH keys, certificados.	Sin persistencia identificada o con plan de remediación.
Rehabilitar acceso por mínimo privilegio.	Aprobación de propietario, caducidad si es temporal, evidencia de revisión y retorno a mínimo privilegio.
Restablecer acceso remoto/VPN/ZTNA.	Solo por recurso, aplicación o segmento necesario; dispositivo conforme, MFA operativo, política aplicada y registro de sesión.

Tabla 61. Evidencias mínimas.

Evidencia	Detalle
Alerta y ticket	ID SIEM/SOC/IAM, severidad, runbook aplicado, fuentes de contraste y motivo de escalado/desescalado.
Identidad	UserID, grupos, privilegios, cambios, sesiones, tokens, MFA, origen/destino, dispositivo, zona horaria y retención disponible.
PAM/bastión	Grabación si existe, aprobación, comando, destino, duración, ventana y cuenta privilegiada o break-glass utilizada.
Cloud/correo	Reglas, consentimientos OAuth, accesos, auditoría, exportaciones, descargas, reenvíos y permisos modificados.
Endpoint/red	Dispositivo de origen, EDR/MDM, IP pública, VPN/proxy/DNS, red usada y telemetría que confirme o descarte compromiso local.
Cronología	Secuencia de accesos, cambios y acciones de contención, con desfases temporales y limitaciones documentadas.
VPN/ZTNA	Política aplicada, recurso/segmento autorizado, dispositivo, postura, origen, duración, sesión concurrente, bloqueo/revocación y evidencia de que no fue acceso plano.
Cuentas de servicio/proveedor	Responsable, finalidad, permisos, secreto/clave, rotación, dependencias, ventana, aprobación, caducidad y acciones de revocación o reactivación.

Tabla 62. Comunicación y escalado.

Comunicación	Criterio
Usuario afectado	Contacto por canal seguro, instrucciones de recuperación de credenciales y verificación.
Dirección	Solo si la cuenta tiene privilegios, impacto, datos o posible fraude.
DPD/Jurídico	Si existe acceso a datos personales o comunicación externa fraudulenta.
Proveedor	Si la cuenta pertenece a tercero, si una cuenta de servicio depende de su integración o si se detecta acceso desde su entorno.

Límites/No hacer:

No confiar en cambio de contraseña si hay tokens/sesiones activas sin revocar. No deshabilitar cuentas de servicio críticas sin plan de continuidad, ventana y dueño de aplicación. No reinstaurar privilegios antes de recertificar necesidad. No tratar VPN/ZTNA como acceso plano ni reactivar proveedores sin cuenta nominativa o responsable trazable, MFA, registro y caducidad.

Tabla 63. Cierre del runbook.

Entregable de cierre	Contenido mínimo
Informe de identidad	Cuenta, vector, privilegios, acciones, persistencia, sistemas tocados y remediación.
Acciones estructurales	MFA resistente, PAM, recertificación, cuentas de servicio, alertas, ZTNA por aplicación.
Mejora de detección	Ajustes de fuentes de alerta, normalización, retención, severidad, ticketing, falsos positivos y actualización del runbook/casos de uso.

RB-03. Explotación web/API en Oficina Virtual, AQUAPP, CRM o APIs**Tabla 64. Ficha de runbook.**

Campo	Contenido
Riesgos vinculados	R4, R7, R6, R10
Objetivo	Responder a indicios de explotación web/API reduciendo exposición y preservando evidencias sin ejecutar pruebas agresivas sobre producción.
Severidad mínima sugerida	S2 si intento bloqueado; S3 si posible acceso a datos o backend; S4 si exfiltración, caída de servicio crítico o explotación masiva.
Cautela de validación	Validar alcance con logs, request ID, trazas y reproducción controlada en entorno autorizado si existe; no lanzar PoC, fuzzing ni explotación contra producción.

Tabla 65. Disparadores y validación inicial.

Disparador / fuente	Qué valida
WAF/CDN/API Gateway	Reglas activadas, picos 4xx/5xx, payloads sospechosos, anomalía de tasa, bypass o abuso de autorización sin detallar regla explotable.
Aplicación/API/BBDD	Errores, trazas, subida de ficheros, cambios de privilegio, sesiones anómalas, consultas o accesos a datos fuera de patrón.
SIEM/SOC/MDR	Correlación entre IP, usuario, endpoint, base de datos, WAF, errores de aplicación y severidad por criticidad del servicio.
NDR/proxy/DNS	Origen recurrente, dominios o rutas inusuales, transferencia anómala, conexiones a backend no esperadas o salto desde frontal.
Reporte externo/proveedor	Aviso de usuario, investigador autorizado, proveedor o CSIRT externo, conservando la comunicación original y limitaciones.
DLP/cloud si aplica	Indicios de exportación, descarga o compartición asociada a la ventana de explotación.
Registrar regla o mitigación	Documentar condición, alcance, falsos positivos, responsable y rollback; la mitigación no debe ocultar evidencias sin exportarlas antes.

Tabla 66. Acciones iniciales.

Secuencia orientativa	Acciones
0-15 min	Preservar request, hora, IP, user-agent, usuario, endpoint, regla WAF y respuesta.
15-60 min	Identificar funcionalidad afectada, datos potencialmente accesibles, versión, despliegue y cambios recientes.
1-4 h	Activar AppSec, DPD si hay datos, proveedor web/front y equipo de aplicación.

Tabla 67. Contención controlada.

Contención	Condición de aprobación
Activar o endurecer regla WAF/API.	Aprobación AppSec/DIS; probar falso positivo y rollback.
Deshabilitar endpoint vulnerable o feature flag.	Aprobación dueño de aplicación y negocio.
Reducir tasa, bloquear IP/ASN o geografía si procede.	Aprobación SOC/AppSec; cautela con abonados legítimos.
Desactivar credenciales/API keys afectadas.	Aprobación dueño de servicio; plan de rotación.
Restaurar servicio web/API desde artefactos confiables si hubo modificación.	Build, configuración y secretos verificados; prueba funcional y de autorización antes de exponer a abonados.

Tabla 68. Erradicación, recuperación y retorno.

Erradicación / recuperación	Criterio de salida
Corregir vulnerabilidad y desplegar parche controlado.	Prueba funcional y seguridad; no explotación destructiva.
Revisar logs de acceso a datos y sesiones.	Determinar alcance de datos y usuarios afectados.
Rotar secretos expuestos.	Validar que no quedan secretos en repositorios o logs.
Monitorizar intentos posteriores.	WAF/SIEM sin recurrencia crítica.

Tabla 69. Evidencias mínimas.

Evidencia	Detalle
Alerta y ticket	ID WAF/SIEM/SOC, endpoint afectado, severidad, runbook, owner de aplicación y fuentes consultadas.
HTTP/API	Request/response relevante, cabeceras, sesión, usuario, endpoint, origen, método, códigos, acción WAF/CDN y trazas correladas.
Aplicación/BBDD	Logs de autorización, errores, consultas, objetos accedidos, identificadores de transacción, versión y despliegue vigente.
Red/proxy/NDR	Flujos, DNS, proxy, CDN, volumen de transferencia y relación con backend sin afirmar exfiltración sin contraste.
Datos	Tablas/objetos accedidos, volumen estimado, usuarios afectados si se conoce, hora, exportaciones y validación DPD si aplica.
Cambio	Commit, despliegue, configuración, regla WAF/API o mitigación aplicada, prueba de rollback y validación funcional.

Tabla 70. Comunicación y escalado.

Comunicación	Criterio
DPD/Jurídico	Si hay datos personales, exposición o acceso no autorizado.
Comunicación	Si afecta a portal de abonados o disponibilidad pública.
Proveedor	Front web/CDN/WAF/cloud si participa en publicación.

Límites/No hacer:

No lanzar fuzzing agresivo ni explotación en producción. No publicar detalles técnicos explotables. No bloquear tráfico amplio sin evaluar impacto en abonados.

Tabla 71. Cierre del runbook.

Entregable de cierre	Contenido mínimo
Informe AppSec	Vector, endpoint, impacto, datos, mitigación, corrección, pruebas y controles preventivos.
Backlog seguro	SDLC, pruebas OWASP, logging, autorización, secretos, WAF/API y revisión periódica.
Mejora de detección	Ajustes de fuentes de alerta, normalización, retención, severidad, ticketing, falsos positivos y actualización del runbook/casos de uso.

RB-04. Cloud/correo, BEC, OAuth o fuga SaaS**Tabla 72. Ficha de runbook.**

Campo	Contenido
Riesgos vinculados	R10, R2, R5, R6
Objetivo	Contener compromiso de buzón, colaboración cloud o configuración SaaS que pueda permitir BEC, fuga de datos o abuso de identidad.
Severidad mínima sugerida	S2 si buzón individual sin datos críticos; S3 si dirección, finanzas, proveedor o datos; S4 si BEC efectivo, exposición masiva o tenant comprometido.

Tabla 73. Disparadores y validación inicial.

Disparador / fuente	Qué valida
Correo/seguridad de email	Reglas de reenvío, envío masivo, suplantación, BEC, adjuntos o enlaces maliciosos, anomalías de cabeceras y destinatarios.
Cloud/SaaS/DLP	OAuth consent sospechoso, descarga masiva, cambios de permisos, compartición externa, exposición de repositorios o reglas DLP.
IAM/MFA/SIEM	Acceso anómalo al tenant, MFA fatigue, sesión desde origen no habitual, cambio de credenciales, token reutilizado o uso de cuenta de servicio/API cloud.
Proxy/DNS/NDR	Navegación hacia dominios de phishing, descarga desde SaaS, conexiones a destinos no habituales o transferencia fuera de patrón.
Usuario/proveedor cloud	Aviso de mensajes enviados sin autorización, fraude, alerta de proveedor, riesgo de cuenta o configuración.

Disparador / fuente	Qué valida
PAM/bastión/proveedor SaaS	Acceso administrativo cloud fuera de ventana, soporte de proveedor, cambios de permisos, app registration o secreto creado/modificado.

Tabla 74. Acciones iniciales.

Secuencia orientativa	Acciones
0-15 min	Revocar sesiones, preservar auditoría, confirmar usuario, buzón, IP, dispositivo, reglas, OAuth/API y cuenta de servicio si aplica.
15-60 min	Analizar alcance: mensajes enviados, adjuntos, destinatarios, datos compartidos, accesos, consentimientos, apps y permisos.
1-4 h	Activar IAM, DPD/Jurídico si hay datos, Comunicación si hay fraude o suplantación externa.

Tabla 75. Contención controlada.

Contención	Condición de aprobación
Revocar tokens/sesiones y reset MFA.	Aprobación IAM; verificar por canal alternativo.
Eliminar reglas maliciosas de reenvío y apps OAuth no autorizadas.	Aprobación cloud/IAM; conservar evidencia previa.
Bloquear dominios, remitentes o URLs maliciosas.	Aprobación SOC/correo.
Deshabilitar compartición externa temporal en ámbito afectado.	Aprobación CISO/cloud si afecta negocio.
Restaurar canales de correo/cloud críticos o activar alternativos.	Validar auditoría, retención, permisos, DLP y capacidad de comunicación de crisis antes de normalizar el servicio.
Suspender app OAuth/API o integración sospechosa.	Aprobación cloud/IAM y dueño de servicio; preservar configuración previa y validar impacto operativo.
Rotar secretos cloud asociados.	Aprobación IAM/cloud; coordinar con aplicación/proveedor y probar continuidad antes de normalizar.

Tabla 76. Erradicación, recuperación y retorno.

Erradicación / recuperación	Criterio de salida
Revisar buzones relacionados y cuentas de dirección/finanzas.	Sin evidencias de expansión.
Recuperar configuración segura y permisos mínimos.	Validar DLP, retención, auditoría, mínimo privilegio y separación de funciones administrativas.
Notificar a destinatarios afectados si procede.	Aprobación Legal/Comunicación.
Recertificar apps OAuth/API, proveedores SaaS y cuentas administrativas.	Sin consentimientos no autorizados, secretos vigentes no justificados ni proveedores con acceso fuera de contrato/ventana.

Tabla 77. Evidencias mínimas.

Evidencia	Detalle
Alerta y ticket	ID correo/cloud/SIEM, severidad, usuario/buzón, runbook aplicado, fuentes consultadas y brechas de retención.
Correo	Mensajes, headers, reglas, forwarding, IP, hora, usuario, adjuntos, URLs, destinatarios y trazas de envío/recepción.

Evidencia	Detalle
SaaS/cloud	Descargas, comparticiones, OAuth, permisos, eDiscovery, DLP, auditoría de acceso y cambios de configuración.
Identidad	Sesiones, MFA, tokens, cambios de credencial, dispositivos, IPs y correlación con IAM/PAM/VPN.
Fraude/BEC	Solicitud de pago, IBAN, factura, proveedor, cadena de correos, destinatarios y decisiones de comunicación.
Cronología	Inicio observado, primera alerta, contención, revocación, recuperación y cierre, con zona horaria normalizada.
OAuth/API/servicio	App ID, consentimiento, permisos, secreto/certificado, propietario, fecha de creación, rotación, IP/origen, proveedor y revocación.

Tabla 78. Comunicación y escalado.

Comunicación	Criterio
Finanzas/Compras	Aviso urgente si posible BEC o cambio de cuenta de proveedor.
DPD/Jurídico	Si hay datos personales o exposición externa.
Usuarios	Mensaje de seguridad interno con instrucciones, sin detalles sensibles.

Límites/No hacer:

No borrar correos/reglas antes de exportar evidencia. No responder al atacante. No enviar comunicación masiva sin validar alcance y mensaje. No reactivar OAuth, API o proveedor SaaS sin recertificación de permisos, secreto rotado si aplica y aprobación del dueño.

Tabla 79. Cierre del runbook.

Entregable de cierre	Contenido mínimo
Informe cloud/correo	Cuenta, vector, mensajes, datos, permisos, acciones y recomendaciones.
Mejoras	MFA resistente, acceso condicional, DLP, DMARC/SPF/DKIM, alertas OAuth, formación anti-BEC.
Mejora de detección	Ajustes de fuentes de alerta, normalización, retención, severidad, ticketing, falsos positivos y actualización del runbook/casos de uso.

RB-05. Proveedor crítico comprometido o caído**Tabla 80. Ficha de runbook.**

Campo	Contenido
Riesgos vinculados	R5, R2, R3, R10, R11
Objetivo	Gestionar incidentes que nacen o se materializan en proveedores críticos sin asumir que la responsabilidad se transfiere fuera de ACME Waters.
Severidad mínima sugerida	S3 si afecta servicio crítico, datos, acceso remoto o integración; S4 si afecta continuidad del agua, identidad, pagos, atención masiva o OT.

Tabla 81. Disparadores y validación inicial.

Disparador / fuente	Qué valida
Proveedor	Notificación de incidente, caída, brecha, ransomware, cambio urgente, mantenimiento no planificado o limitación de servicio.
SOC/SIEM/IAM	Acceso de tercero anómalo, cuenta temporal, VPN, API, integración, sesión de soporte o origen proveedor fuera de patrón.
Negocio/continuidad	Indisponibilidad de CALLMATIC, Servired, cloud/correo, web front, soporte industrial u otro servicio crítico.
Inteligencia/CSIRT/OSINT	Aviso público de vulnerabilidad, brecha o campaña que afecte a proveedor usado por ACME Waters.
Contrato/SLA/OLA	Incumplimiento de comunicación, escalado, evidencias mínimas, subcontratación o continuidad pactada.

Tabla 82. Acciones iniciales.

Secuencia orientativa	Acciones
0-15 min	Abrir ticket maestro, identificar proveedor, servicio, contrato, contacto de emergencia, dependencia y datos tratados.
15-60 min	Solicitar informe inicial: alcance, hora, impacto, acciones, IOCs, datos, continuidad y previsión.
1-4 h	Evaluar desconexión temporal, canales alternativos, revocación de accesos y comunicación a negocio.

Tabla 83. Contención controlada.

Contención	Condición de aprobación
Suspender cuenta/API del proveedor.	Aprobación CISO/DIS y dueño del servicio; validar impacto.
Restringir acceso a landing zone o activo único.	Aprobación DIS; registrar cambios.
Cambiar credenciales compartidas o secretos de integración.	Aprobación dueño técnico; coordinar con proveedor.
Activar alternativa operativa.	Aprobación continuidad/negocio.
Activar canales alternativos o degradación controlada.	Continuidad/negocio valida operación mínima y comunicación a usuarios internos o abonados.
Reactivar accesos del proveedor.	Solo tras evidencia de contención, recuperación y aprobación formal de dueño de servicio, CISO y Jurídico si aplica.

Tabla 84. Erradicación, recuperación y retorno.

Erradicación / recuperación	Criterio de salida
Validar evidencia de recuperación del proveedor.	No reabrir accesos sin informe mínimo y aprobación.
Revisar logs de tercero en ACME.	Sin acceso no autorizado posterior.
Ejecutar salida ordenada temporal o definitiva si procede.	Plan de transición y continuidad.

Tabla 85. Evidencias mínimas.

Evidencia	Detalle
Alerta y ticket	ID de incidente interno, origen del aviso, severidad, proveedor, servicio afectado y runbook aplicado.
Contrato	Servicio, SLA/OLA, cláusulas de seguridad, contactos, subcontratación, datos tratados y obligaciones de comunicación.
Accesos	Cuentas nominales, sesiones, IP, MFA, API, VPN, caducidad, cambios y acciones del proveedor contra ACME.
Proveedor	Informe, IOCs, timeline, impacto, acciones y evidencias, marcado como evidencia externa y sujeto a contraste.
Correlación interna	Logs SIEM/IAM/VPN/API/proxy/firewall que confirmen accesos, impacto o ausencia de uso anómalo en ACME.
Limitaciones	Lagunas de información, retención insuficiente, dependencia contractual, fuentes no disponibles y acciones pendientes.

Tabla 86. Comunicación y escalado.

Comunicación	Criterio
Compras/Jurídico	Gestionar obligaciones contractuales, evidencia y derecho de auditoría.
DPD	Si trata o expone datos personales.
Operaciones	Si es proveedor industrial o servicio esencial.
Negocio afectado	Activar canales alternativos y mensajes a usuarios internos.

Límites/No hacer:

No permitir accesos genéricos o reactivaciones sin evidencia. No asumir que el proveedor ha contenido el incidente sin pruebas mínimas. No trasladar responsabilidad regulatoria a contrato.

Tabla 87. Cierre del runbook.

Entregable de cierre	Contenido mínimo
Informe de tercero	Impacto, datos, accesos, tiempos, continuidad, evidencias y medidas de no repetición.
Acciones contractuales	Revisión SLA, notificación, pruebas conjuntas, derecho de auditoría y plan de salida.
Mejora de detección	Ajustes de fuentes de alerta, normalización, retención, severidad, ticketing, falsos positivos y actualización del runbook/casos de uso.

RB-06. Alerta IT/OT o acceso remoto industrial sospechoso**Tabla 88. Ficha de runbook.**

Campo	Contenido
Riesgos vinculados	R8, R5, R6, R11

Campo	Contenido
Objetivo	Responder a señales en frontera IT/OT o acceso remoto industrial preservando continuidad operacional, safety, calidad del agua y medioambiente, sin intervenir en OT de producción salvo aprobación formal de Operaciones.
Severidad mínima sugerida	S3 por defecto si afecta frontera IT/OT, acceso remoto industrial, proveedor OT o visibilidad limitada; S4 si hay impacto operativo, seguridad de personas, calidad del agua, medioambiente o continuidad.

Tabla 89. Disparadores y validación inicial.

Disparador / fuente	Qué valida
DMZ OT/jump server/PAM/VPN	Inicio de sesión fuera de ventana, proveedor no esperado, destino no autorizado, fallo MFA, transferencia anómala, sesión administrativa o uso de cuenta no nominal.
Firewall industrial / frontera IT/OT	Flujo nuevo IT→OT, puerto no documentado, origen proveedor, comunicación hacia dominio funcional OT o regla modificada sin validación, sin asumir topología de planta.
Sensor pasivo OT / historian / intercambio	Cambio de patrón, actividad no habitual, errores de comunicación, tráfico inesperado o anomalía de intercambio observada pasivamente, sin escaneo activo ni despliegue intrusivo.
SIEM/SOC/MDR	Correlación con identidad, VPN, bastión, firewall, DNS/proxy, cambios recientes y avisos de proveedor, separando alerta IT de impacto OT confirmado.
Operaciones	Comportamiento anómalo en supervisión, mantenimiento, comunicaciones de instalación, calidad del agua, safety, medioambiente o continuidad operacional.
Proveedor OT / mantenimiento	Solicitud de acceso fuera de ventana, aviso de compromiso, indisponibilidad de soporte, cambio remoto no previsto o transferencia no justificada, siempre contrastado con Operaciones.

Tabla 90. Acciones iniciales.

Secuencia orientativa	Acciones
0-15 min	Contactar Operaciones antes de actuar; no ejecutar comandos, escaneos, reinicios ni bloqueos; preservar logs de frontera; identificar instalación, sesión, cuenta, proveedor y dominio funcional afectado.
15-60 min	Validar si existe ventana aprobada, orden de trabajo, responsable de planta, necesidad operacional, riesgo para safety/calidad/medioambiente y canal de reversión.
1-4 h	Activar célula IT/OT, clasificar impacto con Operaciones, preparar contención reversible, no intrusiva y con criterio de parada; definir alternativas operativas si las hubiera.
Antes de cualquier acción OT	Registrar aprobación de Operaciones, responsable ejecutor, ventana, alcance, criterio de parada, reversibilidad, evidencia ya preservada y comunicación con proveedor si aplica.

Tabla 91. Contención controlada.

Contención	Condición de aprobación
Solicitar cierre o bloqueo de sesión remota industrial.	Solo con aprobación de Operaciones; validar impacto en mantenimiento, proceso y soporte; conservar logs de sesión antes de cortar si el riesgo lo permite.
Limitar cuenta o acceso de proveedor OT.	Aprobación Operaciones + CISO/DIS; comprobar alternativa de soporte, mínimo privilegio y efecto sobre continuidad operacional.
Cerrar o restringir flujo IT/OT no autorizado en DMZ.	Aprobación Operaciones/DIS; cambio reversible, alcance limitado, rollback definido y validación de que no afecta safety, calidad del agua ni continuidad.
Aumentar monitorización pasiva.	Validación de Operaciones si requiere despliegue físico o cambio de red; no usar consultas activas, escaneo, fuzzing ni explotación.
Preparar recuperación de configuración OT desde respaldo aprobado si procede.	Solo por personal OT autorizado; comparación con baseline/orden de trabajo, evidencia preservada, prueba no intrusiva, ventana y criterio de parada.
Activar modo operativo alternativo o manual.	Solo si lo decide Operaciones conforme a PCN/PCTIC/PRD o procedimiento de planta; registrar impacto, comunicación, responsable y retorno previsto.

Tabla 92. Erradicación, recuperación y retorno.

Erradicación / recuperación	Criterio de salida
Confirmar si hubo cambio de configuración, sesión remota o intervención funcional.	Comparar con orden de trabajo, logs, respaldo autorizado y validación de Operaciones; no inferir cambio de planta solo por alerta de red.
Revertir cambio no autorizado si procede.	Solo por personal OT autorizado, con ventana, criterio de parada, reversibilidad, comunicación con planta y evidencia previa suficiente.
Restablecer acceso industrial por ventana controlada.	Aprobación de Operaciones, cuenta nominal, mínimo privilegio, sesión registrada y monitorización reforzada.
Retorno operacional controlado.	No cerrar hasta validar función, disponibilidad, calidad del agua, safety/medioambiente si aplica, ausencia de nuevas alertas relevantes y aceptación de Operaciones.

Tabla 93. Evidencias mínimas.

Evidencia	Detalle
Alerta y ticket	ID SIEM/SOC/OT, severidad, activo o dominio funcional, runbook, aprobación de Operaciones, fuentes consultadas y límites de visibilidad.
Frontera IT/OT	Firewall, jump server, PAM, VPN, MFA, sesión, archivos transferidos, hora, origen, destino, puerto, regla relacionada y evidencia de ventana autorizada.
Operaciones	Orden de trabajo, responsable, ventana, impacto de proceso, comunicación con planta, evaluación de safety/calidad/medioambiente y criterio de parada/reversión.
Sensor pasivo / historian / intercambio	Flujos, anomalías, historian/intercambio, alertas no intrusivas, baseline disponible, límites de visibilidad y ausencia de consultas activas.

Evidencia	Detalle
Red/identidad	Correlación con IAM, DNS/proxy, NDR, cambios recientes, accesos de proveedor y tickets de mantenimiento.
Cautela	No incluir resultados de escaneos activos, explotación o acciones intrusivas salvo aprobación formal excepcional, ventana de Operaciones, criterio de parada y justificación documentada.
Proveedor OT	Contacto autorizado, solicitud de acceso, evidencias aportadas, versión de respuesta, acciones ejecutadas por tercero, responsable y compromisos de actualización.

Tabla 94. Comunicación y escalado.

Comunicación	Criterio
Operaciones	Primer destinatario operativo; sin validación no hay acción intrusiva.
CISO/DIS	Coordinación de seguridad y tecnología.
Proveedor OT	Solo por canal autorizado, registrando contacto y respuesta.
Dirección	S4 o impacto en servicio esencial, safety o medioambiente.

Límites/No hacer:

No ejecutar Nmap, Nessus, fuzzing, explotación, fuerza bruta, scripts activos ni consultas no aprobadas contra OT de producción. No aplicar contención automática desde IT. No reiniciar, parchear, aislar, desplegar agentes, cambiar configuración ni capturar tráfico de forma intrusiva en componentes OT sin Operaciones, ventana, criterio de parada, reversibilidad y registro de decisión.

Tabla 95. Cierre del runbook.

Entregable de cierre	Contenido mínimo
Informe IT/OT	Flujo, sesión, instalación o dominio funcional, impacto confirmado o descartado, autorización, acciones, reversión, evidencias, limitaciones de visibilidad e hipótesis no confirmadas.
Mejoras	Acceso remoto industrial, DMZ OT, cuentas nominales, monitorización pasiva, ventanas, respaldos de configuración, procedimientos manuales, proveedores y pruebas no intrusivas.
Mejora de detección	Ajustes de fuentes de alerta, normalización, retención, severidad, ticketing, reducción de falsos positivos, coordinación Operaciones-SOC y actualización del runbook/casos de uso sin incorporar reglas SIEM excesivamente detalladas ni acciones invasivas.

RB-07. Indisponibilidad del CPD o servicios base

Tabla 96. Ficha de runbook.

Campo	Contenido
Riesgos vinculados	R3, R6, R11
Objetivo	Gestionar indisponibilidad técnica o ciber del CPD, AD/DNS/NTP, virtualización, almacenamiento o red, priorizando continuidad y recuperación limpia.
Severidad mínima sugerida	S3 si afecta servicios críticos; S4 si impide operación, recuperación o continuidad del agua.

Tabla 97. Disparadores y validación inicial.

Disparador / fuente	Qué valida
Monitorización infraestructura	Caída de hosts, almacenamiento, red, virtualización, AD, DNS, NTP, servicios internos, capacidad o errores recurrentes.
SIEM/SOC/MDR	Señales de ataque coordinado, borrado, cambios no autorizados, fallo de controles, autenticación anómala o precursor de ransomware.
NDR/firewall/DNS/proxy	Saturación, caída de segmentos, cambios de rutas, resolución DNS anómala, bloqueo masivo o pérdida de visibilidad.
Usuarios/service desk	Aplicaciones inaccesibles, lentitud masiva, errores de autenticación, imposibilidad de operar o reportes concentrados.
Proveedoror/infra	Incidencia eléctrica, comunicaciones, cloud, virtualización, almacenamiento, licencias o dependencia externa.

Tabla 98. Acciones iniciales.

Secuencia orientativa	Acciones
0-15 min	Confirmar si es incidente ciber, fallo técnico o mixto; abrir ticket maestro; preservar logs de cambio y monitorización.
15-60 min	Identificar servicios afectados, dependencia de identidad, backup, red, cloud y proveedores.
1-4 h	Activar continuidad si el impacto se aproxima a MTD/RTO preliminar o amenaza procesos críticos; preparar canales alternativos, priorización BIA y plan de recuperación limpia con responsables.

Tabla 99. Contención controlada.

Contención	Condición de aprobación
Congelar cambios no urgentes.	Aprobación DIS; evitar empeorar estado.
Aislar segmento si hay evidencia de ataque.	Aprobación CISO/DIS; evaluar impacto.
Activar contingencia de identidad o DNS.	Aprobación infraestructura; registrar cuentas break-glass.
Derivar a canales alternativos.	Aprobación continuidad/negocio.
Seleccionar punto de restauración o reconstrucción.	Backup/snapshot validado, aislado de dominio comprometido y coherente con RPO orientativo; registrar limitaciones.
Activar canales alternativos de atención y operación.	Continuidad y negocio aprueban guion, alcance y criterios de desactivación.
Retorno por oleadas.	No reincorporar aplicaciones hasta que servicios base estén estables, monitorizados y validados.

Tabla 100. Erradicación, recuperación y retorno.

Erradicación / recuperación	Criterio de salida
Restaurar servicios base priorizados.	Identidad/DNS/NTP antes de aplicaciones dependientes.
Recuperar virtualización/almacenamiento/red.	Validación funcional y revisión de integridad.
Reincorporar aplicaciones por prioridad BIA.	Dueño de servicio valida retorno.

Tabla 101. Evidencias mínimas.

Evidencia	Detalle
Alerta y ticket	ID monitorización/SIEM/SOC, servicio, severidad, propietario, runbook y hora de detección.
Monitorización	Alertas, métricas, disponibilidad, capacidad, salud de AD/DNS/NTP, almacenamiento, red, virtualización y logs de infraestructura.
Cambios	Últimas modificaciones, responsables, ventanas, CAB/ crisis, configuración, rollback y detección de cambios no autorizados.
Seguridad	EDR/SIEM/NDR/IAM que descarte o confirme ataque, borrado, abuso de credenciales o precursor de ransomware.
Recuperación	Prueba, hora de retorno, validación funcional, integridad, deuda pendiente y monitorización reforzada.
Limitaciones	Fuentes no disponibles, pérdida de logs, desfases horarios, degradación de sensores o dependencia de proveedor.

Tabla 102. Comunicación y escalado.

Comunicación	Criterio
Dirección	S3/S4 con impacto y previsión de recuperación.
Negocio	Canales alternativos y priorización.
Proveedores	Cloud, comunicaciones, hardware, soporte o DR.

Límites/No hacer:

No reiniciar componentes críticos en cadena sin diagnóstico mínimo. No restaurar datos sin confirmar consistencia. No ocultar degradación real a negocio si afecta MTD/RTO orientativo.

Tabla 103. Cierre del runbook.

Entregable de cierre	Contenido mínimo
Informe de disponibilidad	Causa, impacto, tiempo, recuperación, decisiones y mejoras de resiliencia.
Plan de mejora	HA, DR, backup, monitorización, control de cambios y pruebas.
Mejora de detección	Ajustes de fuentes de alerta, normalización, retención, severidad, ticketing, falsos positivos y actualización del runbook/casos de uso.
Explotación conocida	Priorizar por explotación activa o campaña; no descargar ni ejecutar PoC contra producción.

RB-08. Vulnerabilidad crítica o zero-day explorable**Tabla 104. Ficha de runbook.**

Campo	Contenido
Riesgos vinculados	R7, R4, R8, R5
Objetivo	Gestionar vulnerabilidad crítica con explotación conocida o alta exposición, priorizando mitigación segura y validada.

Campo	Contenido
Severidad mínima sugerida	S2 si no expuesto y mitigado; S3 si activo crítico/expuesto; S4 si explotación activa, identidad, CPD, OT o servicio esencial.
Cautela de comprobación	Usar inventario, versión, configuración, exposición, logs y avisos oficiales. En activos críticos u OT, cualquier consulta activa requiere aprobación, ventana y criterio de parada.

Tabla 105. Disparadores y validación inicial.

Disparador / fuente	Qué valida
Inteligencia/fabricante/CSIRT	Aviso de CVE crítica, explotación activa, workaround, mitigación temporal o impacto sobre producto usado por ACME.
Inventario/exposición	Activo vulnerable expuesto o crítico, versión afectada, propietario, zona, dependencia BIA y presencia en frontera IT/OT.
SIEM/SOC/NDR/WAF	Intentos de explotación, payload, anomalía compatible, IOC relacionado o actividad posterior sin reproducir explotación destructiva.
Gestión de vulnerabilidades	Resultado de escáner en IT, inventario, validación documental o comprobación no intrusiva. En OT de producción, solo verificación pasiva, evidencia de proveedor o consulta aprobada por Operaciones.
Proveedor	Producto afectado en cloud, web, VPN, firewall, OT, aplicación gestionada o servicio externo; en OT, contrastar con Operaciones antes de inferir exposición o impacto.
Compensar sin explotar	Cuando no pueda parchearse, aplicar mitigación defensiva reversible y monitorización reforzada; no validar con explotación real sobre producción.

Tabla 106. Acciones iniciales.

Secuencia orientativa	Acciones
0-15 min	Identificar activos potencialmente afectados con inventario y exposición.
15-60 min	Clasificar por criticidad, exposición, explotación conocida, disponibilidad de parche y workaround.
1-4 h	Definir plan: mitigar, parchear, aislar, monitorizar o aceptar temporalmente con riesgo documentado.

Tabla 107. Contención controlada.

Contención	Condición de aprobación
Aplicar workaround recomendado por fabricante o fuente oficial.	Aprobación dueño técnico; validar impacto.
Restringir exposición externa.	Aprobación DIS/AppSec; cuidado con servicios de abonados.
Activar reglas WAF/IPS/EDR/SIEM.	Aprobación SOC/DIS; monitorizar falsos positivos.
Pausar servicio vulnerable si riesgo supera tolerancia.	Aprobación CISO/negocio; plan alternativo.
Preparar rollback o restauración si el parche degrada servicio crítico.	Plan probado o aprobado por cambio de crisis; no prometer disponibilidad sin evidencia.

Tabla 108. Erradicación, recuperación y retorno.

Erradicación / recuperación	Criterio de salida
Aplicar parche en ventana controlada.	Prueba previa si es sistema crítico u OT; en OT, ventana de Operaciones, criterio de parada y reversibilidad.
Verificar remediación.	Comprobación de versión/configuración, evidencia de proveedor, logs o validación no intrusiva. En OT de producción no usar escaneo activo ni explotación para confirmar.
Buscar explotación histórica.	Revisar logs retrospectivos desde ventana de exposición.

Tabla 109. Evidencias mínimas.

Evidencia	Detalle
Alerta y ticket	ID de aviso/CVE, fuente, severidad, activos vinculados, runbook, responsable y criterio de priorización.
Inventario	Activos, versiones, exposición, propietario, criticidad, zona, dependencia BIA y relación IT/OT si aplica.
Detección	Búsquedas SIEM, logs WAF/proxy/NDR, IOCs, intentos observados, resultados y limitaciones de cobertura.
Decisiones	Parche, workaround, bloqueo temporal, aceptación de riesgo, responsable, hora, ventana, rollback y riesgo residual.
Proveedor	Avisos de fabricante/proveedor, SLA, mitigaciones recomendadas, impacto en servicios gestionados y evidencias aportadas.
Validación	Comprobación posterior no destructiva, monitorización reforzada, evidencia de proveedor si aplica y criterio de cierre sin explotar producción ni escanear OT activamente.

Tabla 110. Comunicación y escalado.

Comunicación	Criterio
CISO/DIS	Prioridad y riesgo residual.
Operaciones	Obligatorio si activo OT o dependencia operacional.
Proveedor	Parche, workaround, evidencias y soporte.

Límites/No hacer:

No lanzar PoC destructiva para confirmar en producción. No parchear OT sin pruebas, ventana, Operaciones, criterio de parada y reversibilidad. No usar escaneo activo ni explotación sobre OT de producción para validar exposición. No cerrar riesgo sin verificación posterior.

Tabla 111. Cierre del runbook.

Entregable de cierre	Contenido mínimo
Informe de vulnerabilidad crítica	Alcance, exposición, decisiones, mitigación, remediación, verificación y excepciones.
Actualización de vulnerabilidades	Inventario, procedimiento, SLA interno a validar, detección y reporting.

Entregable de cierre	Contenido mínimo
Mejora de detección	Ajustes de fuentes de alerta, normalización, retención, severidad, ticketing, falsos positivos y actualización del runbook/casos de uso.

RB-09. Endpoint/teletrabajo comprometido o dispositivo perdido

Tabla 112. Ficha de runbook.

Campo	Contenido
Riesgos vinculados	R9, R2, R1, R10
Objetivo	Contener incidentes de movilidad, teletrabajo y endpoint manteniendo mínimo privilegio, cifrado, MDM/EDR, VPN/ZTNA acotado y revocación de acceso.
Severidad mínima sugerida	S1/S2 si dispositivo estándar; S3 si TI, dirección, proveedor, datos o cuenta privilegiada.

Tabla 113. Disparadores y validación inicial.

Disparador / fuente	Qué valida
EDR/XDR/MDM	Malware, conexión C2, incumplimiento de postura, falta de cifrado, jailbreak/root, EDR deshabilitado o última conexión sospechosa.
IAM/VPN/ZTNA	Conexión fuera de horario/perfil, dispositivo no gestionado, MFA sospechoso, sesión desde origen no habitual, token persistente o acceso a recurso no autorizado por política.
Proxy/DNS/NDR	Navegación a phishing, C2, descarga maliciosa, transferencia fuera de patrón o uso de red no corporativa.
Usuario/service desk	Pérdida, robo, phishing, comportamiento anómalo, manipulación física o sospecha de uso no autorizado.
SOC/MDR	Actividad posterior desde la cuenta o dispositivo y correlación con otros endpoints, correo o cloud.
PAM/bastión/guardia TI	Uso administrativo desde teletrabajo, sesión fuera de ventana, destino no habitual o ausencia de registro suficiente.

Tabla 114. Acciones iniciales.

Secuencia orientativa	Acciones
0-15 min	Identificar dispositivo, usuario, perfil, cifrado, MDM, última conexión, datos, accesos, política VPN/ZTNA y privilegios del usuario.
15-60 min	Revocar sesiones, aislar dispositivo si online, preservar EDR, validar cuenta y suspender accesos remotos no necesarios.
1-4 h	Evaluar fuga de datos, credenciales, correo/cloud y aplicaciones accedidas.

Tabla 115. Contención controlada.

Contención	Condición de aprobación
Aislar endpoint desde EDR.	Aprobación técnica; verificar que no afecta servicio crítico.
Borrado remoto si pérdida/robo y cifrado dudoso.	Aprobación CISO/IAM/DPD; registrar justificación.

Contención	Condición de aprobación
Revocar VPN/ZTNA y tokens.	Aprobación IAM/SOC; limitar por aplicación/recurso y registrar impacto sobre continuidad del usuario.
Cambiar credenciales y MFA.	Validar usuario por canal alternativo.
Restituir puesto o acceso remoto.	Entrega de equipo limpio o reimagen validada, cifrado y MDM/EDR conforme; usuario revalidado.
Suspender perfil administrativo desde teletrabajo.	Aprobación CISO/IAM; mantener guardia por bastión/PAM/MFA y canal autorizado si el servicio esencial lo requiere.
Reactivar VPN/ZTNA.	Solo con dispositivo conforme, usuario revalidado, MFA operativo, perfil mínimo y registro de sesión.

Tabla 116. Erradicación, recuperación y retorno.

Erradicación / recuperación	Criterio de salida
Reimagen o limpieza del dispositivo.	No devolver a producción sin EDR/MDM conforme.
Revisión de actividad de cuenta.	Sin señales de abuso posterior.
Rehabilitación por perfil mínimo.	Ventanas, recursos, permisos y dispositivos revisados; acceso remoto sin privilegios innecesarios.
Recertificar acceso de teletrabajo y proveedor asociado.	Caducidad, justificación, postura de dispositivo, MFA y mínimo privilegio documentados.

Tabla 117. Evidencias mínimas.

Evidencia	Detalle
Alerta y ticket	ID EDR/MDM/IAM/SOC, severidad, usuario, dispositivo, runbook y fuentes consultadas.
Dispositivo	Número de activo, cifrado, MDM, EDR, usuario, ubicación conocida, última conexión, procesos, hashes y conexiones.
Cuenta	Sesiones, MFA, aplicaciones, correo, cloud, VPN/ZTNA, tokens, cambios de credencial, privilegios y revocaciones.
Red	IP pública, DNS/proxy/NDR, red usada, dominios, descargas, C2 o indicios de transferencia.
Datos	Datos locales o sincronizados potencialmente expuestos, minimización de datos personales y decisión de borrado remoto si aplica.
Acciones	Aislamiento, bloqueo, recuperación, entrega a soporte, custodia física y validación antes de reactivar.
Acceso remoto	Política VPN/ZTNA, recurso permitido, dispositivo, postura, origen, duración, sesión, aprobación de excepción y revocación.

Tabla 118. Comunicación y escalado.

Comunicación	Criterio
Usuario	Instrucciones de seguridad, recuperación, validación de identidad y condiciones para volver a acceder en remoto.

Comunicación	Criterio
Responsable de área	Si afecta disponibilidad del puesto o datos de negocio.
DPD	Si hay posible pérdida de datos personales.

Límites/No hacer:

No asumir que el cifrado existe sin evidencia. No permitir BYOD o no gestionados a aplicaciones críticas sin control. No reactivar sesión hasta revisar cuenta. No convertir VPN/ZTNA en acceso plano ni permitir administración remota sin PAM/bastión, MFA, registro y aprobación.

Tabla 119. Cierre del runbook.

Entregable de cierre	Contenido mínimo
Informe endpoint	Activo, cuenta, datos, acciones MDM/EDR, impacto y mejora.
Mejoras	MDM, cifrado, ZTNA, postura, perfiles y formación.
Mejora de detección	Ajustes de fuentes de alerta, normalización, retención, severidad, ticketing, falsos positivos y actualización del runbook/casos de uso.

RB-10. Brecha o exposición de datos personales**Tabla 120. Ficha de runbook.**

Campo	Contenido
Riesgos vinculados	R4, R10, R5, R6
Objetivo	Gestionar exposición, acceso no autorizado o pérdida de datos personales con trazabilidad técnica y prudencia jurídica.
Severidad mínima sugerida	S3 si hay datos personales confirmados o probables; S4 si volumen alto, datos sensibles, publicación o impacto reputacional/regulatorio.

Tabla 121. Disparadores y validación inicial.

Disparador / fuente	Qué valida
DLP/SIEM/cloud	Descarga masiva, compartición externa, exfiltración probable, regla DLP, repositorio expuesto o acceso anómalo a datos.
Aplicación/API/BBDD	Consulta o exportación fuera de patrón, abuso de autorización, acceso a datos de abonados o errores que exponen información.
WAF/proxy/NDR	Transferencia o acceso externo asociado a la ventana, origen/destino, volumen y posible ruta de salida.
Proveedor	Notificación de brecha o exposición en servicio tratado, con evidencias y limitaciones identificadas como externas.
Reporte externo	Aviso de investigador, abonado, autoridad o medio, conservando comunicación original y canal de entrada.

Tabla 122. Acciones iniciales.

Secuencia orientativa	Acciones
0-15 min	Preservar evidencia, detener exposición visible si no destruye prueba, activar DPD/Jurídico.

Secuencia orientativa	Acciones
15-60 min	Determinar tipo de datos, volumen, sujetos afectados, sistemas, acceso y ventana temporal.
1-4 h	Preparar análisis de riesgo para derechos y libertades, comunicación y contención.

Tabla 123. Contención controlada.

Contención	Condición de aprobación
Cerrar exposición pública o enlace compartido.	Aprobación técnica inmediata; capturar evidencia antes o simultáneamente si posible.
Revocar credenciales o tokens utilizados.	Aprobación IAM.
Suspender integración o proveedor afectado.	Aprobación CISO/Jurídico/negocio.
Bloquear exfiltración o canal.	Aprobación SOC/DIS; registrar impacto.
Restaurar confidencialidad y control de acceso.	Permisos, enlaces, integraciones y comparticiones revisadas; evidencia de cese de exposición.

Tabla 124. Erradicación, recuperación y retorno.

Erradicación / recuperación	Criterio de salida
Confirmar alcance de datos.	DPD/Jurídico valida criterios de notificación.
Corregir causa raíz.	Configuración, aplicación, identidad, proveedor o proceso.
Notificar si procede.	Solo por canales aprobados y con contenido validado.

Tabla 125. Evidencias mínimas.

Evidencia	Detalle
Alerta y ticket	ID DLP/SIEM/cloud/app, severidad, sistema, runbook, DPD/Jurídico activado y fuentes de evidencia.
Datos	Categorías, volumen estimado, titulares, periodo, fuente, exportaciones y nivel de confianza de la estimación.
Acceso	Usuarios, IP, aplicación, logs, permisos, proveedor, sesiones, API, WAF/proxy/NDR y cambios de autorización.
Exfiltración/exposición	Evidencias de transferencia, compartición, publicación, descarga o exposición, separando hecho, inferencia y limitación.
Decisiones	Cierre de exposición, contención, comunicación, notificación, medidas compensatorias y validación DPD/Jurídico.
Cronología	Inicio, detección, contención, cierre de exposición, recuperación y revisión de retención.

Tabla 126. Comunicación y escalado.

Comunicación	Criterio
DPD/Jurídico	Obligatorio desde el inicio si hay datos personales.

Comunicación	Criterio
Dirección	S3/S4 o riesgo reputacional.
Comunicación	Mensajes a abonados/medios si procede.
Proveedor	Si interviene encargado o subencargado.

Límites/No hacer:
No afirmar ausencia de brecha sin evidencias suficientes. No retrasar la participación del DPD. No comunicar a afectados sin validación jurídica.

Tabla 127. Cierre del runbook.

Entregable de cierre	Contenido mínimo
Informe de brecha	Hechos, datos, alcance, riesgo, medidas, notificación, evidencias y acciones.
Mejoras	DLP, permisos, logging, cifrado, SDLC, proveedores y formación.
Mejora de detección	Ajustes de fuentes de alerta, normalización, retención, severidad, ticketing, falsos positivos y actualización del runbook/casos de uso.

RB-11. DDoS o indisponibilidad de servicios públicos

Tabla 128. Ficha de runbook.

Campo	Contenido
Riesgos vinculados	R3, R4, R5
Objetivo	Mantener disponibilidad de servicios expuestos y reducir impacto en abonados, atención y reputación.
Severidad mínima sugerida	S2 si degradación menor; S3 si afecta Oficina Virtual/AQUAPP/web/API; S4 si afecta comunicación crítica o servicios esenciales durante crisis.

Tabla 129. Disparadores y validación inicial.

Disparador / fuente	Qué valida
CDN/WAF/balanceador	Picos de tráfico, saturación, anomalías capa 7, bloqueos, rate-limit, errores o degradación por endpoint.
NDR/NetFlow/red/DNS	Saturación de enlace, origen distribuido, volumetría, patrón de protocolo, fallo DNS o pérdida de conectividad.
Aplicación/APM	Errores 5xx, latencia, colas, timeouts, agotamiento de recursos o caída de portal/API.
Usuarios/service desk	Reportes masivos de indisponibilidad o degradación desde zonas o canales concretos.
Proveedor front/cloud/ISP	Alerta de mitigación, incidencia de red, cambios de ruta, scrubbing o limitación de servicio.

Tabla 130. Acciones iniciales.

Secuencia orientativa	Acciones
0-15 min	Confirmar alcance, capa afectada, servicio, geografía, proveedor y usuarios afectados.
15-60 min	Activar proveedor CDN/WAF/red, aplicar mitigación controlada y publicar canal alternativo si procede.
1-4 h	Escalar a dirección si afecta atención masiva o coincide con incidente mayor.

Tabla 131. Contención controlada.

Contención	Condición de aprobación
Activar modo mitigación DDoS/WAF/CDN.	Aprobación AppSec/red; monitorizar falsos positivos.
Rate limiting por endpoint.	Aprobación dueño aplicación; cautela con usuarios legítimos.
Página informativa estática o degradada.	Aprobación comunicación/negocio.
Bloqueo geográfico/ASN temporal.	Aprobación CISO/DIS; documentar impacto.
Mantener canal degradado o alternativo hasta estabilidad.	No retirar mitigación hasta validar tráfico, negocio y proveedor; registrar impacto en abonados.

Tabla 132. Erradicación, recuperación y retorno.

Erradicación / recuperación	Criterio de salida
Restaurar capacidad normal gradualmente.	Tráfico estable y sin saturación.
Revisar arquitectura de publicación.	Mejora de CDN/WAF, caching, escalado y DNS.

Tabla 133. Evidencias mínimas.

Evidencia	Detalle
Alerta y ticket	ID CDN/WAF/NDR/monitorización, severidad, servicio, runbook, proveedor front y owner.
Tráfico	Volumen, origen, capa, endpoints, protocolos, DNS, NetFlow/NDR, reglas activadas y datos de proveedor.
Aplicación	Errores 5xx, latencia, colas, timeouts, consumo de recursos, endpoints afectados y disponibilidad observada.
Impacto	Duración, servicios, usuarios, zonas, degradación, canales afectados y comunicación a negocio.
Decisiones	Mitigaciones, rate-limit, scrubbing, reglas WAF/CDN, validación de usuarios legítimos y rollback.
Diferenciación	Evidencias que separan DDoS de explotación web/API, fallo de proveedor o error de cambio.

Tabla 134. Comunicación y escalado.

Comunicación	Criterio
Atención/CRM	Preparar guion y canal alternativo.
Comunicación	Aviso si la indisponibilidad afecta a abonados.
Proveedor	CDN/WAF/red/cloud.

Límites/No hacer:

No confundir DDoS con explotación sin evidencias. No aplicar reglas que bloqueen a abonados sin monitorizar. No publicar detalles técnicos de mitigación en tiempo real.

Tabla 135. Cierre del runbook.

Entregable de cierre	Contenido mínimo
Informe disponibilidad	Duración, tráfico, mitigación, impacto, proveedor y mejoras.
Mejoras	CDN/WAF, runbook de comunicación, capacidad, pruebas y observabilidad.
Mejora de detección	Ajustes de fuentes de alerta, normalización, retención, severidad, ticketing, falsos positivos y actualización del runbook/casos de uso.
Inteligencia defensiva	IOC de campaña, dominios similares, hashes, remitentes, plantillas o asunto recurrente procedentes de SOC/MDR, CSIRT o proveedor, usados solo para bloqueo, búsqueda y comunicación.

RB-12. Campaña de phishing o robo de credenciales**Tabla 136. Ficha de runbook.**

Campo	Contenido
Riesgos vinculados	R2, R10, R9, R1
Objetivo	Gestionar campaña de phishing que pueda derivar en robo de credenciales, malware, BEC o acceso remoto no autorizado.
Severidad mínima sugerida	S1 si bloqueado y sin clics; S2 si usuarios expuestos; S3 si credenciales capturadas, dirección/finanzas, proveedor, cuenta de servicio o malware; S4 si acceso privilegiado o ransomware.

Tabla 137. Disparadores y validación inicial.

Disparador / fuente	Qué valida
Usuarios	Reportes de correo sospechoso, enlaces, adjuntos, solicitud de credenciales o fraude; conservar mensaje original sin reenviarlo inseguramente.
Correo/SIEM/SOC	Campaña masiva, URL común, remitente spoofing, dominio parecido, detección antiphishing o similitud con mensajes conocidos.
IAM/MFA	Intentos de acceso tras clic, MFA fatigue, sesión anómala, cambio de contraseña o token persistente asociado.
EDR/XDR/MDM	Ejecución de adjunto, macro, script, payload, conexión posterior o postura de dispositivo no conforme.

Disparador / fuente	Qué valida
Proxy/DNS/NDR	Resolución o navegación a dominio malicioso, descarga de payload, bloqueo o conexión posterior a la campaña.
VPN/ZTNA/PAM	Uso de credenciales capturadas para acceso remoto, sesión administrativa posterior, recurso fuera de perfil o intento sobre bastión.
Proveedor/tercero	Campaña dirigida a cuentas de tercero, buzones compartidos, soporte externo o cambio fraudulento de datos de proveedor.

Tabla 138. Acciones iniciales.

Secuencia orientativa	Acciones
0-15 min	Preservar muestra, headers, URL, adjuntos, remitente, destinatarios y primeras cuentas afectadas.
15-60 min	Bloquear URL/dominio/remitente, buscar correos similares, identificar clics y accesos posteriores.
1-4 h	Revocar sesiones de usuarios que introdujeron credenciales, comunicar alerta interna y revisar cuentas sensibles, proveedor y guardia TI.

Tabla 139. Contención controlada.

Contención	Condición de aprobación
Retirar correos de buzones.	Aprobación SOC/correo; conservar muestra.
Bloquear URL/dominio/hash.	Aprobación SOC; revisar falsos positivos.
Reset MFA/contraseña y revocar sesiones.	Aprobación IAM; priorizar cuentas sensibles.
Aislar endpoint si ejecutó adjunto.	Aprobación endpoint; preservar EDR.
Recuperar usuarios afectados.	Credenciales, MFA y sesiones saneadas; confirmar ausencia de acceso posterior antes de cierre.
Suspender acceso remoto de cuentas afectadas.	Aprobación IAM/SOC; restituir solo con MFA, perfil mínimo, dispositivo conforme y revisión de actividad.
Bloquear o revisar cuenta de proveedor afectada.	Aprobación CISO/IAM y dueño de servicio; comunicación formal con proveedor y preservación de evidencias.

Tabla 140. Erradicación, recuperación y retorno.

Erradicación / recuperación	Criterio de salida
Confirmar si hubo acceso real.	Revisar IAM, correo, VPN/ZTNA, PAM, cloud, aplicaciones y cuentas de servicio vinculadas.
Reforzar detecciones y formación.	Actualizar reglas, indicadores y campaña de concienciación.
Recuperar identidad de usuarios afectados.	Contraseña/MFA/tokens saneados, sesiones revocadas, dispositivo validado y retorno por mínimo privilegio.

Tabla 141. Evidencias mínimas.

Evidencia	Detalle
Alerta y ticket	ID correo/SIEM/SOC, severidad, campaña, runbook, origen del reporte y fuentes consultadas.
Correo	Headers, URL, adjunto, hash, remitente, destinatarios, hora, asunto, campaña y muestra preservada en canal seguro.
Identidad	Clics, logins, MFA, sesiones, IP, cambios, tokens, reglas de buzón y accesos posteriores.
Endpoint	Ejecución, hash, procesos, conexiones, cuarentena/aislamiento, postura MDM y artefactos relacionados.
Red/proxy/DNS	Dominios, resoluciones, navegación, bloqueos, descargas y conexiones posteriores asociadas a la campaña.
Comunicación	Aviso interno, retirada de mensajes, formación puntual, usuarios afectados y lecciones de detección.
Acceso remoto/PAM	VPN/ZTNA, bastión, sesiones privilegiadas, recurso accedido, dispositivo, política aplicada, duración, revocación y revisión posterior.
Proveedor/cuenta de servicio	Cuenta objetivo, responsable, permisos, secretos, correos recibidos/enviados, cambios solicitados, confirmación por canal alternativo y decisión de revocación.

Tabla 142. Comunicación y escalado.

Comunicación	Criterio
Usuarios	Aviso claro, canal de reporte, pasos de seguridad y recordatorio de no introducir credenciales fuera de portales corporativos.
Dirección/finanzas	Aviso específico si campaña BEC o fraude.
DPD	Si hay acceso a datos personales.

Límites/No hacer:

No reenviar muestras maliciosas sin encapsulado o canal seguro. No culpar al usuario; priorizar reporte temprano. No cerrar sin revisar accesos posteriores, sesiones, tokens, MFA, VPN/ZTNA, PAM y proveedores afectados.
 Tabla 143. Cierre del runbook.

Entregable de cierre	Contenido mínimo
Informe phishing	Campaña, alcance, usuarios, credenciales, acciones, indicadores y formación.
Mejoras	MFA resistente, filtros, simulacros, DMARC/SPF/DKIM, reporte de phishing y alertas.
Mejora de detección	Ajustes de fuentes de alerta, normalización, retención, severidad, ticketing, falsos positivos y actualización del runbook/casos de uso.

11. Coordinación con continuidad y recuperación

La respuesta a incidentes no sustituye PCN, PCTIC ni PRD/DRP. Durante una crisis coordina prioridades de recuperación conforme al BIA preliminar de FASE 3.1 y a la arquitectura de recuperación de FASE 3.2, pero solo como hipótesis operativa hasta que los planes de continuidad y recuperación estén aprobados, probados y aceptados por negocio, TI, Operaciones y proveedores.

Tabla 144. Coordinación entre respuesta y continuidad.

Proceso	Prioridad durante incidente	Criterio
Continuidad operacional del agua	Máxima prioridad si hay impacto real o probable en servicio esencial, calidad del agua, safety o medioambiente.	Operaciones decide junto con dirección; no ejecutar acciones intrusivas.
Identidad corporativa	Prioridad temprana porque habilita administración, teletrabajo, aplicaciones y recuperación.	Cuentas break-glass controladas y PAM/bastión alternativo.
CPD y servicios base	Prioridad alta para virtualización, almacenamiento, red, AD/DNS/NTP, backups y servicios internos que habilitan recuperación.	Restauración limpia, prueba funcional, revisión de integridad y validación del dueño de servicio.
Comunicación de crisis	Canal fuera de banda si correo/cloud o identidad están afectados.	Árbol de llamadas, sala de crisis y repositorio seguro.
Atención a abonados	Activar atención mínima o canal alternativo si CRM/CALLMATIC/portal caen.	Guion de contingencia y coordinación Comunicación.
Trámites online y pagos	Degradación controlada, página informativa, conciliación posterior y canales alternativos.	Dueño de servicio + Legal/DPD si datos.
Backups y recuperación	No son solo tecnología: deben aportar punto confiable de restauración, evidencia de integridad y retorno seguro.	Backups inmutables/aislados, pruebas, hash o verificación, antimalware, logs de jobs y autorización de retorno.

Criterio de separación. Este documento decide cómo responder, contener, preservar evidencias y coordinar la recuperación inicial. La continuidad formal define procesos, prioridades de negocio, recursos alternativos y compromisos aprobados; los planes técnicos de recuperación definen reconstrucción, restauración, pruebas y retorno de cada entorno.

Tabla 145. Separación entre respuesta, continuidad y recuperación.

Elemento	Responsabilidad principal	Límite dentro de FASE 3.3
Respuesta a incidente	Triage, declaración, preservación, contención, erradicación razonable, coordinación y evidencias.	No aprueba compromisos MTD/RTO/RPO ni sustituye PCN/PCTIC/PRD.
PCN	Mantener procesos críticos, prioridades de negocio, recursos alternativos, comunicación y gobierno de crisis.	FASE 3.3 lo activa o alimenta con información; no redefine su alcance.
PCTIC	Continuidad de servicios TIC que soportan procesos de negocio, dependencias, alternativas y prioridades técnicas.	FASE 3.3 solicita activación o priorización, pero no inventa capacidades no probadas.
PRD/DRP	Recuperación ante desastre tecnológico, ubicación alternativa, restauración de plataformas, comunicaciones y dependencias.	Solo se coordina si el incidente supera capacidad ordinaria o afecta CPD/servicios base.
Plan de recuperación de entorno	Instrucciones por entorno: propietarios, dependencias, respaldos, orden de arranque, pruebas y retorno.	Debe existir o generarse como condición previa; no se improvisa recuperación crítica sin responsable.
Proveedor crítico	Aporta evidencias, estado de servicio, continuidad, soporte, tiempos estimados y acciones correctoras.	No se reactivan accesos ni se comunica recuperación sin evidencia mínima y aprobación de ACME Waters.

Tabla 146. Compuertas de recuperación limpia y retorno controlado.

Compuerta	Pregunta de control	Evidencia mínima	Aprobación
Activar continuidad	¿El impacto real o probable amenaza procesos críticos o supera hipótesis BIA?	Servicio/proceso afectado, dependencia BIA, severidad, hora, alternativa disponible.	Incident Commander + Continuidad + dueño de servicio; Operaciones si aplica.
Seleccionar origen de restauración	¿El backup/snapshot/artefacto es confiable y está fuera del alcance comprometido?	Fecha/hora, origen, job, hash o verificación, aislamiento/inmutabilidad, retención y limitaciones RPO.	Infraestructura/Backup + CISO/DIS.
Restaurar o reconstruir en entorno limpio	¿La restauración evita reintroducir persistencia, credenciales o malware?	EDR/antimalware, revisión de configuración, secretos rotados, logs preservados y checklist técnico.	Líder técnico + responsable de plataforma.
Validar funcionalmente	¿El servicio funciona y mantiene integridad de datos antes del retorno?	Prueba técnica, prueba de negocio, conciliación de datos, dependencias y riesgos residuales.	Dueño de servicio + Continuidad.
Retorno a producción	¿El retorno es reversible, gradual y monitorizado?	Plan de oleadas, rollback, ventana, comunicación, monitorización reforzada y criterio de parada.	Incident Commander; Operaciones en OT; Dirección en S4.
Cierre de recuperación	¿Quedan acciones pendientes que deban pasar a PCN/PCTIC/PRD o mejora?	Informe de recuperación, evidencias, desviaciones de RTO/RPO medidos, deuda técnica y responsables.	CISO/RSI + dueño de servicio.

Tabla 147. Dependencias críticas para recuperación durante incidente.

Dependencia	Riesgo durante recuperación	Control de respuesta
Identidad corporativa	Sin IAM/MFA/PAM/AD confiable no puede administrarse la recuperación con trazabilidad.	Cuentas break-glass controladas, bastión/PAM, rotación de secretos y revisión de privilegios.
CPD y servicios base	AD/DNS/NTP, red, almacenamiento o virtualización degradados bloquean restauración de aplicaciones.	Priorizar servicios base, cambios congelados, diagnóstico antes de reinicios y restauración por oleadas.
Backups y repositorios	Ransomware o abuso de privilegios puede cifrar, borrar o contaminar copias.	Aislar repositorios, preservar logs de jobs, validar inmutabilidad, probar restauración y registrar punto usado.
Cloud/correo	Correo comprometido impide comunicación de crisis y puede exponer datos.	Canales fuera de banda, recuperación de tenant/buzones con auditoría y validación de reglas/OAuth/permisos.
Atención a abonados	Caída de CRM/CALLMATIC o portal incrementa impacto reputacional y operativo.	Guion de atención mínima, página informativa, derivación controlada y conciliación posterior.
Trámites online/pagos	Indisponibilidad o datos inconsistentes afectan obligaciones y experiencia de usuarios.	Degradación segura, comunicación aprobada, conciliación y validación legal/DPD si hay datos personales.
Proveedores críticos	El estado externo puede limitar visibilidad, tiempos, evidencias y recuperación real.	Solicitud formal de evidencias, responsables 24x7, criterios de reactivación y plan alternativo.

Dependencia	Riesgo durante recuperación	Control de respuesta
OT y continuidad del agua	Una acción TIC puede afectar safety, calidad, medioambiente o continuidad operacional.	Operaciones valida toda acción; uso de procedimientos manuales o alternativos si están definidos y probados.

12. Métricas, ejercicios y mejora continua

Las métricas de FASE 3.3 se proponen como indicadores de madurez y aprendizaje. No se fijan SLA contractuales ni compromisos operativos cerrados hasta que el SOC/MDR, el BIA, los contratos y la capacidad real estén validados.

Tabla 148. Indicadores de respuesta no contractuales.

Indicador	Definición	Uso correcto
Tiempo de detección	Diferencia entre primera evidencia y primera alerta registrada.	Medir cobertura y calidad de telemetría, no penalizar sin contexto.
Tiempo de triage	Diferencia entre alerta y clasificación inicial.	Debe mejorar con SOAR y runbooks.
Tiempo de contención aprobada	Diferencia entre declaración y primera contención autorizada.	Separar IT estándar, sistemas críticos y OT.
Cobertura de evidencias	Porcentaje de fuentes críticas disponibles durante incidente.	Vincular a R6 y plan de logs.
Calidad de cierre	Incidentes cerrados con cronología, causa, evidencias y acciones.	No cerrar sin lecciones aprendidas.
Pruebas de runbooks	Ejercicios ejecutados y acciones de mejora completadas.	Tabletop, simulacro técnico, proveedor y OT no intrusivo.
Calidad de logs	Porcentaje de fuentes con hora sincronizada, identificadores mínimos, normalización, retención y exportación reproducible.	Usar para priorizar mejoras de visibilidad; no convertir en sanción sin analizar limitaciones técnicas.
Recalificación de severidad	Cambios S0-S4 justificados por nueva evidencia, propagación, privilegios, datos, proveedor u OT.	Medir coherencia entre detección, ticketing y escalado; revisar falsos positivos y falsos negativos.
Tiempo de recuperación medido	Diferencia entre autorización de recuperación y retorno validado del servicio.	Usar para contrastar hipótesis RTO; no convertir en compromiso sin PCN/PCTIC/PRD aprobado.
Éxito de restauración limpia	Restauraciones probadas con integridad, antimalware, prueba funcional y evidencia de punto usado.	Priorizar mejoras de backup/DR y dependencias de servicios base.
Antigüedad de prueba de backup	Tiempo desde la última restauración probada de servicio crítico o entorno equivalente.	Identificar servicios que no pueden prometer recuperación por falta de pruebas.
Trazabilidad SGSI de cierre	Porcentaje de incidentes cerrados con relación explícita riesgo-control-evidencia-decisión-mejora.	Medir calidad de gobierno y aprendizaje; revisar cierres incompletos antes de archivar.
Acciones correctivas vencidas	Acciones post-incidente fuera de plazo o sin evidencia de efectividad.	Priorizar por riesgo residual, servicio esencial, proveedor, datos personales e IT/OT.
Validaciones de cumplimiento activadas	Casos donde DPD/Jurídico/Cumplimiento se activan conforme a criterios definidos.	Medir coordinación y diligencia, no sustituir la decisión legal o regulatoria.

Tabla 149. Programa de ejercicios de respuesta.

Ejercicio	Escenario	Periodicidad sugerida	Participantes
Tabletop ejecutivo	Ransomware + comunicación + datos personales.	Semestral inicial	Comité de Crisis, CISO, CIO, DPD, Comunicación, Continuidad.
Simulacro técnico SOC	Phishing → credenciales → revocación → ticket → cierre.	Trimestral inicial	SOC/MDR, IAM, Endpoint.
Prueba de restauración limpia	Restauración de servicio base o aplicación crítica.	Según plan de continuidad	Infraestructura, Continuidad, dueño de servicio.
Ejercicio proveedor	Incidente en proveedor crítico y evidencias solicitadas.	Anual o tras contrato crítico	Compras, Jurídico, DIS, CISO, proveedor.
Ejercicio IT/OT no intrusivo	Alerta en DMZ OT, acceso remoto industrial, proveedor OT, decisión de no intrusión y aprobación Operaciones sobre logs/simulación, sin tocar producción.	Anual	Operaciones, DIS, SOC, CISO, proveedor OT si procede, Continuidad.
Prueba de canales alternativos	Correo/identidad comprometidos y activación de árbol de llamadas, sala de crisis y guion de atención.	Semestral o tras cambios relevantes	Continuidad, Comunicación, Atención, CISO, CIO.
Prueba proveedor-recuperación	Restauración o continuidad dependiente de proveedor crítico con evidencias y criterios de reactivación.	Anual o tras contrato crítico	Compras, Jurídico, DIS, CISO, proveedor, dueño de servicio.
Tabletop de gobierno y cumplimiento	Incidente S3/S4 con datos personales, proveedor crítico, continuidad, decisión de comunicación y aceptación de riesgo residual.	Anual o tras cambio normativo relevante	Comité de Crisis, CISO/RSI, DPD/Jurídico, Cumplimiento, Comunicación, Continuidad y dueño de servicio.

13. Plantillas operativas

13.1 Ticket maestro de incidente

Tabla 150. Plantilla de ticket maestro.

Campo	Contenido mínimo
ID incidente	Identificador único, vinculado a alertas y subtickets.
Fecha/hora y zona horaria	Inicio observado, primera alerta, declaración, contención, recuperación, cierre.
Clasificación y severidad	Taxonomía IR-xx y nivel S0-S4, con cambios de severidad registrados.
Activos y procesos	Activo, servicio, propietario, zona, criticidad y dependencia BIA.
Hipótesis inicial	Qué se cree que ocurre y con qué evidencias, separado de hechos confirmados.
Acciones	Acción, responsable, hora, aprobación, sistema afectado, resultado y rollback.
Evidencias	Fuente, hash si aplica, ubicación, custodia, responsable y permisos.

Campo	Contenido mínimo
Comunicaciones	Canal, destinatarios, TLP, mensaje, aprobación y hora.
Riesgos residuales	Qué queda pendiente, quién acepta y hasta cuándo.
Cierre	Causa raíz, impacto, acciones correctoras, lecciones y dueño de mejora.
ID SIEM/SOAR	Identificador de incidente/alerta en Sentinel, Logic App/run ID, regla disparadora y correlación con otros tickets.
Runbook / playbook aplicado	Runbook RB-xx, versión del procedimiento, modo manual/asistido/automatizado y resultado de ejecución.
Aprobaciones humanas	Quién aprueba, para qué acción, hora, evidencia considerada y condición de reversión.
Rollback / reversión	Plan de reversión, responsable, condición de activación y resultado si se ejecuta.
Idempotencia y reintentos	Control de duplicidades, reintentos realizados, timeouts y acciones ya aplicadas previamente.
Fuentes de alerta	Fuente primaria, fuente de contraste, ID de alerta, ID de consulta o caso SOC/MDR, hora y canal de entrada.
Fuentes revisadas y brechas de visibilidad	SIEM, EDR/XDR, NDR, WAF, IAM/PAM, cloud/correo, DNS, proxy, backup, OT o proveedor consultados; limitaciones y retención.
Motivo de escalado/desescalado	Hecho nuevo que modifica severidad, autoridad que valida y evidencia que lo soporta.
Lecciones de detección	Ajuste de caso de uso, fuente de log, normalización, retención, enriquecimiento, runbook o formación derivada del cierre.
Hipótesis BIA/MTD/RTO/RPO usada	Valor preliminar utilizado para priorizar, fuente, limitación y confirmación de que no es compromiso aprobado.
Recuperación y retorno	Origen de restauración, validaciones, dueño aprobador, hora de retorno, monitorización reforzada y criterio de parada.
Relación SGSI	Riesgo, control, política/procedimiento, acción correctiva, propietario y estado de revisión de efectividad.
Validación de cumplimiento	DPD/Jurídico/Cumplimiento activado si aplica, criterio de activación, evidencia considerada y decisión documentada.
Autoridad y aceptación	Quién acepta riesgo residual o desviación temporal, alcance, vencimiento y condición de revisión.

13.2 Registro de decisión

Tabla 151. Plantilla de registro de decisión.

Campo	Valor a documentar
Fecha/hora	
Decisión	
Responsable que aprueba	
Evidencia usada	

Campo	Valor a documentar
Alternativas consideradas	
Impacto esperado	
Riesgo aceptado	
Rollback / reversibilidad	
Resultado observado	
Acción SOAR / Logic App	
Modo de ejecución	Manual / asistido / automático con aprobación
Condición de reversión	
Control de duplicidad	Estado previo verificado / acción no aplicada previamente
ID de ejecución	ID de Logic App, alerta, incidente Sentinel o subticket asociado
Impacto esperado sobre evidencias	
Evidencias preservadas antes de ejecutar	
Alternativas menos intrusivas valoradas	
Criterio de reversión / rollback	
Separación hecho-hipótesis-inferencia	
Validación jurídica/DPD si aplica	
Propietario de riesgo / servicio	
Control o política afectada	
Validación de cumplimiento requerida	No aplica / DPD / Jurídico / Cumplimiento / ENS / proveedor
Riesgo residual y fecha de revisión	

13.3 Registro de evidencias

Tabla 152. Plantilla de registro de evidencias.

Campo	Valor a documentar
ID evidencia	
Descripción	
Fuente / sistema	
Fecha/hora de adquisición	
Responsable	
Método / herramienta	
Hash / integridad	

Campo	Valor a documentar
Ubicación segura	
TLP / confidencialidad	
Cadena de custodia	
ID correlación SIEM/SOAR	
Playbook / Logic App origen	
Consulta o exportación asociada	
Permisos de acceso	
Hash / firma / verificación de integridad	
Herramienta y versión usada	
Consulta, filtro, exportación o método de adquisición	
Zona horaria y desfase conocido	
Persona que adquiere / custodia	
Transferencias de custodia	
Clasificación/TLP y datos personales	
Limitaciones de la evidencia	
Relación con hecho, hipótesis o inferencia	
Campos mínimos de log	Marca de tiempo, zona horaria, origen/destino, protocolo/puerto si aplica, aplicación, usuario unívoco y tipo de evento.
Evento bruto y evento normalizado	Referencia al evento original, resultado de normalización/parsing y cualquier transformación aplicada.
Retención y desfase temporal	Periodo de retención, NTP o desfase conocido, pérdida de eventos, lagunas y hora de exportación.
Base de acceso a la evidencia	Rol autorizado, necesidad operativa, alcance de consulta, minimización y aprobación si contiene datos personales o información sensible.
Relación con control SGSI	Control, política, procedimiento o medida cuyo funcionamiento se acredita o cuestiona.

13.4 Solicitud mínima a proveedor durante incidente

Tabla 153. Solicitud mínima de información a proveedor crítico.

Elemento solicitado	Detalle
Descripción del incidente	Qué ocurrió, cuándo se detectó y qué servicio de ACME Waters afecta.
Alcance	Sistemas, cuentas, datos, subcontratistas, ubicaciones y clientes afectados.
Cronología	Inicio, detección, contención, recuperación y próximos hitos.

Elemento solicitado	Detalle
Datos personales	Categorías y volumen si aplica; medidas de contención.
Accesos a ACME	Cuentas, API, VPN, IPs, sesiones y acciones realizadas.
IOCs y evidencias	Indicadores, logs, artefactos y recomendaciones de búsqueda.
Continuidad	Estado de servicio, alternativa, previsión y limitaciones.
Acciones correctoras	Medidas ya ejecutadas y pendientes.
Contacto 24x7	Responsable técnico y responsable de gestión.
Evidencia de recuperación	Pruebas realizadas, punto de restauración, integridad, servicios validados, limitaciones y riesgos residuales.
Criterio de reactivación	Condiciones para reabrir accesos, APIs o integraciones, responsable aprobador y medidas de seguimiento.
Responsabilidad contractual / regulatoria	Rol del proveedor, subcontratistas, encargado/responsable si aplica, obligaciones de notificación y limitaciones reconocidas.
Evidencias de diligencia	Medidas previas, controles activos, acciones tomadas, revisión post-incidente y compromiso de remediación verificable.

13.5 Anexo forense de cierre del incidente

Tabla 154. Estructura mínima del anexo forense de cierre.

Bloque	Contenido esperado
Objeto y alcance	Incidente, ventana temporal, sistemas, fuentes analizadas y limitaciones.
Cronología	Línea temporal normalizada con referencia a evidencias y zona horaria.
Hechos confirmados	Eventos observados con fuente, ID de evidencia y método de obtención.
Hipótesis e inferencias	Explicación técnica separada de hechos, con grado de confianza y evidencias de soporte.
Acciones de respuesta	Contención, erradicación, recuperación, aprobaciones, automatizaciones y cambios realizados.
Impacto y datos	Alcance confirmado, impacto estimado y puntos pendientes de validación jurídica/DPD si aplica.
Conclusiones y mejoras	Conclusiones defendibles, limitaciones, recomendaciones y tareas de mejora abiertas.
Revisión de amenazas y vulnerabilidades	Integrada: coherencia entre amenazas priorizadas, riesgos R1-R11, vulnerabilidades V1-V12 y runbooks RB-01 a RB-12; indicadores defensivos realistas; priorización por exposición, criticidad, explotación conocida e impacto en servicio esencial; prohibición de PoC, explotación innecesaria, post-explotación ofensiva y pruebas agresivas contra producción.
Trazabilidad SGSI y cumplimiento	Riesgo, control, evidencia, decisión, riesgo residual, validación DPD/Jurídico/Cumplimiento si aplica y acción correctiva vinculada.

13.6 Ficha de recuperación y retorno controlado

Tabla 155. Ficha de recuperación y retorno controlado.

Campo	Contenido mínimo
Servicio / entorno	Nombre, propietario, criticidad, proceso BIA asociado y zona IT/OT/cloud/proveedor.
Hipótesis MTD/RTO/RPO	Valores preliminares utilizados para priorizar, fuente y advertencia de no compromiso aprobado.
Dependencias	Identidad, DNS/NTP, red, almacenamiento, BBDD, aplicaciones, proveedor, OT, atención o canales alternativos.
Origen de restauración	Backup, snapshot, build, artefacto, repositorio o reconstrucción; fecha/hora, ubicación, aislamiento e integridad.
Validaciones técnicas	Antimalware/EDR, integridad, configuración, secretos rotados, logs preservados y pruebas de seguridad no destructivas.
Validaciones de negocio/Operaciones	Prueba funcional, conciliación de datos, aceptación de riesgo residual y criterio de parada.
Aprobaciones	Incident Commander, dueño de servicio, Continuidad, CISO/DIS y Operaciones si aplica.
Retorno	Ventana, oleadas, comunicación, rollback, monitorización reforzada y hora de servicio normalizado.
Desviaciones y mejora	Brechas respecto a hipótesis BIA, limitaciones, deuda técnica, acciones PCN/PCTIC/PRD y responsable.
OWASP Top 10 / guías OWASP de aplicaciones	Referencia defensiva para clasificar riesgos web/API, abuso de autorización, validación de entrada, exposición de datos y controles de mitigación sin reproducir explotación en producción.
Catálogos CVE/CVSS, avisos de fabricante y CSIRT	Apoyo para priorizar vulnerabilidades críticas por exposición, explotación conocida, criticidad del activo, workaround, parche y evidencias internas.
Material docente de Amenazas y Vulnerabilidades	Marco conceptual para distinguir amenaza, vulnerabilidad, ataque, actor, impacto, phishing, DDoS, cadena de suministro, ataques web/API, credenciales y configuración débil.
Accesos de proveedor	Cuenta nominativa o responsable trazable, MFA/PAM/bastión si aplica, ventana, finalidad, IP/origen, permisos, caducidad, logs disponibles y procedimiento de revocación/reactivación.
Cuentas de servicio/API	Propietario, uso previsto, permisos, secretos/certificados, última rotación, dependencias, evidencias de uso anómalo y plan de rotación segura.

13.7 Registro de mejora y trazabilidad SGSI

Tabla 156. Registro de mejora post-incidente y trazabilidad SGSI.

Campo	Contenido mínimo
ID de acción	Identificador único, vinculado a incidente, runbook, riesgo y control afectado.
Origen	Lección aprendida, control fallido, laguna de evidencia, dependencia de proveedor, desviación BIA o hallazgo de recuperación.

Campo	Contenido mínimo
Riesgo y control	Riesgo R1-R11 o riesgo operativo, control existente o ausente y evidencia que justifica la mejora.
Propietario	Responsable de ejecución, área afectada y aprobador del cierre.
Prioridad	Criterio basado en exposición, criticidad, explotación conocida, datos personales, proveedor, IT/OT o continuidad.
Plan de acción	Medida, plazo, dependencia, coste estimado si se conoce y criterio de aceptación.
Evidencia de cierre	Prueba documental, log, configuración, ejercicio, restauración, contrato revisado o validación funcional.
Revisión de efectividad	Fecha, responsable, resultado, riesgo residual y decisión de mantener, ajustar o escalar la acción.

Referencias bibliográficas

A continuación se recogen referencias públicas utilizadas como marco metodológico y normativo:

- **BOE. Real Decreto 311/2022**, por el que se regula el Esquema Nacional de Seguridad. <https://www.boe.es/buscar/act.php?id=BOE-A-2022-7191>
- **BOE. Ley Orgánica 3/2018** de Protección de Datos Personales y garantía de los derechos digitales. <https://www.boe.es/buscar/act.php?id=BOE-A-2018-16673>
- **ENISA. ENISA Threat Landscape**. <https://www.enisa.europa.eu/publications/enisa-threat-landscape-2024>
- **EUR-Lex. Directiva (UE) 2022/2555** relativa a medidas para un elevado nivel común de ciberseguridad en la Unión. <https://eur-lex.europa.eu/eli/dir/2022/2555/oj>
- **EUR-Lex. Reglamento (UE) 2016/679**, Reglamento General de Protección de Datos. <https://eur-lex.europa.eu/eli/reg/2016/679/oj>
- **INCIBE. Guías y recursos para empresas**. <https://www.incibe.es/empresas/guias>
- **ISO. ISO/IEC 27001** Information security management systems. <https://www.iso.org/standard/27001>
- **ISO. ISO/IEC 27005** Information security risk management. <https://www.iso.org/standard/80585.html>
- **ISO. ISO 22301** Business continuity management systems. <https://www.iso.org/standard/75106.html>
- **ISA/IEC. ISA/IEC 62443 series**, Industrial automation and control systems security. <https://www.isa.org/standards-and-publications/isa-standards/isa-iec-62443-series-of-standards>
- **MITRE. MITRE ATT&CK**. <https://attack.mitre.org/>
- **MITRE. MITRE ATT&CK for ICS**. <https://attack.mitre.org/matrices/ics/>
- **NIST. Cybersecurity Framework 2.0**. <https://www.nist.gov/cyberframework>
- **NIST. SP 800-30 Rev. 1**, Guide for Conducting Risk Assessments. <https://csrc.nist.gov/pubs/sp/800/30/r1/final>
- **NIST. SP 800-61 Rev. 3**, Incident Response Recommendations and Considerations for Cybersecurity Risk Management. <https://csrc.nist.gov/pubs/sp/800/61/r3/final>
- **NIST. SP 800-82 Rev. 3**, Guide to Operational Technology Security. <https://csrc.nist.gov/pubs/sp/800/82/r3/final>
- **NIST. SP 800-86**, Guide to Integrating Forensic Techniques into Incident Response. <https://csrc.nist.gov/pubs/sp/800/86/final>
- **NIST. SP 800-207**, Zero Trust Architecture. <https://csrc.nist.gov/pubs/sp/800/207/final>
- **OWASP. Application Security Verification Standard**. <https://owasp.org/www-project-application-security-verification-standard/>
- **OWASP. OWASP Top 10**. <https://owasp.org/www-project-top-ten/>
- **OWASP. Web Security Testing Guide**. <https://owasp.org/www-project-web-security-testing-guide/>